

AI / GenAI Capability Evaluation Framework

A research-based framework for regulated DevOps organizations

Draft for review · Generated with Claude Code

Contents

1. Executive Summary
2. Research Findings: What Other Companies and Frameworks Do
3. Technology Company Benchmark
4. Banking and Regulated Financial Services Benchmark
5. Comparison of Level Structures Used in the Market
6. Common AI / GenAI Skill Dimensions
7. Banking / Regulated-Industry Skill Dimensions
8. Recommended Evaluation Model and Justification
9. Proposed 10-Level AI / GenAI Capability Ladder
10. Mapping of 10 Levels to Common 4/5/6-Level Models
11. Mapping to Job Families and Seniority
12. Team-Specific Evaluation Guidance
13. HR Scoring Rubric
14. Evidence-Based Assessment Process
15. Practical Tests by Role
16. Promotion and Career Path Guidance
17. 4-Month and 12-Month Target Levels
18. Training Plan by Level
19. Governance and Risk Considerations
20. HR Implementation Plan
21. Templates
22. Recommended First 10 Actions
23. References and Sources

A research-based, regulated-industry framework for DevOps, SRE, Platform, Observability, Service Desk, DataOps, QA, Security, Release, and Technical Management teams.

How to read this report: Sections 2-7 are researched best practice; Sections 8-22 are synthesized recommendations for your organization. Inferred conclusions are explicitly labelled.

1. Executive Summary

Recommendation: Adopt a hybrid **10-level AI proficiency ladder (L0-L10)** paired with a **16-dimension rubric scored 0-5**, with **regulated controls pulled early** (data handling, model-risk, approval/rollback gates evaluated from L2 onward, not bolted on at the top). Assessment is **evidence-based** (artifacts, peer review, demonstrated work — not self-rating alone), with **4-month and 12-month targets** per role.

Why it works: It separates behavior (the ladder — what a person can safely do) from capability detail (the rubric — how well, across 16 dimensions), so HR gets clean level labels while managers get a defensible, auditable scoring trail. Pulling compliance controls in early matches a regulated bank's reality: risk is highest when junior users touch real data, not when senior architects build governed platforms.

Headline answers:

Question	Answer
(a) What others do	Most public frameworks use 4-6 broad stages (e.g., awareness → adoption → integration → leadership). Few are bank-specific; almost none pull model-risk/compliance gates in early. (Inferred from public material.)
(b) Are 10 levels right?	Appropriate for our use — but only because L0-L10 doubles as both an individual growth path and an organizational capability map. For pure HR leveling, the 11 points are collapsed to 5 HR bands (see below) to avoid false precision.
(c) Recommended HR model	Use the 5-band rollup for compensation/promotion conversations; keep the full L0-L10 + 16-dim rubric for development planning and audit evidence.
(d) Mapping to 10 teams	Each team gets a target band by role , not a blanket level — most teams cluster at L3-L6, with platform/automation teams targeting L7-L9 and a small governance core at L10.

HR band rollup (for leveling decisions):

Band	Ladder levels	Plain-language meaning
A - Foundational	L0-L2	Aware of GenAI and data rules; not yet a reliable user
B - Practitioner	L3-L4	Safe, effective daily use with verification
C - Integrator	L5-L6	Embeds AI in workflows; lifts the team
D - Builder	L7-L9	Builds governed automations, solutions, and platforms
E - Leader	L10	Owns enterprise AI strategy, governance, and regulatory risk

Bottom line: This is decision-ready. HR runs leveling on 5 bands; managers run development and audit on the 11-level ladder and 16-dimension rubric; the bank gets early, provable risk controls and measurable 4-/12-month movement per team.

2. Research Findings: What Other Companies and Frameworks Do

This section summarizes how technology firms, consulting firms, AIOps vendors, public standards bodies, and regulated banks evaluate AI/GenAI skills today. Researched best practice is stated first; our interpretation is labeled separately.

Researched best practice (from public material)

How they evaluate AI skills. No major technology company, consulting firm, or bank publicly publishes an internal HR ladder that maps specific AI competencies to engineering levels. What they publish instead falls into five reusable patterns:

Approach	Who uses it (public examples)	What it actually measures
Maturity models (org/team level)	Gartner (5 stages), Microsoft partner-published Copilot adoption (5 levels), Anthropic enterprise adoption (4 stages), Google/DORA performance clusters (4)	How far the organization has progressed, not an individual's grade
Responsibility/competence ladders	SFIA 9 (7 levels), e-CF / EN 16234-1 (5 levels, mapped to EQF 3-8)	Individual responsibility by autonomy, influence, complexity, knowledge
Certification tiers	AWS, Google Cloud, IBM (Foundational → Associate → Professional/Specialty)	Tested knowledge via proctored exams
Capability-domain scoring	McKinsey "rewired" (domains, not a numbered ladder), CNCF Platform Engineering (per-aspect maturity)	Strength across named domains rather than one number
Lifecycle / autonomy gates	ServiceNow (build → benchmark → monitor), GitLab Duo (Read/Write/Delete gates), PagerDuty AIOps tiers	How much a system or person is trusted to act

What stages they use. Stage counts cluster around 4 and 5. DORA and Anthropic use 4; Gartner, Microsoft adoption, and most ITIL-style maturity scales use 5. SFIA uses 7 for individual responsibility, and the e-CF uses 5. Vendor autonomy ladders run 3-5 (Atlassian Rovo: 3; consolidated AIOps: roughly L0-L5). There is no single industry standard count.

What dimensions they assess. Across all sources, dimensions converge on: AI/GenAI literacy; prompt and tool literacy; technical depth (ML/MLOps, data engineering); RAG/grounding; agent and tool-use design; responsible AI (fairness, transparency, hallucination, privacy); productivity outcomes; and governance/model-risk literacy. Public standards add a security layer (OWASP LLM Top 10 2025, with prompt injection ranked #1) and a trustworthy-AI layer (NIST AI RMF characteristics).

What evidence they accept. The strongest public practice favors objective evidence over self-assessment:

Evidence type	Source examples
Proctored certification pass	AWS, Google Cloud, IBM
In-product telemetry	Suggestion acceptance rate, % code authored by AI, active usage
Controlled studies	GitHub ~55% faster RCT; Accenture enterprise trial
Delivery metrics	DORA / SPACE / DevEx movement (objective CI/CD and incident data)
Governance artifacts	Model inventories, Responsible-AI assessments, factsheets, control evidence (IBM watsonx.governance, PwC, KPMG)
Benchmark/ground-truth datasets	ServiceNow Data Kit; PagerDuty incident-validated playbooks

How they tie skills to seniority, hiring, and training. SFIA and the e-CF are the clearest public examples of tying skill to seniority through responsibility levels. Certifications gate hiring and role eligibility (cloud vendors). Learning academies (Deloitte AI Academy, Accenture LearnVantage, Capital One Tech College / 160-hour MLETP) structure training progression. The EU AI Act now imposes a staff AI-literacy obligation, making baseline literacy a compliance requirement rather than optional.

How they handle governance and model risk. Governance is treated as a parallel track, not a side note. NIST AI RMF (Govern, Map, Measure, Manage) maps onto bank risk committees and three-lines-of-defense. ISO/IEC 42001 is the only certifiable AI management system (38 Annex A controls). Banks apply SR 11-7 model-risk guidance with full force to AI/ML/GenAI, requiring independent validation, council sign-off (e.g., HSBC AI Review Councils), and mandatory sanctioned-gateway use (JPMorgan LLM Suite, Goldman GS AI Assistant). Vendors gate actions by risk tier (GitLab Duo: Read = always allow, Write/Delete = always ask).

Interpretation (Inferred from public material)

- Any mapping of AI competencies to specific HR engineering levels is **inferred**; no firm publishes one, so an internal ladder must be built by grafting AI competencies onto an existing responsibility framework (SFIA/e-CF).
- Public evidence on AI's value is **mixed and should temper hype**: 2024 DORA found AI adoption correlated with reduced delivery stability (larger batches, more churn), and MIT NANDA-cited work reported ~95% of GenAI pilots showed no measurable financial impact, attributed to workflow and incentive issues rather than model quality. This is why evaluation should reward measured outcomes, not tool enthusiasm.
- Best practice for a regulated org is to run a **governance maturity track in parallel** with a capability track, so individual skill growth never outruns controls (synthesized recommendation).

3. Technology Company Benchmark

Technology & Cloud Companies

Big technology and cloud vendors are both the producers of GenAI tooling and the most-studied adopters of it. Their public material is unusually useful as a benchmark because it separates three things a regulated financial-services org needs to keep distinct: (1) **certifications/skilling** that test individual capability, (2) **productivity/adoption measurement** frameworks that test whether capability turns into outcomes, and (3) **governance/model-risk** frameworks that keep AI use safe. The pattern below is drawn entirely from public sources.

(a) What these orgs actually do to evaluate and skill AI capability

Org	What they do (public)	Primary mechanism
Microsoft	Runs a Copilot Skilling Center + structured learning paths, internal "Copilot Expo"/virtual skilling events, and a Center of Excellence (CoE) model to drive and measure adoption.	Role-based learning + CoE governance
GitHub	Publishes peer-reviewed productivity research (RCTs) and ships in-product telemetry (acceptance rate, suggestions used) that customers use to measure capability uplift.	Evidence-based measurement
Google / Google Cloud	Authors the DORA State of DevOps research and Cloud Skills Boost / Google Cloud certifications (incl. Generative AI learning paths). DORA now explicitly studies AI's effect on delivery.	Industry research + certification
AWS	Skill Builder learning plans + role-based certifications: AI Practitioner (AIF-C01) and Generative AI Developer - Professional ; hands-on Bedrock/Amazon Q labs.	Tiered certification ladder
OpenAI / Anthropic	Publish enterprise adoption guides/playbooks (Anthropic's four-stage adoption framework; OpenAI enterprise guidance) and prompt/agent best-practice docs; partner with consultancies (Accenture, BCG, McKinsey) for enablement.	Adoption playbooks + partner enablement
IBM	watsonx.governance Lifecycle Advisor certification and governance training tied directly to model-risk/compliance roles.	Governance-specific credentials
Meta / Netflix / Uber / LinkedIn	Engineering-blog disclosures of internal AI tooling and developer-productivity measurement; no public formal "AI ladder."	Internal tooling + DevEx metrics (Inferred from public material)

(b) Level / maturity structures they use

Structure	Owner	Shape
5-level Copilot adoption maturity (often cited as: Initial → Experimenting → Operational → Strategic → Transformational)	Microsoft ecosystem / partners	Org maturity, not individual rank (partner-published; mark Inferred)
Agentic AI maturity model (security & governance)	Microsoft Learn	Governance maturity ladder
Certification tiers (Foundational → Associate → Professional/Specialty)	AWS, Google Cloud, IBM	Individual capability ladder
Four-stage enterprise adoption framework (roughly: explore → pilot → scale → transform)	Anthropic enterprise guide	Org adoption stages
DORA performance clusters (Low → Medium → High → Elite)	Google/DORA	Team delivery performance

Note: Cloud vendors apply **maturity models to the organization** and **certification tiers to the individual**. A financial-services org should mirror this split rather than collapse them.

(c) Skill dimensions assessed

Dimension	Where it shows up
Appropriate use / use-case selection	AWS AI Practitioner core domain ("when to use AI/ML/ GenAI")
Foundation models & prompt engineering	AWS, Google Cloud, OpenAI/Anthropic docs
Retrieval-Augmented Generation (RAG) & grounding	Amazon Q Business, Bedrock, IBM watsonx
Agent / tool-use design	Microsoft Copilot Studio, Anthropic/OpenAI agent guidance
Responsible AI: bias, fairness, hallucination, privacy	Bedrock Guardrails, Microsoft Responsible AI, IBM watsonx.governance
Productivity outcomes (throughput, quality, flow)	DORA, SPACE, DevEx
Governance / model-risk literacy	IBM watsonx Governance Lifecycle Advisor

(d) Evidence they require

Evidence type	Source	What it proves
Proctored certification exam pass	AWS, Google Cloud, IBM	Tested individual knowledge

Evidence type	Source	What it proves
In-product telemetry (suggestion acceptance rate, % code authored by AI, active usage)	GitHub Copilot, Microsoft Copilot dashboards	Real usage, not self-report
Randomized controlled trials / quasi-experiments	GitHub (≈55% faster task completion in the JavaScript HTTP-server RCT; Accenture enterprise trial)	Causal productivity uplift
DORA / SPACE / DevEx metric movement	Google/DORA research	Team-level delivery & experience
Adoption-program outcome metrics (business impact, quality, adoption rate)	Microsoft CoE guidance	Outcome vs. activity

Important caution for a regulated org: the public evidence is mixed, not uniformly positive. Google's 2024 DORA research found AI adoption **correlated with reduced delivery stability** (larger batch sizes, more churn), and an MIT NANDA-cited figure put ~95% of GenAI pilots as failing to show measurable financial impact — failures attributed to **workflow integration and incentives, not model quality**. Capability evidence should therefore pair individual skill proof with team delivery + risk metrics, never one alone.

(e) How AI capability connects to seniority / promotion / hiring / training

Connection	Public pattern	Confidence
Hiring screen	Vendor certifications (AWS AI Practitioner, Google Cloud GenAI, IBM watsonx Governance) are recognized hiring signals.	High (public)
Role specialization	Distinct tracks emerge: AI-using practitioner (AI Practitioner cert) vs. AI-building engineer (GenAI Developer Professional) vs. AI governance advisor (IBM).	High (public)
Promotion / leveling	These companies do not publish internal "AI rungs" on their engineering ladders. Any claim that "level X requires AI skill Y" inside Microsoft/Google/Meta is (Inferred from public material) and should not be presented as fact.	Inferred — flag clearly
Training pathway	Strongly explicit: learning paths → certification → hands-on labs (Skill Builder, Skilling Center, Cloud Skills Boost).	High (public)

(f) Safety / governance / security / model-risk handling

Control area	Representative public mechanism
Content & output safety	Amazon Bedrock Guardrails (content filtering, topic blocking, hallucination/PII reduction); Microsoft Responsible AI principles

Control area	Representative public mechanism
Risk identification before deploy	Microsoft "Responsible AI risk radar"; Agentic AI maturity model
Model lifecycle & model risk	IBM watsonx.governance — use-case registration, lifecycle tracking, factsheets/metadata, fairness/bias/drift monitoring; integrates with OpenPages Model Risk Governance (directly relevant to banking model-risk regimes such as SR 11-7-style oversight)
Data custody / vendor risk	Public scrutiny of data-retention policies (e.g., Anthropic 30-day policy debate) shows enterprises now treat prompts, outputs, logs, and traces as governed data
Center of Excellence governance	Microsoft CoE model centralizes policy, usage standards, and measurement

Bottom line for benchmarking: the credible, transferable pattern from this category is a **three-layer model** — (1) tiered individual certifications (foundational → professional → governance-specialist), (2) outcome measurement via DORA/SPACE/DevEx plus tool telemetry, and (3) a governance/model-risk spine (guardrails + lifecycle governance + CoE). What is **not** publicly available — and must not be fabricated — is any internal company HR ladder mapping specific AI competencies to specific engineering levels.

Consulting / Research / Advisory Firms

Consulting, research, and advisory firms shape how most large enterprises (including regulated banks) think about AI capability. They play two roles at once: they sell AI maturity assessments and upskilling programs to clients, and they run large internal AI fluency programs for their own staff. Both are useful benchmarks. The key caveat for a regulated org: these firms publish frameworks and maturity stages, but they generally do not publish the internal grade-by-grade HR rubrics that map AI skill to specific pay bands or promotion gates. Where a mapping is implied but not officially published, it is marked **(Inferred from public material)**.

(a) What these firms actually do to evaluate and skill AI capability

Firm	Capability-building approach (public)	Internal workforce program
Deloitte	"AI fluency" framing across the whole workforce; sells upskilling/reskilling strategy and job-redesign to clients via its State of AI in the Enterprise research.	Deloitte AI Academy — structured internal upskilling for technical and non-technical staff; role-based learning paths and certifications.
McKinsey	AI capability building as a formal practice; "rewired" operating-model thinking that pairs talent, tech, and adoption. QuantumBlack is the AI/analytics arm that defines technical role archetypes (data scientist, ML engineer, data engineer, designer, translator).	Internal academies and the "Forward"/QuantumBlack Labs talent pipelines; heavy use of role archetypes.

Firm	Capability-building approach (public)	Internal workforce program
Gartner	Research-and-advisory: publishes the widely used AI Maturity Model (5 stages) and Hype Cycle; advises on operating model, AI governance, and skills gaps.	N/A (advisory model, not a delivery workforce in the same sense).
Accenture	Sells large-scale "LearnVantage" and AI-talent transformation; talent strategy around "reinvention" and human + AI teams.	Mass internal reskilling at scale (hundreds of thousands of staff) with role-based AI learning.
BCG	AI transformation capability via BCG X (its tech build/design unit); the "10-20-70" rule (10% algorithms, 20% tech/data, 70% people/process) drives where capability investment goes.	Internal AI academies; technical archetypes in BCG X.
PwC	Responsible AI toolkit and workforce reskilling ("New world. New skills."); strong governance/assurance angle.	Firm-wide AI upskilling and citizen-developer programs.
KPMG	AI governance / Trusted AI framework and "digital workforce"/automation capability; control and assurance lens.	Internal AI upskilling tied to its trust framework.
Forrester	Research-and-advisory: AI maturity and AI adoption models; segments organizations by adoption posture (e.g., experimenters vs. transformers) (Inferred from public material — exact tier labels vary by Forrester report).	N/A (advisory model).

(b) Level / maturity structures they use

Framework	Stages / levels	What advances a stage
Gartner AI Maturity Model	1. Awareness → 2. Active → 3. Operational → 4. Systemic → 5. Transformational	Moving from informal talk (1) to pilots (2), to at-least-one production system with funding and in-house expertise (3), to AI embedded across processes (4), to AI reshaping the business model (5).
Forrester AI maturity / adoption	Adoption tiers from early experimentation through scaled/transformative use (Inferred from public material)	Breadth of deployment, governance discipline, and measurable business value.
McKinsey "rewired" / capability	Less a numbered ladder; assessed across domains — strategy, talent, operating model, tech/data, adoption & scaling, governance	Capability scored per domain; scaling and adoption are the hardest gates.
BCG 10-20-70	Not a level model — an investment-allocation principle	Emphasizes that 70% of value comes from people, process, and adoption, not the model itself.

Framework	Stages / levels	What advances a stage
Deloitte fluency	"AI fluency" across the workforce; foundational → applied → advanced framing (Inferred from public material)	Breadth (how much of the workforce is fluent) plus depth (job redesign around AI).

These maturity models are **organizational**, not individual. A regulated org should treat them as a "where is our function on the curve" instrument, and build a separate individual skills ladder on top.

(c) Skill dimensions they assess

Dimension	What it covers	Emphasized by
AI/GenAI fluency	Understanding what AI can/can't do; prompt and tool literacy; judging output quality	Deloitte, Accenture, PwC
Technical depth	ML/MLOps engineering, data engineering, model development, evaluation	McKinsey/QuantumBlack, BCG X
Data foundation	Data quality, pipelines, governance, feature management	All
Translation / product	Turning business problems into AI solutions; the "translator" / AI product role	McKinsey, BCG
Adoption & change	Driving usage, redesigning jobs and workflows around AI	Deloitte, Accenture, BCG (the "70")
Responsible / Trusted AI	Fairness, transparency, accountability, human oversight	PwC, KPMG
AI governance & risk	Model risk, controls, regulatory alignment	KPMG, Gartner, PwC

(d) Evidence they require / recommend

Evidence type	How it shows up
Production systems in use	Gartner's "Operational" stage requires at least one AI system in production with dedicated funding — not slideware.
Measurable business value	Forrester and McKinsey both gate higher maturity on demonstrated value/ROI, not pilots.
Role-based certifications	Deloitte AI Academy and Accenture LearnVantage issue completion/certification tied to learning paths.
Portfolio / build evidence	QuantumBlack and BCG X archetypes are evidenced by shipped models, code, and deployed solutions.
Governance artifacts	PwC/KPMG expect documented Responsible-AI assessments, model inventories, and control evidence.

Evidence type	How it shows up
Adoption metrics	% of workforce trained/active, jobs redesigned (Deloitte notes 84% of firms had not redesigned jobs — a maturity tell).

(e) How AI capability connects to seniority / hiring / promotion / training

Mechanism	Public pattern
Role archetypes drive hiring	McKinsey/QuantumBlack and BCG X hire and level against named technical archetypes (data scientist, ML engineer, data engineer, translator, designer), each with seniority tiers.
Learning academies as the training spine	Deloitte AI Academy, Accenture LearnVantage, and firm-specific academies are the standard training mechanism; role-based paths gate access to AI-heavy work.
Promotion linkage	Firms publicly tie AI fluency to "reinvention" of roles, but the explicit "you need AI skill X to make Senior Manager" rubric is not published — treat any such mapping as (Inferred from public material) .
Talent strategy change	Deloitte's research found ~75% of organizations expect to change talent strategies within two years due to GenAI — signaling AI capability is becoming a hiring and progression factor, not optional.

(f) Safety / governance / security / model-risk handling

Firm	Governance framing	What a regulated org can borrow
PwC	Responsible AI toolkit: fairness, transparency, accountability, robustness, human oversight; assurance-oriented.	A skills dimension for "Responsible AI" with named, assessable behaviors.
KPMG	Trusted AI / AI governance framework and "digital workforce" controls; audit and assurance heritage.	Control-and-evidence mindset that maps cleanly to bank model-risk (e.g., SR 11-7-style) expectations.
Gartner	AI TRISM (Trust, Risk and Security Management) as a discipline; advises governance maturity alongside capability maturity.	Pair a governance maturity track with the capability track so skill growth never outruns control.
McKinsey/BCG/ Deloitte/ Accenture	Responsible-AI principles embedded in transformation work; risk treated as a scaling gate.	Make "can this be deployed safely and within policy" an explicit promotion-level competency for senior technical roles.

Practical takeaway for a regulated FS org: use a Gartner-style 5-stage model to benchmark the organization; borrow McKinsey/BCG role archetypes to define individual technical levels; adopt Deloitte/Accenture academy + role-based learning paths as the training spine; and bolt on a PwC/KPMG-style Responsible-AI and model-risk track so

capability and governance advance together. Do not import any firm's internal promotion rubric as if it were published — it is not.

Sources: - [Gartner AI Maturity Model \(BMC summary\)](#) - [Deloitte: State of AI in the Enterprise 2026](#) - [Deloitte AI Academy](#) - [Deloitte: Generative AI shaping the future workforce](#)

ITSM / DevOps / Observability / AIOps Vendors

This category is the most operationally relevant benchmark for a regulated financial-services technology org, because these vendors embed AI directly into the tools your SRE, platform, ITSM, and DevSecOps teams already use. Their public material does two useful things: (1) it defines **autonomy / automation maturity levels** that you can borrow directly as the spine of a capability ladder, and (2) it documents **human-in-the-loop (HITL) controls** that map cleanly to model-risk and change-management requirements. Most of these vendors do not publish a "data scientist skill rubric" — they publish an operating model for how much you let AI act, and what proof you need before you raise the autonomy dial. That operating model is exactly what an HR/skills ladder should track.

(a) What these orgs actually do to evaluate and skill AI capability

The common pattern is **graduated autonomy gated by evidence**, not a one-time certification. Capability is demonstrated by an operator's (or team's) ability to move a workflow up the autonomy scale safely.

Vendor / product	What they evaluate / how they skill people	Inferred vs. published
ServiceNow Now Assist	Now Assist Skill Kit lets builders create and publish custom prompts/skills and build "ground-truth" datasets (Now Assist Data Kit) to benchmark accuracy before deployment. Now Assist Analytics measures adoption, usage, and performance. Skilling is therefore tied to building, benchmarking, and monitoring skills, not just using them.	Published
Atlassian Intelligence / Rovo + JSM	Capability is demonstrated by building/customizing Rovo agents , grounding them in knowledge, and graduating from chat to assigned tickets to autonomous trigger-based automation. Atlassian frames a "governance-in-the-loop" model where humans audit/validate AI-prepared work.	Published
PagerDuty AIOps	Operators progress from manual response → AI-assisted triage/diagnostics → "suggest then act on approval" → smart playbooks generated from past incidents. Capability is shown by codifying reliable automations and runbooks.	Published

Vendor / product	What they evaluate / how they skill people	Inferred vs. published
Datadog AI (Bits AI), Dynatrace Davis, New Relic AI, Splunk AI/ITSI, Elastic AI Assistant, Grafana AI	Capability is shown by configuring the assistant against your telemetry, validating its root-cause/anomaly outputs against known incidents, and tuning detectors/SLOs. Dynatrace's "Davis" couples causal/predictive AI with generative AI — operators must understand why a recommendation was made before acting on it.	Mostly inferred from public product positioning
Harness AI, GitLab Duo, HashiCorp/Terraform AI	Capability is shown by safely operating agentic flows in the SDLC/IaC: GitLab Duo classifies tools as Read/Write/Delete and gates Write/Delete behind approval; HITL is default in interactive mode. Operators prove competence by configuring tool-level governance policies correctly.	Published (GitLab); inferred (Harness, HashiCorp)

(b) Level / maturity structures they use

There is strong convergence on a **3-to-5 step autonomy ladder**. This is the single most reusable artifact for your own ladder.

Level	Common label (synthesized from PagerDuty, Atlassian, GitLab patterns)	What the human does	What the AI does
L0	Manual / no AI	Everything	Nothing
L1	Assistive / conversational	Asks, reads, decides	Summarizes, drafts, answers, surfaces context
L2	Recommend (suggest-only)	Reviews and approves each suggestion	Proposes root cause, remediation, code, runbook
L3	Approve-to-act (HITL gate)	Approves a specific action before execution	Executes only after explicit human approval
L4	Supervised autonomy	Monitors, sets guardrails, handles exceptions	Acts autonomously within bounded, low-risk scopes; escalates edge cases
L5	Autonomous (bounded)	Audits after the fact; owns guardrails/policy	Triggers and completes whole workflows within policy

- **Atlassian Rovo** publishes a 3-level model: conversational → integrated team member (assign tickets to agents) → autonomous trigger-based automation. (Published)
- **PagerDuty** describes a progression from assisted diagnostics to "run remediation automatically upon approval" to learned smart playbooks. (Published)

- **GitLab Duo** encodes the gate in tool classification: Read = Always Allow, Write/Delete = Always Ask. (Published)
- The L0–L5 consolidated table above is **(Inferred / synthesized from public material)** — no single vendor publishes this exact 6-step scale, but it is a faithful composite.

(c) Skill dimensions they assess

Dimension	What "good" looks like	Where it shows up publicly
Prompt / agent authoring	Can build and version custom skills/agents and ground them in trusted data	ServiceNow Skill Kit; Atlassian Rovo agents; GitLab Duo flows
Evaluation & benchmarking	Builds ground-truth datasets, measures accuracy before rollout	ServiceNow Data Kit (published); inferred for others
Telemetry / domain grounding	Connects AI to the right observability data; validates RCA outputs	Datadog, Dynatrace Davis, New Relic, Splunk, Elastic, Grafana (inferred)
Automation engineering	Codifies runbooks/playbooks, sets safe blast radius	PagerDuty Runbook/Process Automation (published)
Guardrail / policy configuration	Sets which actions are allowed/ask/blocked; defines approval gates	GitLab tool governance; ServiceNow guardrails (published)
Judgment / oversight	Knows when to keep a human in the loop; recognizes hallucination/over-trust	Atlassian "governance-in-the-loop"; ServiceNow HITL escalation (published)
Monitoring & continuous tuning	Tracks adoption, drift, accuracy, cost post-deployment	ServiceNow Now Assist Analytics (published)

(d) Evidence they require

Evidence type	Concrete artifact	Source
Ground-truth / benchmark datasets	Labeled datasets to predict and verify accuracy before go-live	ServiceNow Data Kit (published)
Accuracy / adoption / performance metrics	Dashboards of usage, accuracy, value	ServiceNow Now Assist Analytics (published)
Approval audit trails	Logged human approvals for Write/Delete/remediation actions	GitLab Duo HITL; PagerDuty approve-to-act (published)
Versioned agents / runbooks / IaC	Published skills, smart playbooks, Terraform modules in source control	ServiceNow, PagerDuty, HashiCorp (published/inferred)
Guardrail / policy configs	Tool-rule and content-safety configuration as reviewable artifacts	GitLab governance settings; ServiceNow Guardian (published)

Evidence type	Concrete artifact	Source
Incident learnings	Playbooks auto-generated and validated from past incidents	PagerDuty (published)

(e) Connecting AI capability to seniority / promotion / hiring / training

These vendors do not publish HR ladders, so the mapping below is **(Inferred / synthesized for your context)** but is well-grounded in their autonomy models:

Seniority signal	Demonstrated capability (using vendor autonomy levels)
Junior / IC	Operates at L1-L2: uses the assistant, reviews suggestions, never auto-executes
Senior / IC	Operates at L3: authors agents/runbooks, configures HITL gates, validates accuracy with ground-truth data
Lead / Staff	Operates at L4: designs supervised-autonomy scopes, sets blast radius, owns evaluation pipelines and monitoring
Principal / Manager	Owns L5 policy: decides where autonomy is permitted, signs off on guardrails, accountable for model-risk posture

Training pathways in this category are tool-anchored: vendor certifications + hands-on labs (e.g., ServiceNow Now Learning, Atlassian University, PagerDuty/GitLab docs and certifications). Practical recommendation: **make promotion contingent on demonstrated, audited movement up the autonomy ladder** — not on tenure or tool familiarity alone.

(f) Safety / governance / security / model-risk handling

This is the strongest, most directly transferable part of the category for a banking-style org.

Control	Mechanism	Vendor (published)
Action gating by risk	Read = auto, Write/Delete = require approval; remediation runs only on approval	GitLab Duo; PagerDuty
Content/safety guardrails	Monitoring and mitigation of offensive content, security vulnerabilities, sensitive-data exposure	ServiceNow Now Assist Guardian
Sensitive-topic escalation	Detects sensitive interactions and routes to a human instead of answering	ServiceNow (HR chatbot example)
Prompt-injection / agentic threat mitigation	Built-in prompt-injection detection; documented agentic security threats; composite identity for least-privilege and auditability	GitLab Duo
Human-in-the-loop by default	No action without approval in interactive mode; "governance-in-the-loop" validation	GitLab Duo; Atlassian Rovo

Control	Mechanism	Vendor (published)
Regulatory alignment	Explicit reference to EU AI Act-style HITL observability and multi-person approval for automated decisions	GitLab Duo
Monitoring / drift visibility	Adoption, usage, accuracy, and performance analytics post-deployment	ServiceNow Now Assist Analytics

Key takeaway for the org: adopt the autonomy ladder (b) as the backbone of your AI capability rubric, require the evidence in (d) as the gate to raise autonomy, and treat (f) controls as non-negotiable change-management requirements. The vendors give you both the maturity scale and the governance plumbing; the HR ladder's job is to certify that people can operate each rung safely and prove it with auditable artifacts.

Public Frameworks & Standards

Public frameworks rarely measure "GenAI skill" as a single score. Instead, they contribute three reusable building blocks that a financial-services org can borrow: (1) **levels of responsibility** (how senior/autonomous a person is), (2) **skill or maturity dimensions** (what is being assessed), and (3) **controls and evidence** (what must be demonstrated, especially for safety, security, and model risk). The table below maps each framework to what it actually contributes.

(a) What these frameworks do, and what they contribute

Framework	What it actually does	Primary contribution
SFIA (Skills Framework for the Information Age), v9	Defines IT/digital skills against 7 generic "Levels of Responsibility." SFIA 9 (2024) added explicit AI/data-science skills and guidance on splitting work between humans and AI.	Seniority ladder + per-skill level descriptors; directly usable for promotion/hiring
European e-Competence Framework (e-CF / EN 16234-1)	EU standard mapping 41 ICT competences to 5 proficiency levels (e-1 to e-5), aligned to the European Qualifications Framework (EQF).	Competence model with proficiency tiers; portable across EU regulatory contexts
DORA / Accelerate metrics	Research-backed software delivery performance metrics; benchmarks teams as Low / Medium / High / Elite.	Team-level outcome metrics (not individual skill) to validate whether AI tooling actually improves delivery
ITIL 4	Service management framework; defines practices and a "Four Dimensions" + Service Value System model.	Operational capability and process maturity language for run/ops teams

Framework	What it actually does	Primary contribution
CNCF Platform Engineering Maturity Model	Assesses internal developer platforms across maturity levels.	Maturity tiers for platform/enablement teams that ship AI tooling internally
NIST AI RMF (AI 100-1)	Voluntary risk-management framework structured around 4 functions: Govern, Map, Measure, Manage (plus a GenAI Profile, NIST AI 600-1).	Governance functions and control categories; the backbone for AI risk governance
ISO/IEC 42001:2023	Certifiable AI Management System (AIMS) standard; Annex A lists 38 AI-specific controls across 9 objectives.	Auditable management-system controls and evidence requirements
OWASP Top 10 for LLM Applications (2025)	Ranked list of the top LLM/GenAI application security risks.	Concrete security competencies and threat checklist for AI-assisted dev
Responsible-AI / AI-literacy frameworks (e.g., OECD AI Principles, EU AI Act AI-literacy duty, NIST trustworthy-AI characteristics)	Define principles and a baseline literacy obligation for staff who build or use AI.	Literacy baseline + ethical dimensions; increasingly a legal requirement
Secure-SDLC for AI (e.g., NIST SSDF SP 800-218 + 800-218A GenAI profile, SAFECODE/OWASP guidance)	Extends secure-development practices to AI/GenAI components.	Process controls and developer practices for shipping AI safely

(b) Level / maturity structures

Framework	Level structure	Notes
SFIA 9	7 levels: 1 Follow, 2 Assist, 3 Apply, 4 Enable, 5 Ensure/Advise, 6 Initiate/Influence, 7 Set strategy/Inspire/Mobilise	Each level defined by Autonomy, Influence, Complexity, Business/behavioural skills, Knowledge
e-CF	5 proficiency levels (e-1 lowest to e-5 highest), mapped to EQF levels 3-8	Competence-based rather than role-based
DORA	4 performance clusters: Low / Medium / High / Elite	Outcome bands, not skill levels
ITIL 4	Practice capability maturity (assessed per practice); no single fixed scale	Often paired with a 5-point capability model

Framework	Level structure	Notes
CNCF Platform Eng. Maturity	4 maturity levels (Provisional → Operational → Scalable → Optimizing), assessed per aspect	Lower = tactical, higher = strategic; not meant to "max out" everywhere (Inferred: exact level labels vary by source revision)
NIST AI RMF	No maturity levels; 4 functions x categories/subcategories	Profiles/tiers are organization-defined
ISO/IEC 42001	Conformant / non-conformant (certifiable); not graded	Maturity is implied by control coverage
OWASP LLM Top 10	Ranked risk list (LLM01–LLM10); no maturity scale	Used as a coverage checklist

(c) Skill / assessment dimensions

Framework	Dimensions assessed
SFIA 9	Autonomy, Influence, Complexity, Business skills/behaviours, Knowledge — applied per skill (incl. AI/data skills)
e-CF	5 competence areas: Plan, Build, Run, Enable, Manage
DORA	Deployment frequency, Lead time for changes, Change failure rate, Failed-deployment recovery time (+ reliability)
ITIL 4	Four Dimensions: Organisations & People, Information & Technology, Partners & Suppliers, Value Streams & Processes
CNCF Platform Eng.	Investment, Adoption, Interfaces, Operations, Measurement
NIST AI RMF	Trustworthiness characteristics: valid & reliable, safe, secure & resilient, accountable & transparent, explainable & interpretable, privacy-enhanced, fair (bias managed)
ISO/IEC 42001	AI policy, internal org/roles, resources, AI system lifecycle, data quality & lineage, human oversight, third-party/supply chain
OWASP LLM Top 10	Prompt injection, sensitive-info disclosure, supply chain, data/model poisoning, output handling, excessive agency, system-prompt leakage, vector/embedding weaknesses, misinformation, unbounded consumption
Responsible-AI / literacy	Fairness, transparency, accountability, human oversight, privacy, plus baseline AI literacy for staff

(d) Evidence required

Framework	Typical evidence
SFIA 9	Demonstrated responsibilities at level, work products, manager/peer assessment, certifications mapped to skills

Framework	Typical evidence
e-CF	Competence portfolio mapped to EQF; qualifications and demonstrated outputs
DORA	Telemetry from CI/CD, incident, and deployment systems (objective, not self-reported)
ITIL 4	Process records, defined value streams, role definitions, audited practice adoption
CNCF Platform Eng.	Platform adoption metrics, self-service interfaces, operational/SLO data, user feedback
NIST AI RMF	Risk register, impact assessments, measurement results, documented Govern/Map/Measure/Manage activities
ISO/IEC 42001	Statement of Applicability, AI impact assessments, data lineage records, oversight logs, drift monitoring, audit trail (third-party certifiable)
OWASP LLM Top 10	Threat models, red-team / pen-test results, mitigations per risk, secure-config evidence
Secure-SDLC for AI	SBOM/AI-BOM, provenance records, secure-coding and review evidence, test/scan results

(e) How AI capability connects to seniority / promotion / hiring / training

- **SFIA and e-CF are the only two that directly drive HR decisions.** SFIA level descriptors are commonly used to write role profiles, set promotion criteria, and structure pay bands; SFIA 9's added AI/data skills let an org say, for example, "an L5 ML engineer is expected to Ensure/Advise on model deployment." e-CF maps to formal qualifications and is favored where EU/regulatory portability matters.
- **DORA, CNCF, and ITIL connect at the team level, not the individual.** They are best used to validate that AI investment paid off (e.g., did AI-assisted coding move the team from High to Elite, or did change-failure-rate worsen?), and to gate enablement/training spend.
- **NIST AI RMF, ISO 42001, OWASP, and responsible-AI frameworks define required competencies and literacy** that should appear as expectations in role descriptions and as training curricula — increasingly a hiring/onboarding prerequisite rather than a "nice to have." (Inferred from public material: none of these frameworks prescribe a promotion ladder; orgs typically graft their competencies onto SFIA levels.)

(f) Safety / governance / security / model risk

Concern	Best-fit framework(s)	What it provides
AI governance & risk management	NIST AI RMF (Govern/Map/Measure/Manage); ISO/IEC 42001	Functions + certifiable controls; maps cleanly onto bank-style risk committees
Model risk management	NIST AI RMF + ISO 42001 (and, inferred, alignment with bank model-risk practice such as SR 11-7-style validation)	Validation, monitoring, drift detection, human oversight

Concern	Best-fit framework(s)	What it provides
Application/LLM security	OWASP Top 10 for LLM Applications (2025)	Prioritised threat list and mitigations for AI-assisted and AI-embedded apps
Secure development of AI	NIST SSDF (SP 800-218 + 800-218A GenAI profile); OWASP/SAFECODE guidance	Secure-SDLC practices extended to training data, models, and prompts
Responsible AI / fairness / literacy	OECD AI Principles; NIST trustworthy-AI characteristics; EU AI Act AI-literacy duty	Ethical dimensions + a mandatory staff-literacy baseline
Operational resilience	ITIL 4; DORA recovery/reliability metrics	Incident handling and recovery expectations for AI services

Practical takeaway for a regulated org: use **SFIA 9** (or e-CF) for the people ladder, **NIST AI RMF + ISO 42001** for the governance and model-risk spine, **OWASP LLM Top 10 + NIST SSDF** for the security competencies, and **DORA/CNCF/ITIL** as outcome evidence that AI capability is real and not just claimed.

Sources: [SFIA 9 AI skills framework](#) · [CNCF Platform Engineering Maturity Model](#) · [OWASP Top 10 for LLM Applications 2025](#) · [ISO/IEC 42001 Annex A controls](#)

4. Banking and Regulated Financial Services Benchmark

4.0 Technology Companies vs Banks / Financial Institutions

Area	Technology Companies	Banks / Financial Institutions	Impact on Evaluation Framework
AI experimentation	Often faster and more open	More controlled and policy-driven	Safety and policy knowledge must be evaluated earlier
Data usage	Broader internal experimentation	Strict data classification and privacy controls	Data handling must be part of basic levels
Automation	Higher autonomy may be allowed	Human approval and audit required	Automation levels must require approval and rollback
Governance	Product/platform-driven	Risk, compliance, legal, audit heavily involved	Governance competency must be explicit
Evaluation	Productivity and innovation focused	Risk-adjusted capability and control focused	Evaluation must balance productivity and risk

Area	Technology Companies	Banks / Financial Institutions	Impact on Evaluation Framework
Agentic AI	Faster pilots	Strong restrictions on production actions	Agentic levels require stronger controls
Evidence	Engineering output	Engineering output plus compliance evidence	HR evidence must include auditability
Skills	AI builder skills	AI builder plus AI risk/control skills	Ladder must include risk and governance skills

Banking & Regulated Financial Services Benchmark

Regulated financial-services firms approach AI capability very differently from pure tech companies. Because they operate under model-risk, consumer-protection, and operational-resilience regimes (e.g., SR 11-7, GDPR, EU AI Act, FCA/PRA, MAS), they treat "AI skill" as a combination of technical ability **and** control discipline. Capability is rarely promoted on raw model-building talent alone; it is gated by whether the person can build, deploy, and operate AI in a governed, auditable, human-supervised way.

Almost none of these firms publish an internal "AI skills ladder." The items below are drawn from public press releases, careers/job ads, annual-report and CIO statements, and bank engineering blogs. Anything not directly stated publicly is marked **(Inferred from public material)**.

(a) What these orgs actually do to evaluate and build AI capability

Firm	Public action	What it signals about capability-building
JPMorgan Chase	"LLM Suite" rolled out to ~140K-250K employees; multiplexes OpenAI/Anthropic models; 450+ GenAI use cases; named American Banker "Innovation of the Year" 2025	Mass-scale enablement of all staff, not just engineers; a governed internal gateway becomes the skill-building surface
Morgan Stanley	"AI @ Morgan Stanley Assistant" (2023) and "Debrief" for wealth advisors; "AskResearchGPT" (GPT-4o) for institutional securities, over 70K research reports	Role-specific assistants; advisors are trained to supervise AI output, not author from scratch
Goldman Sachs	Firmwide "GS AI Assistant" after ~10K-employee pilot; developer-tailored version; approved internal-hosted LLMs (GPT-4, Gemini, open-source); Copilot in secure environments	Tiered, role-tailored assistants; engineers skilled on copilots inside approved environments
Capital One	"Tech College" (since 2017, incl. Machine Learning & AI track); 160-hour Machine Learning Engineering Training Program (MLETP); strong public Responsible/Explainable AI language in ML job ads	Formal internal academy + structured conversion of SWE/data engineers into ML engineers

Firm	Public action	What it signals about capability-building
HSBC	"AI Review Councils" embedded across the group (1H25); Chief AI Officer; "Group Responsible AI Governance Manager" roles advertised; heavy training investment	Governance-first; capability measured partly by ability to clear council review
DBS	"PURE" framework (Purposeful, Unsurprising, Respectful, Explainable); explicit "co-pilot, human-in-the-loop" stance; staff trained to interpret AI recommendations	Skill = safe interpretation and oversight of AI, not autonomous use
Citi	Publicly outlined firmwide AI employee training programme; deployed developer/coding assistants and internal GenAI tools to tens of thousands	Broad workforce literacy push alongside engineer tooling

Common pattern: a **secure internal LLM gateway** (model-agnostic, logged) is the primary place capability is exercised and observed. Public personal ChatGPT/Claude use is typically restricted; the sanctioned tool is the measurement surface.

(b) Level / maturity structures they use

Structure	Where seen publicly	Notes
Three Lines of Defense	SR 11-7 / OCC guidance, applied to AI/GenAI models	Develop → independent validate → internal audit; this is the dominant maturity lens in banking
AI Review Council / approval gates	HSBC (AI Review Councils), responsible-AI council roles across banks	Use cases progress through tiered review by risk level
Role-tailored assistant tiers	Goldman, Morgan Stanley, JPMorgan	Developer / banker / analyst / advisor variants of the same platform
Internal academy progression	Capital One Tech College tracks; MLETP completion	Structured course-based advancement (Inferred from public material that completion gates ML role eligibility)
Risk-tiered model classification	SR 11-7 model inventory + materiality tiering	High-materiality models get heavier validation and monitoring

There is **no publicly disclosed numbered "AI capability ladder" (L1-L5)** at these firms. The de-facto maturity model is the model-risk lifecycle plus council approval, not an HR competency rubric. **(Inferred from public material.)**

(c) Skill dimensions they assess

Dimension	Evidence it is assessed	Pure-tech contrast
ML/GenAI engineering (LLMs, RAG, vector stores, full ML lifecycle)	Capital One ML job ads; Goldman developer assistant	Similar to tech

Dimension	Evidence it is assessed	Pure-tech contrast
Responsible & Explainable AI	Capital One ML role expectations; DBS PURE; HSBC governance roles	Far heavier weighting than typical tech
Model risk & validation literacy	SR 11-7 three-lines structure	Largely absent in pure tech
Secure/governed tool use (data handling, no leakage)	Goldman internal-hosted models; JPMorgan LLM Suite gateway	Stricter; sanctioned-tool-only
Human-in-the-loop / oversight judgment	DBS co-pilot stance; HSBC "human judgement at the core"; MS advisor workflows	Distinctive to regulated firms
AI literacy for non-engineers	JPMorgan 140K+ rollout; Citi training programme	Broader, board-mandated literacy
Auditability / documentation	SR 11-7 documentation requirements (Inferred for GenAI specifically)	Much stronger

(d) Evidence they require

Evidence type	Public basis
Completion of internal training (course/program)	Capital One Tech College, MLETP (160h)
Demonstrated safe use inside the sanctioned LLM gateway	JPMorgan LLM Suite, Goldman GS AI Assistant, MS assistants
Model documentation, validation records, monitoring logs	SR 11-7 model-risk requirements (applied to AI/ML/GenAI)
Council / review-board sign-off on a use case	HSBC AI Review Councils
Adherence to a named responsible-AI framework	DBS PURE; firm-published responsible-AI principles
Productivity/quality outcomes (time saved, accuracy)	JPMorgan cites ~3–6 hrs/week saved; MS research-query deflection (outcome metrics, firm-reported)

(e) How AI capability connects to seniority / hiring / promotion / training

- **Hiring:** ML/AI engineer job ads (e.g., Capital One) explicitly require Responsible & Explainable AI experience and full-lifecycle ML — i.e., governed-AI skill is a screening criterion, not a bonus. **(Public job-ad evidence.)**
- **Dedicated leadership tracks:** Creation of Chief AI Officer roles (HSBC) and "Responsible AI Governance Manager" postings shows AI governance has its own senior career path. **(Public.)**
- **Training as an enabler, not yet a published promotion gate:** Internal academies (Capital One Tech College/MLETP, Citi's planned programme) build capability, but firms do

not publicly state that course completion is a formal promotion requirement. Treat any such linkage as **(Inferred from public material)**.

- **Tooling access as a capability marker:** Receiving the developer-tailored assistant (Goldman) or research GPT (Morgan Stanley) is role-scoped — access itself reflects assessed need/trust. **(Inferred from public material.)**

(f) How they handle safety, governance, security, and model risk

Control area	Regulated practice (public)	Why it differs from pure tech
Model risk management	SR 11-7 (Fed/OCC) applied to AI/ML/GenAI; three lines of defense; independent validation; model inventory & tiering	Pure tech rarely has mandated independent validation or supervisory exams
Responsible-AI governance	HSBC AI Review Councils; DBS PURE framework; published responsible-AI principles	Formal councils with veto power over deployment
Secure LLM use	Internally hosted/approved models (Goldman); gated multiplexed gateway (JPMorgan LLM Suite); restrictions on public chatbots	Data-leakage and confidentiality controls are mandatory, audited
Human-in-the-loop	DBS "always a human in the loop"; HSBC "human judgement, decision-making and accountability at the core"; MS advisor review of output	Accountability must rest with a named human
Auditability & explainability	Documentation, monitoring, explainability expectations under SR 11-7; "Easy to explain" in DBS PURE	Regulators can demand reproducible rationale
Vendor / model risk	Multi-model approval lists (Goldman: GPT-4/ Gemini/open-source); third-party model treated as vendor risk	Third-party AI falls under vendor-risk and concentration-risk regimes
Bias / fairness	Responsible/Explainable AI expectations in ML roles (Capital One); fair-lending overlay for consumer models (Inferred for consumer-credit AI)	Consumer-protection law (e.g., ECOA/fair lending) adds legal exposure

Net takeaway for a regulated org: the differentiator is not whether staff can use GenAI, but whether they can use it inside a controlled gateway, document and validate it, keep a human accountable, and clear a governance council. An AI-capability ladder in this sector should therefore weight **governed, auditable, human-supervised delivery** at least as heavily as raw technical skill — which is the opposite emphasis of most pure-tech ladders.

Sources: JPMorgan LLM Suite — CNBC, CIO Dive, JPMorganChase blog; Morgan Stanley AskResearchGPT — press release, CNBC; Goldman Sachs GS AI Assistant — CNBC, Fortune; Capital One MLETP, Tech College; HSBC AI; DBS Responsible AI; Fed SR 11-7 / OCC model risk guidance.

5. Comparison of Level Structures Used in the Market

The market uses everything from 3-level autonomy ladders to 7-level responsibility frameworks, plus non-numbered domain models. The table compares the main structural choices.

Structure	Real frameworks using it	What it is good at	Where it falls short
3 levels	Atlassian Rovo autonomy (conversational → integrated → autonomous)	Simple, fast to communicate, good for tool-autonomy gating	Too coarse for HR; can't separate junior from senior nuance
4 levels	DORA clusters (Low/Medium/High/Elite); Anthropic adoption (explore/pilot/scale/transform); CNCF (Provisional/Operational/Scalable/Optimizing)	Clean for org/team maturity and adoption stages; easy executive narrative	Few steps for a large mixed-seniority workforce; promotion gaps feel large
5 levels	Gartner AI Maturity (Awareness→Transformational); Microsoft Copilot adoption; e-CF (e-1 to e-5); ITIL per-practice	Most common, well-understood, balances detail and simplicity	Still compresses a wide span of individual seniority into one step
6 levels	Synthesized AIOps autonomy (L0-L5: Manual→Bounded autonomous)	Good for action-autonomy and risk gating with an explicit "manual" floor	Optimized for system autonomy, not human career growth
7 levels	SFIA 9 Levels of Responsibility (Follow→Set strategy)	Industry-standard for individual responsibility; rich autonomy/influence/complexity attributes; maps to EQF	Generic to all of IT; not AI-specific without grafting
10 levels	Common in large tech HR ladders (Inferred from public material; specific level definitions are not published)	Fine-grained steps suit large orgs; frequent, motivating promotions; precise pay banding	Many steps risk over-engineering and inflated debate over adjacent levels

Structure	Real frameworks using it	What it is good at	Where it falls short
Role-based competency bands	McKinsey "rewired" domains; Deloitte AI fluency; BCG X / QuantumBlack archetypes	Reflects real role variety; avoids forcing everyone onto one scale	Harder to compare across roles; weaker single promotion signal
Skill matrices / rubrics	NIST AI RMF subcategories; OWASP LLM Top 10; ISO 42001 Annex A controls	Granular, evidence-based, auditable; ideal for scoring specific competencies	Not a narrative; doesn't by itself tell someone "what level am I"
Maturity stages	Gartner, Forrester, Microsoft, DORA	Best for org/program tracking and board reporting	Describes the organization, not the individual
Certification paths	AWS / Google Cloud / IBM tiers; Deloitte/Accenture academies	Objective, externally verifiable, gates hiring	Tests knowledge, not on-the-job application or judgment

Are 10 levels too many, too few, or appropriate?

For a large regulated financial-services org with a wide seniority span (interns and analysts through principal engineers, architects, and a Chief AI Officer), **10 levels are appropriate** — provided they are paired with a rubric. The reasoning:

- **Why not fewer.** A 4- or 5-step ladder forces a junior developer and a staff engineer into adjacent buckets, creating large, demotivating promotion gaps and imprecise pay banding. Maturity models (Gartner 5, DORA 4) describe the organization, not individuals, so they are unsuitable as a personal grade.
- **Why not more.** Beyond ~10, adjacent levels become hard to distinguish, and calibration debates outweigh the benefit.
- **Why a hybrid is best.** A numbered ladder alone invites subjective, hype-driven judgments ("seems good with AI"). A rubric alone gives no career narrative. Combining a **10-level ladder (for HR narrative, promotion, and pay)** with a **per-dimension 0-5 rubric (for objective, evidence-based scoring)** gives both a clear story and a defensible, auditable measurement — exactly what a regulated org needs. The 10 levels can be cross-walked to SFIA's 7 responsibility levels and to 4/5-stage maturity models for external benchmarking and board reporting.

6. Common AI / GenAI Skill Dimensions

These 16 dimensions apply across most roles. Each pairs a plain-language meaning with how it is observed in practice (favoring objective evidence over self-rating).

#	Dimension	What it means	How it is observed
1	AI literacy	Understands what AI is, what it can and cannot do, and its limits	Short assessment; can explain a use case and its risks in plain terms
2	GenAI literacy	Understands generative models, tokens, context, and hallucination behavior	Quiz or interview; recognizes when output is likely unreliable
3	Prompt engineering	Writes clear, structured prompts; iterates to improve output	Sample prompts/outputs; versioned prompt artifacts; peer review
4	AI tool usage	Uses sanctioned AI tools effectively and within policy	In-product telemetry (active usage, acceptance rate); tool logs
5	Job-specific application	Applies AI to real tasks in their own role	Work products; measured task throughput or quality change
6	Critical thinking / validation	Checks AI output for accuracy, bias, and relevance before using it	Review notes; caught-error examples; rejection of bad output
7	Human review / verification	Keeps a human accountable for AI-assisted decisions	Approval records; sign-off trails on AI-influenced work
8	Automation ability	Builds reliable, safe automations and agents	Versioned runbooks/playbooks/agents; blast-radius limits
9	Data & RAG understanding	Grasps grounding, retrieval, data quality, and freshness	RAG configs; can explain grounding source and failure modes
10	Agentic AI understanding	Understands multi-step agents, tool use, and autonomy risk	Designed/operated an agent with appropriate guardrails
11	AI safety & security	Recognizes prompt injection, data leakage, excessive agency (OWASP LLM Top 10)	Threat models; red-team/test results; secure configs
12	Governance & compliance	Works within AI policy, logging, and approval requirements	Adherence evidence; clean audit findings; policy attestations
13	Model-risk awareness	Understands model validation, monitoring, and drift	Participation in validation/monitoring; documented model risk
14	Collaboration / knowledge-sharing	Spreads good AI practice; mentors others	Reusable prompts/templates shared; mentoring; internal talks
15	Business impact	Ties AI use to measurable value (time, quality, cost)	ROI/outcome metrics; before/after measures, not anecdotes

#	Dimension	What it means	How it is observed
16	Leadership & strategy	Sets AI direction, standards, and investment priorities	Owned standards/CoE work; strategy artifacts; portfolio decisions

7. Banking / Regulated-Industry Skill Dimensions

In a regulated financial-services org, the dimensions below sit on top of the common ones. They are weighted more heavily and — critically — must be demonstrated **earlier** in the ladder than in a pure tech company.

#	FSI dimension	What it means	How it is observed
1	Responsible-AI awareness	Applies fairness, transparency, accountability, human oversight (e.g., DBS PURE)	Named-framework adherence; documented responsible-AI checks
2	Data classification / confidentiality	Knows data sensitivity tiers and handles each correctly	Correct classification in practice; clean data-handling reviews
3	Customer-data & PII/ PCI handling	Protects regulated customer data in all AI use	No PII/PCI in prompts/logs; DLP and gateway evidence
4	Model-risk awareness (SR 11-7)	Understands model inventory, materiality tiering, independent validation	Validation records; materiality classification; monitoring logs
5	Prompt-injection awareness	Recognizes and mitigates injection (OWASP LLM #1)	Threat models; tested mitigations; secure prompt handling
6	Third-party AI tool risk	Treats external LLMs under vendor- and concentration-risk regimes	Approved-model-list use; vendor-risk assessments
7	AI audit logging	Ensures AI interactions are logged and retained	Log/trace evidence; retention compliance
8	Explainability / traceability	Can explain how an AI-influenced decision was reached	Explainability artifacts; documentation passing review
9	Human approval for operational actions	Requires sign-off before AI acts on Write/Delete/remediation	Approval audit trails (GitLab Duo / PagerDuty-style gates)
10	Segregation of duties	Separates build, validation, and audit roles (three lines of defense)	Role separation evidence; independent validation by a different party
11	Change-management integration	Routes AI changes through standard change control	Change tickets; approvals tied to AI deployments

#	FSI dimension	What it means	How it is observed
12	Regulatory-compliance awareness	Knows applicable obligations (SR 11-7, EU AI Act literacy, fair lending)	Attestations; compliance training completion
13	Audit-evidence generation	Produces artifacts regulators can inspect	Statements of Applicability, impact assessments, factsheets
14	AI incident reporting	Identifies and escalates AI failures and near-misses	Incident reports filed; escalation path followed
15	Vendor / model risk management	Manages model lifecycle, approval, and concentration risk	Multi-model approval lists; lifecycle and drift monitoring
16	Secure SDLC for AI-assisted code	Reviews and secures AI-generated code (NIST SSDF 800-218A)	Code review, SBOM/AI-BOM, scan/test results
17	Risk-adjusted automation	Sets autonomy in proportion to action risk and blast radius	Tiered gates (Read auto / Write-Delete approval); bounded scope

Why these must appear earlier in a regulated ladder

In a pure tech company, governance and model-risk skills tend to be expected only at senior levels. In banking, the cost of a mistake — a fair-lending violation, a customer-data leak, or an unvalidated model in production — is regulatory and reputational, not just technical. SR 11-7, the EU AI Act's literacy obligation, and three-lines-of-defense expectations mean **every** person touching AI must demonstrate baseline responsible-use, data-handling, and approval discipline from their first level. Capability is gated by governed, auditable, human-supervised delivery — not by raw model-building talent alone. Practically, dimensions 1, 2, 3, 5, 7, and 9 should be required at entry levels; the deeper model-risk and validation dimensions (4, 10, 13, 15) scale with seniority but their awareness starts early.

8. Recommended Evaluation Model and Justification

Recommendation: a hybrid model. Use a **10-level capability ladder** for the HR narrative (career story, promotion, pay banding) and a **16-dimension 0-5 rubric** for objective scoring, with both cross-walked to standard 4/5-stage maturity models for benchmarking and board reporting.

How the two parts work together

- **The ladder (L1-L10)** answers "what level am I and what's next" in plain language — suited to HR conversations, promotion decisions, and compensation.
- **The rubric (16 dimensions, scored 0-5 each)** answers "can this person actually do it, with evidence" — suited to technical assessment and audit. A level on the ladder is supported by a required rubric profile (e.g., minimum scores on safety, governance, and human-review dimensions), so a promotion is backed by evidence rather than impression.

Mapping to other models

Ladder band	Suited for	Maps to maturity (Gartner 5 / DORA 4)	Maps to SFIA 7
L1-L3 (foundational)	HR-suitable; literacy + safe use	Awareness/Active; Low/Medium	Follow / Assist / Apply
L4-L6 (practitioner)	Technical-assessment-suitable	Operational; High	Enable / Ensure-Advise
L7-L8 (senior/lead)	Technical + governance assessment	Systemic; Elite	Initiate-Influence
L9-L10 (principal/exec)	HR + strategy-suitable	Transformational	Set strategy

Why 10 levels for a large mixed-seniority regulated org

- It spans the full population — analysts and non-engineers needing only AI literacy through principal engineers, architects, and a Chief AI Officer — without forcing distinct careers into the same step.
- Frequent, well-defined steps keep promotions motivating and pay banding precise.
- Lower levels (L1-L3) are **HR-suitable** (literacy, safe tool use) and can be assessed lightly; middle and upper levels (L4-L8) are **technical-assessment-suitable** and require evidence and, for governance dimensions, independent review; top levels (L9-L10) are **strategy/leadership-suitable**.

How regulated controls shift the ladder

Governance, model-risk, and responsible-AI dimensions are **front-loaded**: baseline responsible-use, data-handling, human-review, and approval discipline are required from L1, not deferred to senior levels. Run a **governance maturity track in parallel** with the capability track so skill growth never outruns controls. Make safe, policy-compliant, auditable deployment an **explicit senior-level technical competency** — at L7+, "ships safely under SR 11-7 / three-lines-of-defense" matters as much as model-building skill.

How managers avoid evaluating hype vs real capability

This is the central risk, and the public evidence demands caution: 2024 DORA linked AI adoption to reduced delivery stability, and MIT NANDA-cited work found ~95% of GenAI pilots showed no measurable financial impact — failures of workflow and incentives, not model quality. Guard against hype by requiring:

1. **Evidence over enthusiasm.** Score the rubric only against artifacts — telemetry, work products, approval trails, validation records, governance documents — never self-reported tool excitement.
2. **Outcome metrics, not activity.** Reward measured business impact (time saved, quality, defect reduction) using before/after data, not the volume of AI usage.

3. **Validation and human-review dimensions as gates.** A high productivity score cannot offset a low score on critical-thinking/validation, human review, or safety — preventing "fast but unsafe" from reading as senior.
4. **Independent calibration.** For governance and model-risk dimensions, require sign-off from someone outside the candidate's delivery line (three-lines-of-defense), mirroring SR 11-7 independent validation.
5. **Tool-agnostic wording.** Define dimensions around judgment and outcomes, not specific products, so the ladder survives vendor and model churn.

9. Proposed 10-Level AI / GenAI Capability Ladder

This ladder grafts AI/GenAI competencies onto a responsibility-based spine (SFIA-style: autonomy, influence, complexity), as recommended in Section 2. No public firm publishes an AI-to-HR-level mapping, so the level-to-grade alignment is **(Inferred from public material)**; the underlying competencies, evidence types, and controls are drawn from public frameworks (SFIA 9, e-CF, NIST AI RMF, OWASP LLM Top 10 2025, ISO/IEC 42001, SR 11-7, DORA/SPACE).

Reading guide. Levels 1-3 are universal literacy and safe use (mandatory baseline for all staff under the EU AI Act literacy obligation). Levels 4-6 are productive practitioner use. Levels 7-9 are building and engineering. Level 10 is strategy and governance leadership. Regulated controls are embedded early: data-handling and safety appear from L2-L3; approval and rollback gates appear for automation at L7+; full governance ownership at L10.

L1 — No Exposure

Field	Content
Research-based rationale	Maturity models (Gartner, Anthropic) start with an "explore/none" floor; a ladder needs an explicit zero so the org can measure baseline literacy debt against the EU AI Act literacy obligation.
Summary	Has not used GenAI tools for work; no working mental model of what they do or their risks.
Expected behavior	Does not use AI in daily work. May be curious or skeptical. No exposure to sanctioned tools.
Technical skills	None required.
Prompt-engineering skills	None.
AI tool usage	None.
Job-specific application	None yet.

Field	Content
Automation skills	None.
Data/RAG skills	None.
Agentic-AI skills	None.
AI safety & governance skills	None — this is the primary gap and risk.
Banking/regulatory risk awareness	Unaware that pasting data into public tools is a control breach.
Evidence required for HR	None (default starting state).
Practical assessment example	Short literacy quiz returns near-zero.
Role-specific examples	New joiner pre-onboarding; staff in roles with no AI rollout.
Promotion signal	Completes mandatory AI-literacy onboarding module.
Training needed for next level	Org AI-literacy 101: what GenAI is, what the sanctioned tools are, the do-not-paste data rules.
Anti-patterns	Using unsanctioned consumer tools "to try them."
Red flags	Pasting customer or confidential data into public chatbots.

L2 — AI Awareness

Field	Content
Research-based rationale	The EU AI Act makes baseline literacy a compliance requirement, not optional; maturity models treat awareness as the gate before any hands-on use.
Summary	Understands what GenAI can and cannot do, knows the sanctioned tools exist, and knows the data-handling rules before touching a tool.
Expected behavior	Can explain GenAI in plain terms; recognizes hallucination as a real failure mode; knows which tool is approved for which data class.
Technical skills	Conceptual only: prompt/response, model, hallucination, context window.
Prompt-engineering skills	Recognizes a good vs. bad prompt; has not yet built skill.

Field	Content
AI tool usage	Aware of the sanctioned gateway (e.g., internal LLM suite); not yet a regular user.
Job-specific application	Can name 1-2 places AI might help their role.
Automation skills	None.
Data/RAG skills	Understands why grounding matters conceptually.
Agentic-AI skills	None.
AI safety & governance skills	Knows the data-classification rules: what is public/internal/confidential/restricted and that restricted data never goes to a model without approval.
Banking/regulatory risk awareness	Knows hallucinated output cannot be used in client-facing or regulatory contexts unchecked.
Evidence required for HR	Pass mandatory AI-literacy + acceptable-use assessment.
Practical assessment example	Multiple-choice: "Which tool may you use for confidential customer data?" + identify a hallucination risk.
Role-specific examples	Branch ops, compliance analyst, junior dev who has completed onboarding.
Promotion signal	Completes acceptable-use cert; runs first prompts in the sanctioned tool.
Training needed for next level	Hands-on intro to the sanctioned chat tool; safe-prompting basics.
Anti-patterns	"I read about it" without ever opening the approved tool.
Red flags	Believing AI output is authoritative; not knowing the data rules after training.

L3 — Basic AI User

Field	Content
Research-based rationale	Vendor adoption ladders (Microsoft Copilot 5-level) place routine assisted use early; controlled studies (GitHub ~55% faster) show value begins at basic competent use.
Summary	Uses sanctioned GenAI for simple, low-risk daily tasks and reliably applies data-handling and verification rules.
Expected behavior	Drafts, summarizes, and rewrites with AI; always checks output before use; never pastes restricted data.

Field	Content
Technical skills	Operates the sanctioned UI confidently; understands token/context limits in practice.
Prompt-engineering skills	Writes clear single-shot prompts with role and context.
AI tool usage	Daily use of approved chat/assistant for drafting and Q&A.
Job-specific application	Email drafts, meeting summaries, doc rewrites, code explanations.
Automation skills	None — manual, in-tool only.
Data/RAG skills	Uses tool's built-in document upload within approved data classes.
Agentic-AI skills	None.
AI safety & governance skills	Verifies every output before use; redacts/avoids sensitive data; reports odd behavior. Treats AI as a draft, not a source.
Banking/regulatory risk awareness	Knows AI drafts to clients/regulators need human review and sign-off.
Evidence required for HR	Manager attestation of safe routine use; optional foundational vendor cert.
Practical assessment example	Summarize a 3-page policy and flag where the summary could be wrong.
Role-specific examples	Analyst summarizing reports; PM drafting tickets; support agent drafting replies.
Promotion signal	Consistent, safe, daily use; starts iterating prompts to improve results.
Training needed for next level	Structured prompt-engineering: few-shot, decomposition, output formatting.
Anti-patterns	Copy-pasting AI output verbatim into deliverables.
Red flags	Skipping verification; occasional sensitive-data leakage.

L4 — Effective Prompt User

Field	Content
Research-based rationale	Across all sources, prompt/tool literacy is a converged dimension; in-product telemetry (acceptance rate) becomes meaningful here.
Summary	Gets reliable, high-quality results through deliberate prompting technique and knows when AI is the wrong tool.

Field	Content
Expected behavior	Iterates prompts methodically; uses examples, constraints, and structured output; recognizes hallucination patterns and self-corrects.
Technical skills	Comfortable with structured outputs (tables, JSON), system/role prompting in the tool.
Prompt-engineering skills	Few-shot, chain-of-thought, decomposition, format control, prompt iteration.
AI tool usage	Power use of chat tools and in-IDE assistants where applicable.
Job-specific application	Produces near-final drafts; uses AI for analysis scaffolding, code review hints.
Automation skills	Saves and reuses prompt templates; no programmatic automation.
Data/RAG skills	Effectively grounds prompts by pasting/uploading approved context; understands grounding reduces hallucination.
Agentic-AI skills	Uses multi-turn refinement; no autonomous agents.
AI safety & governance skills	Designs prompts that request sources/uncertainty ; spots and discards fabricated citations; maintains data-class discipline.
Banking/regulatory risk awareness	Understands prompt injection exists (OWASP LLM #1) at a user level; cautious with untrusted pasted content.
Evidence required for HR	Prompt portfolio (before/after); telemetry showing high suggestion-acceptance with low rework.
Practical assessment example	Given a messy requirement, produce a structured spec via 3 prompt iterations and explain each change.
Role-specific examples	Dev using AI for boilerplate + tests; analyst building first-pass models; risk officer drafting control narratives.
Promotion signal	Others ask them "how did you get that result?"; reusable prompts emerge.
Training needed for next level	Integrating AI into multi-step workflows; tool chaining; light scripting.
Anti-patterns	Over-prompting trivial tasks; treating prompt tricks as a substitute for domain knowledge.
Red flags	Accepting fabricated citations; ignoring uncertainty signals.

L5 — Workflow AI User

Field	Content
Research-based rationale	DORA/SPACE delivery metrics start moving when AI is woven into real workflows, not one-off chats; this is where measurable productivity appears.
Summary	Embeds AI across a multi-step personal/team workflow and measures the result.
Expected behavior	Chains AI across stages (research → draft → review → format); standardizes prompts for a recurring process; tracks time saved and quality.
Technical skills	Connects tools (IDE assistant + chat + docs); light scripting or no-code glue.
Prompt-engineering skills	Builds reusable prompt libraries and templates for a workflow.
AI tool usage	Multiple AI tools used together for a coherent process.
Job-specific application	End-to-end assist on a recurring deliverable (e.g., PR review + test generation; report pipeline).
Automation skills	No-code/low-code workflow assembly; scheduled prompts; not yet production automation.
Data/RAG skills	Uses tool-provided retrieval over approved knowledge bases; understands chunking/grounding effects.
Agentic-AI skills	Uses single-step assistants/tools; aware of agent concepts.
AI safety & governance skills	Builds human-review checkpoints into the workflow ; documents which steps are AI-assisted; keeps sensitive data out of unapproved hops.
Banking/regulatory risk awareness	Knows AI-assisted workflow steps may be auditable; keeps a record of where AI touched a regulated deliverable.
Evidence required for HR	Documented workflow + before/after metrics (cycle time, defect rate, rework).
Practical assessment example	Show a recurring task before AI vs. after, with measured time saved and a quality check step.
Role-specific examples	Dev with AI-in-loop PR/test workflow; analyst with a standardized AI research-to-report flow.
Promotion signal	Their workflow gets adopted by teammates; measurable team-level gain.
Training needed for next level	Sharing/standardizing AI patterns for others; mentoring; light evaluation methods.
Anti-patterns	Optimizing personal speed while increasing downstream rework (the DORA stability warning).
Red flags	Larger, sloppier batches; unreviewed AI output entering shared artifacts.

L6 — AI Power User

Field	Content
Research-based rationale	SFIA influence dimension: at this level the person shapes how a team works, not just their own output; capability-domain models reward cross-team strength.
Summary	Recognized team/squad AI expert who raises everyone's effective AI use and sets safe local norms.
Expected behavior	Mentors, curates prompt libraries, defines team AI conventions, evaluates new tools, and champions verification discipline.
Technical skills	Deep across the sanctioned toolset; can compare models/tools on real tasks.
Prompt-engineering skills	Designs robust, reusable, injection-resistant prompt patterns for the team.
AI tool usage	Evaluates and onboards tools; sets defaults and guardrails for the team.
Job-specific application	Lifts a whole team's deliverable quality/speed; runs internal show-and-tell.
Automation skills	Builds shared no-code/low-code automations with review gates.
Data/RAG skills	Curates team knowledge bases for retrieval; understands grounding quality trade-offs.
Agentic-AI skills	Pilots assistant/agent features for the team in a controlled way.
AI safety & governance skills	Owns team-level safe-use norms ; ensures verification and data rules are followed; first responder for "is this allowed?" questions; escalates to governance.
Banking/regulatory risk awareness	Knows which use cases need risk/compliance involvement; routes them appropriately.
Evidence required for HR	Adopted team artifacts (prompt library, conventions); measured team-level improvement; mentorship record.
Practical assessment example	Run a 30-minute clinic that measurably improves two colleagues' workflows.
Role-specific examples	Senior dev as squad AI lead; lead analyst standardizing AI use across a desk.
Promotion signal	Becomes the go-to; their patterns spread beyond the immediate team.
Training needed for next level	Programmatic AI integration (APIs, eval harnesses, RAG engineering, MLOps basics).
Anti-patterns	Tool evangelism without measurement; pushing tools that increase churn.

Field	Content
Red flags	Encouraging speed over controls; informal data-handling shortcuts spreading.

L7 — AI Automation Contributor

Field	Content
Research-based rationale	Vendor autonomy ladders (GitLab Duo Read/Write/Delete gates; ServiceNow build→benchmark→monitor) treat the move from assist to acting systems as a controlled threshold — hence approval/rollback gates enter here.
Summary	Builds production AI-powered automations using APIs, with explicit approval and rollback controls.
Expected behavior	Writes code that calls models/tools to perform real work; designs for failure, logging, and reversibility; ships behind review gates.
Technical skills	LLM API integration, structured/function calling, error handling, logging, secrets management.
Prompt-engineering skills	Programmatic prompting, output schemas/validation, eval-driven prompt tuning.
AI tool usage	SDKs and platform APIs; CI integration.
Automation skills	Production automations with human-in-the-loop approval for write/delete actions and a tested rollback path ; idempotency; monitoring.
Data/RAG skills	Builds basic RAG pipelines (ingest, chunk, embed, retrieve) over approved sources.
Agentic-AI skills	Single-purpose tool-using assistants with bounded scope; no open-ended autonomy.
AI safety & governance skills	Implements OWASP LLM Top 10 mitigations (esp. prompt-injection #1), input/output filtering, least-privilege tool access, audit logging; logs every automated action.
Banking/regulatory risk awareness	Knows automations touching regulated processes need model-risk/governance sign-off before production; never auto-acts on customer-impacting steps without a gate.
Evidence required for HR	Shipped automation in production with documented approval gates, rollback, logs, and an eval/benchmark result.
Practical assessment example	Build an automation that drafts-and-routes (not auto-sends) with a rollback and an injection-resistance test.
Role-specific examples	Engineer building an AI triage bot with human approval; data analyst automating a grounded report pipeline.

Field	Content
Promotion signal	Automations run reliably in production and pass control review.
Training needed for next level	System/solution design; retrieval architecture; eval frameworks; trade-off decisions across teams.
Anti-patterns	Auto-executing write/delete actions without approval; "demo-grade" automation in production.
Red flags	No rollback, no logging, broad tool permissions, unmitigated prompt-injection surface.

L8 — AI Solution Designer

Field	Content
Research-based rationale	SFIA complexity/influence rises to architecting solutions; capability-domain models (McKinsey "rewired") reward end-to-end solution ownership across domains.
Summary	Designs end-to-end AI solutions for a business problem, choosing the right pattern, model, and controls, and proving value with evaluation.
Expected behavior	Selects build/buy, RAG vs. fine-tune vs. prompt, defines evals and SLAs, designs the control surface, and justifies cost/latency/risk trade-offs.
Technical skills	Architecture across models, retrieval, orchestration, evaluation, observability, cost/latency engineering.
Prompt-engineering skills	System-level prompt and context strategy; eval-grounded, not ad hoc.
AI tool usage	Platform-level decisions; sets standards others build on.
Automation skills	Defines the approval/rollback and monitoring patterns that L7 implements.
Data/RAG skills	Production RAG architecture: data quality, freshness, retrieval evaluation, grounding guarantees, ground-truth datasets.
Agentic-AI skills	Designs bounded multi-tool agent solutions with guardrails and escalation paths.
AI safety & governance skills	Builds NIST AI RMF (Govern/Map/Measure/Manage) into the design; produces Responsible-AI assessment, model factsheet, and evaluation evidence as deliverables.
Banking/regulatory risk awareness	Designs to pass SR 11-7 model-risk validation : documentation, independent-validation hooks, monitoring, fallback; engages the AI review council early.
Evidence required for HR	A delivered solution with architecture doc, eval/benchmark results, Responsible-AI assessment, and passed model-risk review.

Field	Content
Practical assessment example	Produce a design for a regulated use case incl. pattern choice, eval plan, controls, and how it clears SR 11-7.
Role-specific examples	Staff engineer/architect designing a grounded advisory assistant; ML lead designing a monitored scoring solution.
Promotion signal	Designs are reused as reference architectures; solutions clear governance the first time.
Training needed for next level	Platform/agent-framework engineering; multi-agent orchestration; reusable enablement at scale.
Anti-patterns	Choosing fine-tuning/agents for prestige over fit; designing without an eval or control plan.
Red flags	No measurement strategy; controls bolted on after design; ignoring validation requirements.

L9 — AI Agent / Platform Builder

Field	Content
Research-based rationale	CNCF platform-engineering maturity and AIOps tiering treat reusable platforms and trusted autonomy as the most advanced engineering capability; this is the highest individual-contributor build level.
Summary	Builds the agentic frameworks and shared AI platforms that many teams build on, with safety and governance designed in.
Expected behavior	Engineers reusable agent/orchestration platforms, guardrail layers, eval harnesses, and golden datasets used org-wide.
Technical skills	Multi-agent orchestration, tool/permission frameworks, platform reliability, scalable RAG/vector infra, MLOps/LLMOps at scale.
Prompt-engineering skills	Builds prompt/guardrail systems and injection-defense layers as platform features.
AI tool usage	Provides the internal platform/SDK that L4-L8 consume.
Automation skills	Builds the org-wide approval, rollback, kill-switch, and audit framework that gates all automated actions by risk tier.
Data/RAG skills	Enterprise retrieval platform: governed data access, lineage, evaluation datasets, freshness/quality SLAs.
Agentic-AI skills	Production multi-agent systems with bounded autonomy, escalation, observability, and tiered action permissions (Read auto / Write+Delete gated).
AI safety & governance skills	Implements ISO/IEC 42001-aligned controls as platform capabilities; builds the model inventory, factsheet generation, and control-evidence telemetry.

Field	Content
Banking/regulatory risk awareness	Builds the sanctioned-gateway and three-lines-of-defense hooks; ensures every consuming team inherits compliant controls by default.
Evidence required for HR	A platform/agent framework adopted by multiple teams, with documented guardrails, audit/telemetry, and governance sign-off.
Practical assessment example	Demonstrate a multi-agent platform with tiered action gating, kill-switch, audit trail, and an injection-defense eval.
Role-specific examples	Principal engineer owning the internal AI platform; agent-framework lead.
Promotion signal	The platform becomes the default substrate; controls scale across the org.
Training needed for next level	Enterprise strategy, policy, regulatory engagement, portfolio risk, executive influence.
Anti-patterns	Autonomy without kill-switch; platform that lets teams bypass controls.
Red flags	Unbounded agent permissions; no audit trail; no model inventory.

L10 — AI Strategy / Governance Leader

Field	Content
Research-based rationale	NIST AI RMF "Govern" and bank practice (HSBC AI Review Councils, sanctioned gateways) treat enterprise AI strategy and model-risk governance as a distinct leadership function above any build role.
Summary	Sets enterprise AI strategy and owns the governance, risk, and policy framework that lets the org scale AI safely.
Expected behavior	Defines AI strategy and investment; chairs/advises the AI review council; owns the governance maturity track; balances innovation against regulatory risk.
Technical skills	Broad technical literacy sufficient to challenge designs and validators; not hands-on build.
Prompt-engineering skills	N/A at task level; sets standards.
AI tool usage	Defines the sanctioned-tool policy and procurement standards.
Automation skills	Owns the risk-tier policy that determines what may ever be automated.
Data/RAG skills	Owns enterprise data-governance and AI-data policy.
Agentic-AI skills	Sets autonomy-trust policy and the conditions under which agents may act.

Field	Content
AI safety & governance skills	Owns the full governance framework: NIST AI RMF program, ISO/IEC 42001 management system, Responsible-AI policy, AI-literacy compliance (EU AI Act), and incident response.
Banking/regulatory risk awareness	Owns SR 11-7 alignment, three-lines-of-defense, regulator engagement, council sign-off, and model inventory at enterprise scale.
Evidence required for HR	Approved enterprise AI strategy and governance framework; audit/regulator outcomes; portfolio risk posture; council leadership record.
Practical assessment example	Present an enterprise AI strategy with a parallel governance maturity roadmap and how it satisfies regulators and SR 11-7.
Role-specific examples	Head of AI / Chief AI Officer; AI risk & governance director; CTO/CIO AI portfolio owner.
Promotion signal	Strategy is adopted org-wide; AI scales without control breaches or regulatory findings.
Training needed for next level	Terminal level — continued growth is breadth of mandate and board/regulator influence.
Anti-patterns	Strategy that lets capability outrun controls; governance as paperwork rather than enforcement.
Red flags	No model inventory, no incident plan, capability scaling ahead of governance maturity.

10. Mapping of 10 Levels to Common 4/5/6-Level Models

The 10-level ladder gives fine promotion granularity while collapsing cleanly onto the shorter models the market actually uses (Section 5). The mappings below let HR, executives, and external benchmarking each read the ladder in their preferred frame. All mappings are **(Inferred from public material)** — they align our levels to the shape of public frameworks, not to any published company ladder.

Our Level	4-Level (Aware/ Adopt/ Scale/ Lead)	5-Level Gartner-style maturity	6-Level competency band	SFIA responsibility level	Low/ Med/ High band
L1 No Exposure	Aware	1 — Awareness	Band 0 — None	(below SFIA 1)	Low

Our Level	4-Level (Aware/ Adopt/ Scale/ Lead)	5-Level Gartner- style maturity	6-Level competency band	SFIA responsibility level	Low/ Med/ High band
L2 AI Awareness	Aware	1 — Awareness	Band 1 — Foundational	SFIA 1 — Follow	Low
L3 Basic AI User	Adopt	2 — Active (experimentation)	Band 2 — Basic	SFIA 2 — Assist	Low
L4 Effective Prompt User	Adopt	2 — Active	Band 3 — Proficient	SFIA 3 — Apply	Medium
L5 Workflow AI User	Adopt → Scale	3 — Operational	Band 3 — Proficient	SFIA 3 — Apply	Medium
L6 AI Power User	Scale	3 — Operational	Band 4 — Advanced	SFIA 4 — Enable	Medium
L7 AI Automation Contributor	Scale	4 — Systematic (managed)	Band 4 — Advanced	SFIA 4-5 — Enable/Ensure	High
L8 AI Solution Designer	Scale → Lead	4 — Systematic	Band 5 — Expert	SFIA 5 — Ensure, advise	High
L9 AI Agent/ Platform Builder	Lead	5 — Transformational	Band 6 — Authority	SFIA 6 — Initiate, influence	High
L10 AI Strategy/ Governance Leader	Lead	5 — Transformational	Band 6 — Authority	SFIA 7 — Set strategy, inspire	High

How to read it. - **4-level (Aware/Adopt/Scale/Lead)** — best for executive narrative and adoption reporting (mirrors Anthropic explore/pilot/scale/transform and DORA clusters). - **5-level Gartner-style** — best for organizational/portfolio maturity dashboards. - **6-level competency band** — best for HR pay/grade banding where six bands already exist. - **SFIA level** — best for grafting onto an existing responsibility framework and for external comparability. - **Low/Med/High** — fastest screening band: Low = literacy/safe use (L1-L3), Medium = productive practitioner (L4-L6), High = builder/leader (L7-L10).

Governance track runs in parallel (synthesized recommendation). Capability level should never exceed the org's governance maturity for the same use case. A practical rule: any individual operating at L7+ must work within controls owned at L9-L10, so individual skill growth never outruns the control environment (Section 2 recommendation).

11. Mapping to Job Families and Seniority

This maps seniority archetypes to the ladder for the 10 teams, giving a **floor** (mandatory minimum to operate in role) and a **target** (expected steady-state). Floors enforce the baseline: under the EU AI Act literacy obligation and the org's data-handling rules, **every role has a hard floor of L2 (AI Awareness)**; any role using AI in delivery has a floor of **L3 (safe routine use with verification)**. Targets are **(Inferred from public material)** — calibrated to SFIA responsibility levels, not to any published company ladder.

Seniority floor + target (general spine).

Seniority	Floor	Target	Notes
Junior	L3	L4	Must be safe-and-verified before unsupervised AI use.
Mid	L4	L5-L6	Expected to embed AI in workflows and measure it.
Senior	L5	L6-L7	Expected to lift the team and/or ship gated automations.
Lead / Architect	L6	L8-L9	Owns solution design and reference patterns.
Manager (people)	L4	L6	Must understand AI well enough to coach, review evidence, and enforce controls; need not build.
Expert / Principal (IC)	L7	L9-L10	Deepest build authority; platform and strategy influence.

Team-by-team expected level (floor → target). Floors below the general spine are not permitted; where a team's risk profile demands more, the floor is raised (noted).

Team	Junior	Mid	Senior	Lead/ Architect	Manager	Expert/ Principal
1. Software Engineering	L3 → L4	L4 → L6	L5 → L7	L7 → L9	L4 → L6	L8 → L10
2. Data Science / ML	L4 → L5	L5 → L7	L7 → L8	L8 → L9	L5 → L7	L9 → L10
3. Data Engineering	L3 → L4	L4 → L6	L6 → L7	L7 → L8	L4 → L6	L8 → L9
4. Platform / DevOps / SRE	L3 → L4	L4 → L6	L6 → L7	L7 → L9	L4 → L6	L8 → L10
5. Product Management	L3 → L4	L4 → L5	L5 → L6	L6 → L7	L4 → L6	L7 → L8
6. QA / Test Engineering	L3 → L4	L4 → L5	L5 → L7	L6 → L8	L4 → L5	L7 → L8
7. Risk / Model Risk / Compliance	L3 → L4	L4 → L5	L5 → L7	L7 → L9	L4 → L6	L8 → L10

Team	Junior	Mid	Senior	Lead/ Architect	Manager	Expert/ Principal
8. Security / InfoSec	L3 → L4	L4 → L6	L6 → L7	L7 → L9	L4 → L6	L8 → L10
9. Business / Operations Analysts	L3 → L4	L4 → L5	L5 → L6	L6 → L7	L4 → L5	L7 → L8
10. Design / UX	L3 → L4	L4 → L5	L5 → L6	L6 → L7	L4 → L5	L6 → L7

Minimums and rules. - **Universal floor: L2** for every employee (literacy + acceptable use), regardless of role or AI usage. - **Delivery floor: L3** for anyone using AI in their work product (safe routine use + verification + data-class discipline). - **Higher floors where risk concentrates:** Data Science/ML starts at L4 (they build models that fall under model risk); Risk/Compliance and Security seniors must reach L7 to credibly review and challenge AI systems they govern. - **Automation gate:** No one operates above L6 (i.e., ships production automations, L7+) without working inside L9-L10-owned controls (approval, rollback, audit). Capability never outruns governance. - **Managers:** floor L4 so they can read AI evidence and enforce controls; they are not required to build (no L7+ requirement) unless they hold a dual IC/technical mandate. - **Targets are aspirational steady-state**, not promotion guarantees; promotion still requires the evidence specified per level in Section 9.

12. Team-Specific Evaluation Guidance

12.x DevOps / CI-CD

This subsection defines what AI capability looks like for engineers who build and operate continuous integration / continuous delivery (CI-CD) pipelines, deployment automation, and release tooling in a regulated banking-style environment. The emphasis is on safe, auditable, and measurable use of GenAI — never on speed alone. In a regulated context, an AI-generated pipeline change is still a production change: it must pass the same review, approval, segregation-of-duties (SoD), and rollback controls as any human-written change.

Capability bands at a glance

Band	Ladder range	What it looks like in DevOps / CI-CD	Typical AI tasks performed
LOW	L1-L3	Uses AI for isolated, low-risk authoring with full human verification. Never pastes secrets, prod hostnames, or customer data into a tool. Output is reviewed before it touches a repo.	Drafting a Jenkinsfile stage or YAML snippet; explaining a failing log line; generating boilerplate deployment scripts; first-draft release notes from a commit list.

Band	Ladder range	What it looks like in DevOps / CI-CD	Typical AI tasks performed
MEDIUM	L4-L6	Gets reliable results through deliberate prompting and embeds AI across multi-step pipeline work. Sets safe norms for the team and measures the gains. AI assists diagnosis and analysis, humans still own the merge and the deploy decision.	Structured pipeline failure diagnosis; change-risk summaries for CAB; DORA metric analysis and narrative; rollback option analysis; templating reusable pipeline components with prompts.
HIGH	L7-L10	Builds production-grade AI-assisted automation and platforms with approval gates, guardrails, and rollback baked in. Owns or shapes governance for how AI is used in the delivery toolchain.	AI-assisted automations behind approval/rollback gates; policy-as-code generation validated against control catalog; agent/platform tooling for pipeline self-healing with guardrails; enterprise AI-in-SDLC strategy and regulatory posture.

Examples mapped to ladder levels

Level	Concrete DevOps / CI-CD example	Required safety / data control
L1	Has never used GenAI for pipeline work; unaware that pasting a <code>Jenkinsfile</code> with embedded credentials is a data-leak risk.	N/A — target for uplift.
L2	Can explain what may and may not be sent to an approved AI tool (no secrets, no prod IPs, no customer data, no proprietary control logic).	Knows the data-classification and approved-tool list before typing a prompt.
L3	Generates a YAML lint fix or a simple shell deploy step, reads it line by line, and tests it in a sandbox before committing.	Verifies output; runs in non-prod; redacts inputs.
L4	Diagnoses an intermittent pipeline failure by giving the AI a sanitized log + pipeline context and iterating prompts to isolate root cause.	Logs scrubbed of hostnames, tokens, account IDs.
L5	Embeds AI across a release workflow: generates release notes from sanitized commit history, drafts a change-risk summary, and tracks cycle-time saved.	Each AI output passes existing PR review and CAB approval; gains measured.
L6	Acts as team AI lead: publishes prompt templates for Jenkinsfile/YAML gen and rollback analysis, sets the "no secrets in prompts" norm, coaches peers.	Owns team-level safe-use norms; audits team usage.
L7	Builds an AI-assisted automation (e.g., generates a rollback plan or PR) that only executes behind manual approval and an automated rollback gate.	Approval gate + automated rollback + audit log + SoD enforced.

Level	Concrete DevOps / CI-CD example	Required safety / data control
L8	Architects an end-to-end AI solution (e.g., change-risk scoring feeding the deployment gate) that passes model-risk validation.	Documented model-risk validation; human override; monitoring.
L9	Builds a reusable, guarded agent/platform for pipeline self-healing or policy-as-code generation used across multiple teams.	Org-wide guardrails, central logging, versioned policy, kill switch.
L10	Owns enterprise strategy for AI in the delivery toolchain and the associated regulatory/governance posture.	Enterprise AI governance, regulator-facing controls, risk ownership.

Capability-to-task coverage

AI task	LOW (L1-L3)	MEDIUM (L4-L6)	HIGH (L7-L10)
Jenkinsfile / YAML generation	Drafts single stages, verifies manually	Generates reusable, parameterized templates	Auto-templated via guarded tooling
Pipeline diagnosis	Explains a log line	Structured root-cause from sanitized logs	Automated triage with human gate
Deployment scripts	Boilerplate, sandbox-tested	Multi-environment, reviewed	Generated behind approval + rollback
Release notes	First draft from commits	Polished, audience-tuned, repeatable	Automated in release pipeline
Change-risk analysis	Summarizes a single change	CAB-ready risk narrative	Risk scoring feeding deploy gate
DORA analysis	Reads the dashboard	Analyzes trends + narrative	Designs/automates the measurement
Rollback recommendation	Suggests an option to verify	Compares options with trade-offs	Generates validated rollback plan behind gate
CI/CD automation	N/A (consumes only)	Prototypes helper scripts	Production automation with guardrails
Secure use of AI code	Reviews every line	Sets team review norms	Enforces org-wide validation policy
Policy-as-code	Reads existing policy	Drafts/edits policy with review	Generates validated policy at platform scale

Evidence HR can verify

HR does not need to judge code quality. HR verifies that the evidence exists, is dated, and shows the right controls were applied.

Evidence type	What to look for	Confirms
Merged PRs / merge requests	AI-assisted change with reviewer approval recorded; SoD respected (author ≠ approver)	L3+ safe authoring
Prompt templates / runbooks	Shared, version-controlled prompt assets authored by the engineer	L6 norm-setting
Pipeline / CAB records	Change-risk summaries, release notes, rollback plans attributed to AI-assisted work, with approval trail	L5-L7 workflow use
DORA dashboards / reports	Before/after metrics on deploy frequency, lead time, change-fail rate, MTTR with the engineer's analysis	L5+ measured gains
Automation config	Approval gates, rollback gates, audit logging present in any AI-touched automation	L7+ guarded automation
Model-risk / governance docs	Validation sign-off, kill switch, monitoring for AI solutions/platforms	L8-L10
Tool-usage / data-handling attestation	No secrets, prod identifiers, or customer data in prompts; approved tools only	All levels — baseline control

Practical test examples

Test 1 — Pipeline diagnosis and safe authoring (targets L4) Give the engineer a failing pipeline run with a realistic but pre-sanitized log and the relevant `Jenkinsfile` /YAML. Ask them to use the approved AI tool to identify the root cause and propose a fix. Pass criteria: correctly identifies that the inputs were already sanitized and confirms no further secrets are exposed; uses deliberate, iterative prompting; produces a correct fix; states that the fix must go through PR review and run in non-prod first. Fail if they paste raw credentials/hostnames or treat AI output as merge-ready without verification.

Test 2 — Guarded rollback automation (targets L7) Provide a scenario: a deployment is degrading a service. Ask the engineer to design an AI-assisted rollback recommendation/automation. Pass criteria: AI proposes the rollback plan, but execution sits behind a manual approval gate, an automated rollback/health gate, full audit logging, and enforced SoD; human override is explicit. Fail if AI is allowed to act on production autonomously or without an audit trail.

Recommended target levels

Population	Target after 4 months	Target after 12 months
All DevOps / CI-CD engineers (baseline)	L3 — safe, verified routine use; zero data-handling incidents	L4-L5 — reliable prompting embedded in release workflows with measured gains
Senior engineers / leads	L4-L5	L6-L7 — team norm-setting and guarded production automation
Platform / tooling specialists	L5	L7-L8 — guarded automation and validated AI solutions

Population	Target after 4 months	Target after 12 months
DevOps / platform manager or principal	L5-L6	L8+ — solution design and contribution to AI-in-SDLC governance

Note: progression past L7 requires demonstrated approval-gate, rollback, and audit discipline, not just technical skill. In a regulated setting, the control behavior is the gating criterion, not the cleverness of the automation.

(Inferred from public material): Ladder definitions and target-level pacing are synthesized from publicly available DevOps/DORA practice (deployment frequency, lead time, change-failure rate, MTTR) and common regulated-industry change-management controls (segregation of duties, CAB approval, audit trails, model-risk validation). No internal or proprietary company HR ladder was used.

12.x SRE / Operations

AI in Site Reliability Engineering touches production systems, customer-facing availability, and sensitive telemetry. In a regulated financial-services context, the bar is higher than in most teams: an AI suggestion that triggers an unsafe remediation can cause an outage or a control breach. Capability here is judged less by clever prompting and more by **disciplined human-in-the-loop control, blast-radius awareness, and data hygiene with logs and metrics**.

What capability looks like

Band	Behavior in practice	Typical ladder level
LOW	Pastes raw alerts or log lines into a GenAI tool to "ask what's wrong," with no awareness that logs may contain PII, account numbers, secrets, or internal hostnames. Accepts RCA guesses without verifying against real telemetry. No idea which tools are approved. Uses AI output to act on production directly.	L0-L2
MEDIUM	Uses approved AI assistants to summarize incidents, cluster alerts, and draft postmortems, always verifying against source dashboards before relying on output. Scrubs or uses sanitized log samples. Uses AI to propose RCA hypotheses and runbook matches, then confirms them manually. Treats every AI remediation suggestion as a proposal requiring human approval.	L3-L5
HIGH	Builds and operates AI-assisted operational workflows with approval and rollback gates: auto-summarized incident timelines, burn-rate analysis, capacity forecasts, and safe-remediation suggestions that route through change control. Sets safe norms for the on-call team, defines what data may enter prompts, and lifts others. At the top end, architects guardrailed automation that passes model-risk and change-management validation.	L6-L10

Examples mapped to ladder levels

Capability area	L3-L4 (Basic / Effective)	L5-L6 (Workflow / Power)	L7-L9 (Automation / Platform)
Incident & alert summarization	Asks AI to summarize a sanitized alert thread, checks against the alert source	Standardizes a prompt template the whole on-call rotation uses; measures triage time saved	Pipeline auto-drafts incident timelines from event streams with redaction at ingest
Log/metric analysis	Pastes a scrubbed log snippet to spot patterns, verifies in the logging platform	Uses AI to correlate metric anomalies across services, validates against dashboards	Builds an analysis assistant wired to read-only telemetry with access controls
RCA suggestions	Asks for candidate root causes, confirms each manually	Runs structured RCA prompting and ranks hypotheses by evidence	Agent proposes ranked RCA with linked evidence; humans confirm before any action
Runbook recommendation	Asks "which runbook fits this symptom," opens and reads it	Curates prompt + runbook index so matches are consistent	Retrieval system surfaces the approved runbook, never executes it autonomously
Postmortem drafts	Drafts a blameless postmortem from notes, edits for accuracy	Templates postmortems and tracks action-item quality	Auto-assembles draft from incident data for human authoring and sign-off
SLO burn-rate	Asks AI to interpret a burn-rate figure	Builds repeatable burn-rate narrative for stakeholders	Automated burn-rate alerting with AI-generated context, human-tuned thresholds
Capacity prediction	Sanity-checks a forecast against history	Uses AI to model demand scenarios, validates assumptions	Productionized capacity forecast with model-risk validation and monitoring
Safe remediation	Treats AI fixes as suggestions only; never auto-applies	Defines which remediations are AI-eligible and which are never	Builds remediation automation with approval gates, rollback, and audit logging
Human-in-the-loop IR	Always keeps a human decision-maker in the loop	Codifies HITL checkpoints into the team's IR process	Designs IR platform where AI assists but humans authorize every change

Evidence HR can verify

Evidence type	What to look for
Incident records	Postmortems and incident tickets where AI assistance is disclosed, with human verification noted
Prompt templates / runbooks	Shared, version-controlled prompt templates and runbook indexes the team actually uses
Change-management trail	Approval and rollback records showing AI-suggested remediations went through change control, not direct production edits
Data-handling proof	Evidence of log/metric sanitization or use of only approved, access-controlled tools (no raw PII/secrets in prompts)
Measurable gains	Before/after metrics: triage time, mean time to summary, postmortem turnaround, forecast accuracy
Peer enablement (L6+)	Onboarding docs, brown-bags, or norms the person authored for the on-call team
Production artifacts (L7+)	Deployed automations with audit logs, guardrails, and model-risk/validation sign-off

Practical test examples

Test 1 — Safe incident triage (targets L3-L5). Give the engineer a realistic but synthetic alert storm plus sample logs that deliberately contain a fake account number and an internal hostname. Ask them to use an approved AI tool to summarize the incident and propose likely root causes. - Pass signals: redacts or refuses to paste the sensitive fields, uses only an approved tool, treats RCA output as hypotheses, verifies against the provided dashboard, and never proposes acting on production without approval. - Fail signals: pastes raw sensitive data, accepts the AI's RCA as fact, or suggests an immediate production change.

Test 2 — Safe remediation design (targets L6-L8). Present a recurring incident and ask the engineer to design an AI-assisted remediation. Evaluate whether the design includes: an approval gate, a defined rollback, an explicit blast-radius limit, audit logging, a list of remediations that are never AI-eligible, and how it would clear change management and model-risk review.

Embedded regulated safety and data controls

- **No sensitive data in prompts:** logs/metrics must be sanitized or accessed via approved, access-controlled tooling; never paste account numbers, secrets, PII, or customer identifiers.
- **Human authorizes every production change:** AI may suggest, summarize, and analyze; a human approves and executes through change management. No autonomous remediation without explicit, gated approval.
- **Approval + rollback + audit by default:** any AI-touched automation requires approval gates, a tested rollback path, and immutable audit logging.

- **Model-risk validation (L8+):** AI solutions affecting availability or capacity decisions must pass the org's model-risk and change-management validation before production use.
- **Approved tools only:** use sanctioned GenAI services with appropriate data-residency and retention settings; shadow tools are not permitted for operational data.

Recommended target levels

Population	After 4 months	After 12 months
All SRE/Ops engineers	L3 — safe, verified daily use on low-risk tasks with correct data handling	L5 — AI embedded across triage, postmortem, and analysis workflows with measured gains
Senior SREs / on-call leads	L4-L5	L6 — team AI expert setting safe norms and enabling others
Tooling/platform SREs	L5	L7-L8 — production automations with approval/rollback gates passing model-risk validation

Targets assume access to approved tooling and time allocated for enablement. Progression past L5 should be gated on demonstrated safety discipline, not just throughput gains.

12.x Platform / Kubernetes

This guidance helps non-specialists evaluate how well a Platform / Kubernetes engineer uses GenAI to do their job safely and effectively. Kubernetes work touches production stability, security boundaries, and cost — so AI use here is judged not just on speed, but on whether the engineer keeps a human in the loop for anything that changes a live cluster. In a regulated environment, treat every cluster as production-adjacent.

What LOW / MEDIUM / HIGH capability look like

Band	What it looks like in practice	Typical ladder level
LOW	Uses AI to draft a YAML manifest or explain a <code>kubectl</code> error, but copies output without checking namespaces, image tags, or resource limits. No awareness of what cluster data is safe to paste into a tool. Cannot tell when AI advice is wrong.	L1-L3
MEDIUM	Reliably prompts AI for manifests, Helm values, and diagnosis with cluster context redacted. Verifies suggestions against real cluster state and policy before applying. Uses AI across a workflow (e.g. diagnose → propose fix → write the PR), and can roughly state time saved.	L4-L5
HIGH	Sets safe AI norms for the platform team, builds approved automations (self-service assistants, policy checks, capacity reports) with approval and rollback gates, and designs reusable, guardrailed tooling that passes security and model-risk review.	L6-L9

Capability examples mapped to ladder levels

Platform task	LOW (L1-L3)	MEDIUM (L4-L5)	HIGH (L6-L9)
Manifest generation	Pastes a generated Deployment as-is	Generates manifest, then fixes limits, probes, securityContext, and validates with <code>kubectl --dry-run / linter</code>	Maintains AI-assisted manifest templates with org defaults baked in
Helm assistance	Asks AI to "write a Helm chart," ships it untested	Uses AI to refactor <code>values.yaml</code> and templates, verifies with <code>helm template + diff</code>	Builds shared chart library and AI prompts the team reuses
Pod/node diagnosis	Pastes raw logs (may contain secrets) to get an explanation	Redacts logs, uses AI to narrow root cause, confirms against metrics/events	Codifies common diagnoses into an AI runbook / assistant
Resource-limit & autoscaling recommendation	Accepts AI's requests/limits guess	Feeds real usage data, sanity-checks HPA/VPA suggestions against headroom	Automates right-sizing proposals as reviewed PRs, never auto-applied
Cluster capacity	Asks AI generically "is my cluster big enough"	Gives AI real (sanitized) utilization data for a capacity narrative	Builds repeatable AI capacity-reporting with human sign-off
Service-mesh troubleshooting	Copies mesh config blindly	Uses AI to interpret mTLS/routing errors, validates in non-prod first	Encodes mesh troubleshooting patterns into team tooling
Self-service assistant	N/A	Pilots an internal Q&A helper for app teams	Builds and governs a guardrailed self-service platform assistant
Cost optimization	Repeats generic "use spot instances" advice	Uses AI on real spend data to find concrete savings, validates impact	Owns AI-driven cost reporting with measured, attributed savings
Policy-as-code	Unaware of OPA/Kyverno or writes unchecked policy	Uses AI to draft/refine policies, tests against real manifests	Designs the AI-assisted policy-as-code pipeline org-wide

Evidence HR can verify

You do not need Kubernetes knowledge to confirm these. Ask for artifacts and look for the markers below.

Evidence	What good looks like
Merged PRs	AI-assisted manifests/Helm changes that passed CI, linting, and peer review — not direct-to-cluster edits
Prompt or chat history	Cluster identifiers, secrets, and customer data are redacted or absent before being sent to AI tools
Change records	Every AI-suggested production change has a ticket, an approver, and a documented rollback step
Before/after metrics	Stated, checkable numbers: incident MTTR, time-to-manifest, % cost reduction, capacity accuracy
Team artifacts (HIGH only)	Shared templates, runbooks, policies, or an assistant that others on the team actually use
Tool approval	Only company-approved AI tools used; no pasting into unsanctioned public chatbots

Practical test examples

Test 1 — Diagnose and fix (MEDIUM signal). Give the engineer a broken Deployment (e.g. a pod in `CrashLoopBackOff` with a bad probe and a missing resource limit) and a sanitized log snippet. Ask them to use AI to diagnose and produce a corrected manifest. - Pass: They redact anything sensitive before prompting, identify the real root cause, fix limits/probes, and validate with a dry-run or lint before proposing — not just paste AI's answer.

Test 2 — Right-size with a gate (HIGH signal). Provide sanitized CPU/memory usage data and ask for an autoscaling and resource-limit recommendation delivered as a reviewable change. - Pass: They produce a justified HPA/requests/limits proposal as a PR with rollback notes and explicitly do not auto-apply to a live cluster, citing the approval gate.

Regulated safety and data controls (always required)

- **No live-cluster auto-changes.** AI may propose; a human approves and applies. Production changes go through change management with a rollback plan.
- **Data minimization.** No secrets, tokens, kubeconfigs, customer data, internal hostnames, or IP ranges in prompts. Redact logs and configs first.
- **Approved tools only.** Use sanctioned enterprise AI tooling with data-handling guarantees; never paste cluster data into unsanctioned public tools.
- **Auditability.** AI-influenced production changes are traceable to a ticket, an approver, and the prompt/output rationale.
- **Policy and security gates.** Generated manifests and policies pass linting, policy-as-code (e.g. OPA/Kyverno), and security review before merge.

Recommended target levels

Horizon	Target	Rationale
After 4 months	L4-L5 for most platform engineers	Reliable, verified AI use embedded in day-to-day workflows (manifests, diagnosis, Helm) with data controls habitual

Horizon	Target	Rationale
After 12 months	L6-L7 , with 1-2 engineers at L8+	Team norms set by power users, plus approved, gated automations (self-service assistant, policy-as-code, cost reporting) built by senior staff

(Inferred from public material: ladder bands and target levels are synthesized recommendations mapped to the provided L1-L10 framework and common Kubernetes practice; they are not drawn from any internal company ladder.)

12.x Observability / Monitoring

This subsection covers engineers and SREs who build and operate monitoring stacks (Prometheus/PromQL, Loki/LogQL, Elasticsearch, Grafana, distributed tracing). GenAI is increasingly used to draft queries, generate dashboards, recommend alert rules, reduce alert noise, correlate signals, and analyze traces. In a regulated financial-services context, the binding constraint is not whether AI can produce a query or a dashboard — it is whether the human operator can validate the output against live signals and avoid blind spots in production alerting.

What LOW / MEDIUM / HIGH capability look like

Band	Ladder	What it looks like in observability work	Risk posture
LOW	L1-L3	Uses AI to draft individual PromQL/LogQL/ES queries and explain unfamiliar metrics. Verifies output by running the query and sanity-checking results. Does not yet trust AI for alert thresholds or production dashboards.	Manual verification on every output; low blast radius
MEDIUM	L4-L6	Reliably prompts AI for golden-signal dashboards, alert-rule sets, and noise-reduction logic. Uses AI to correlate metrics/logs/traces during incidents. Sets team norms for safe AI use in monitoring and reviews others' AI-generated queries.	AI embedded in workflow; human owns thresholds and runbook impact
HIGH	L7-L10	Builds approved automations: AI-assisted anomaly detection, auto-generated dashboards from service definitions, alert-tuning pipelines with rollback. Architects monitoring-as-code solutions that pass model-risk review and embed guardrails org-wide.	Production automation with approval, rollback, and validation gates

Examples mapped to ladder levels

Ladder	Representative observability behavior
L2	Knows not to paste production hostnames, customer identifiers, or raw log lines with PII into a public AI tool; understands sandbox vs. live data rules.
L3	Asks AI to write a PromQL query for p99 latency, runs it, and confirms the result matches the known dashboard value before using it.

Ladder	Representative observability behavior
L4	Uses structured prompts (metric names, label schema, time window, intent) to get correct LogQL filters and Elasticsearch DSL on the first or second try; catches AI-invented metric names.
L5	Builds a repeatable workflow: AI drafts golden-signal dashboard (latency, traffic, errors, saturation) per service, engineer validates panels against real traffic, measures reduction in dashboard build time.
L6	Sets the team's prompt library and review checklist for AI-generated alert rules; coaches others on validating thresholds and avoiding false-negative alerts.
L7	Ships an approved alert-noise-reduction automation (e.g., AI-assisted grouping/deduplication) behind a feature flag with rollback and a human approval gate.
L8	Designs an end-to-end anomaly-detection solution for a service tier that passes model-risk validation, with documented failure modes and fallback to static thresholds.
L9	Builds a reusable, guardrailed agent/platform that generates dashboards and alert rules from service metadata for multiple teams.
L10	Owens the governance standard for AI use across the observability function, including regulatory and audit obligations.

Evidence HR can verify

Claimed level	Verifiable evidence (no specialist knowledge required)
L2-L3	Completion of internal data-handling/AI-policy training; examples of AI-drafted queries with a note on how each was verified.
L4-L5	Saved prompt templates; before/after dashboard build-time or query-iteration counts; peer confirmation that AI outputs were validated against live data.
L6	Team prompt library or review checklist authored by the individual; record of coaching sessions or onboarding others.
L7	Merged pull request for an automation that includes an approval gate and a documented rollback path; change-management ticket reference.
L8-L10	Model-risk/validation sign-off documents; architecture review records; governance policy or standard with the individual named as owner.

Note: HR should verify the existence and authorship of artifacts (PRs, tickets, checklists, sign-offs) and corroborate impact with the technical lead, rather than judging the technical correctness of queries.

Practical test examples

Test 1 — Query generation with verification (targets L3-L4). Give the candidate a sample metric/label schema and ask: "Write a PromQL query for the 95th-percentile request latency of service X over the last 15 minutes, and a LogQL query to find 5xx responses for

the same service. Show how you confirmed each is correct." Pass criteria: correct functions and labels, no invented metric names, and an explicit verification step (ran it, compared to a known value). Strong candidates flag any guessed label and note that thresholds must be confirmed against real data.

Test 2 — Alert-noise reduction with safety reasoning (targets L5-L7). Provide a noisy alert set (e.g., a flapping CPU alert and duplicated downstream alerts) and ask the candidate to use AI to propose a noise-reduction approach. Pass criteria: AI-assisted grouping/dedup or threshold tuning is proposed, but the candidate explicitly preserves false-negative safety (does not suppress alerts that could mask outages), defines a rollback, and routes the change through an approval gate before production. The integrity signal is refusing to silence alerts without validation.

Embedded regulated safety and data controls

Control	Requirement
Data handling	No PII, account/customer identifiers, secrets, or production hostnames pasted into non-approved AI tools; use approved enterprise tooling and sanitized examples only.
Human accountability	A named engineer owns every AI-generated alert threshold, dashboard, and query that reaches production. AI output is a draft, never the final authority.
False-negative protection	Alert-noise reduction must never suppress signals that could mask customer-impacting incidents; changes require validation against historical incidents.
Change gates	Production automations require approval, version control, audit trail, and a tested rollback path.
Model-risk alignment	Anomaly-detection and other AI-driven detection logic must pass model-risk validation with documented failure modes and a static-threshold fallback.

Recommended target levels

Horizon	Target	Rationale
After 4 months	L4 (Effective Prompt User) , with senior staff at L5	Most observability engineers should reliably generate and verify queries and golden-signal dashboards; leads embed AI across incident and dashboard workflows.
After 12 months	L5-L6 , with at least one L7 per team	The function operates AI across multi-step workflows with measured gains; a power user sets norms; at least one engineer ships an approved, rollback-protected automation.

Target levels above are synthesized recommendations for this function, not an existing internal standard. The L1-L10 definitions are the provided ladder reference; mappings to observability tasks are (Inferred from public material) on Prometheus/Grafana/Loki/Elasticsearch usage and standard SRE practice.

12.x Service Desk / IT Support

Service Desk / IT Support handles high volumes of tickets, customer/employee interactions, and access requests. In a regulated financial-services environment, AI use here is powerful but sensitive: agents routinely touch customer PII, account data, and audit-relevant records. Evaluation must reward speed and consistency gains while proving that data-handling rules, human review, and traceability are never bypassed.

Regulated safety and data controls (apply at every level): - Never paste customer PII, account numbers, card data, credentials, or full ticket bodies into non-approved/public GenAI tools. Use only sanctioned, data-governed tools. - AI-drafted customer responses are reviewed by a human before sending; the human owns the final message. - AI ticket classification/routing decisions are auditable and overridable by a person. - Chatbot and automation actions affecting accounts require defined scope limits, logging, and rollback/escalation paths. - Any automation touching customer data passes change-control approval before production.

What LOW / MEDIUM / HIGH capability looks like

Capability band	Ladder range	What it looks like on the Service Desk
LOW	L1-L3	Knows the data rules; uses approved AI to summarize sanitized tickets, draft routine replies, and search the KB, always verifying before acting or sending.
MEDIUM	L4-L6	Reliable prompting for classification/routing and KB recommendations; embeds AI across the ticket lifecycle, measures deflection/handle-time gains, and sets safe norms for the team.
HIGH	L7-L10	Builds approved automations (auto-routing, repetitive-issue resolution, SLA-breach prediction) and L1 chatbots with guardrails, handoff logic, and rollback that pass model-risk validation.

Examples mapped to ladder levels

Level	Service Desk example
L1	Has never used GenAI for support work; unaware of which tools are approved or what data must not be shared.
L2	Can state the data-handling rules (no PII into unapproved tools) before touching any AI tool.
L3	Uses approved AI to summarize a sanitized ticket or draft a routine password-reset reply, then verifies and edits before sending.
L4	Uses deliberate prompts to classify tickets by category/priority and recommend the right KB article reliably, with consistent quality.
L5	Embeds AI across the full ticket flow (summarize to classify to route to draft response) and tracks first-contact resolution and handle-time improvements.

Level	Service Desk example
L6	Acts as the team's AI expert: writes the prompt library and safe-use playbook, trains peers on PII-safe drafting, and audits AI output quality.
L7	Builds an approved auto-routing or repetitive-issue automation (e.g., auto-resolve known-error tickets) with logging, approval, and rollback gates.
L8	Designs an end-to-end SLA-breach-prediction or auto-triage solution that passes model-risk validation and defines its monitoring.
L9	Builds a reusable L1 chatbot/agent platform with org-wide guardrails, customer-data controls, and standardized human-handoff logic.
L10	Owns the support-AI strategy, deflection targets, governance, and regulatory risk posture across the service organization.

Evidence HR can verify

Evidence type	What to ask for
Tooling	Confirmation the person uses only sanctioned/approved AI tools (no PII in public tools).
Work artifacts	Saved prompts, prompt library, or safe-use playbook authored or used by the person.
Metrics	Before/after handle-time, first-contact resolution, deflection rate, or routing-accuracy figures attributable to AI use.
Reviews/sign-off	Change-control approvals, model-risk validation sign-off, and rollback plans for any automation or chatbot they built.
Peer enablement	Training sessions delivered, peers onboarded, or norms documented (for L6+).
Audit trail	Logs showing AI routing/automation decisions are recorded and human-overridable.

Practical test examples

Test 1 — Safe summarize, classify, route (targets L3-L4): Give a realistic ticket containing PII (name, account number). Ask the candidate to summarize, classify priority/category, and recommend a route using an approved tool. Pass: Sanitizes or redacts PII before any tool use (or uses the governed tool correctly), produces an accurate summary and correct classification, and states that the routing decision is reviewable.

Test 2 — Draft a customer response with handoff judgment (targets L4-L6): Provide a frustrated customer complaint about a failed transaction. Ask for an AI-assisted draft reply. Pass: Produces an accurate, on-tone, compliant draft; flags it for human review before sending; correctly identifies when the issue must be escalated to a human (e.g., dispute, suspected fraud) rather than handled by AI/chatbot.

Recommended target levels

Horizon	Target level	Rationale
After 4 months	L3-L4	Most agents safely use approved AI daily for summarization, classification, and drafting, with reliable prompting and verified output.
After 12 months	L5 (team) / L6-L7 (leads)	Teams embed AI across the ticket lifecycle and measure gains; leads set norms and begin building approved automations under model-risk and change-control governance.

(Inferred from public material) Specific deflection and handle-time benchmarks should be set against the organization's own baselines; published industry figures vary widely and should not be treated as committed targets.

12.x Data / DataOps

This guidance covers how to evaluate AI capability for engineers and analysts working on data pipelines, warehouses, quality, and governance. In a regulated financial-services context, data work touches sensitive customer records (PII, account, transaction data), so every AI use must respect data-residency, masking, and least-privilege rules. The bar is not "did AI produce SQL" — it is "did the person produce correct, governed, auditable data outcomes faster while controlling data risk."

What LOW / MEDIUM / HIGH capability look like

Band	Ladder	What it looks like in Data / DataOps	Data risk posture
LOW	L1-L2	Does not use AI, or pastes raw production data/PII into public tools to "ask it to fix my query." Cannot explain why that is unsafe. Output unverified against real schema.	Dangerous if unsupervised — may leak sensitive data.
MEDIUM	L3-L5	Uses approved AI to draft SQL, explain a pipeline failure, or propose data-quality rules; always verifies against the catalog and runs on non-prod first. Embeds AI into recurring workflows (e.g. triage of failed DAGs) and tracks time saved. Never pastes real customer rows.	Safe for routine, low-to-medium-risk tasks with verification.
HIGH	L6-L10	Sets team norms for safe AI data use; builds approved automations (anomaly/freshness alerts, schema-drift detectors) with rollback and human approval; designs validated AI data solutions; owns governance for AI-on-data across the org.	Trusted to design controls others depend on.

Capability examples mapped to ladder levels

Capability	L3-L4 (Basic / Effective)	L5-L6 (Workflow / Power)	L7-L8 (Automation / Solution)	L9-L10 (Platform / Governance)
SQL generation	Drafts a query from a prompt, verifies row counts and joins, uses masked/ synthetic samples only	Templates prompts with schema context; reviews AI SQL for cost and PII exposure before run	Ships reviewed AI-assisted query patterns into pipelines with cost guardrails	Sets org standard for AI-generated SQL review and approved-tool list
Pipeline-failure diagnosis	Asks AI to interpret a stack trace/log, confirms root cause manually	Builds a repeatable triage flow that summarizes failed runs from logs	Automates first-pass diagnosis with human-approved remediation	Defines incident-response AI playbook and audit trail
Data-quality rule gen	Proposes null/ range/uniqueness checks, validates against real distribution	Generates rule sets across tables and measures defect catch rate	Deploys AI-suggested rules behind approval into the DQ framework	Governs DQ-rule lifecycle and false-positive thresholds org-wide
Freshness monitoring	Drafts a freshness check for one table	Standardizes freshness SLAs and alerting with AI assistance	Automates freshness alerting with rollback-safe config	Owens freshness-SLA policy and exception governance
Schema-drift detection	Explains a detected schema change and its impact	Builds drift-watch across critical tables, routes to owners	Automates drift detection with gated migration approval	Sets enterprise schema-change/ contract policy
Lineage explanation	Asks AI to explain upstream/ downstream of a field, verifies in catalog	Produces lineage summaries for impact analysis routinely	Wires lineage-aware automation into change management	Owens lineage-governance and reg-reporting traceability
ETL/ELT troubleshooting	Uses AI to suggest fixes for a broken transform, tests in non-prod	Builds reusable troubleshooting prompts/runbooks	Ships approved auto-remediation with rollback	Defines safe-automation standards for transforms
Anomaly detection	Reviews AI-flagged anomalies, confirms true/ false positive	Tunes anomaly thresholds and tracks precision	Deploys validated anomaly models with human-in-loop	Owens model-risk-validated anomaly platform

Capability	L3-L4 (Basic / Effective)	L5-L6 (Workflow / Power)	L7-L8 (Automation / Solution)	L9-L10 (Platform / Governance)
Catalog assistant	Uses AI to find/describe datasets, verifies metadata	Improves catalog metadata at scale with AI assistance	Automates catalog enrichment with review gates	Governs catalog-AI accuracy and access controls
Sensitive-data handling	Knows what is PII; never feeds it to AI; uses masked data	Enforces masking/synthetic-data norms on the team	Builds masking-by-default into AI data tooling	Owens data-privacy policy for all AI-on-data

Evidence HR can verify

HR does not need to judge SQL quality — they verify that artifacts exist and that controls were followed. Ask for any of the following (with sensitive content redacted):

Evidence type	What to look for	Maps to
Pull requests / merge requests	AI-assisted SQL or pipeline fixes that were reviewed, tested in non-prod, and approved	L3-L5
Triage / runbook docs	A documented AI-assisted diagnosis workflow with measured time saved	L5-L6
Approved tool usage	Use of the sanctioned enterprise AI tool only; no evidence of public-tool data paste	L2+ (gate)
Deployed automations	Anomaly/freshness/drift jobs with approval and rollback gates, plus change tickets	L7-L8
Validation records	Model-risk or governance sign-off on an AI data solution	L8+
Policy / norms artifacts	Team standards, training, or governance docs the person authored	L6, L9-L10
Metrics	Defect catch rate, MTTR on pipeline incidents, freshness-SLA adherence before/after AI	L5+

Practical test examples

Test 1 — Safe SQL generation and verification (targets L3-L5). Give the candidate a masked or synthetic schema and a business question (e.g. "monthly active accounts by segment, last 6 months"). Observe: - Do they use only the approved tool and synthetic/masked data (never real PII)? - Do they provide schema context in the prompt rather than guessing column names? - Do they verify the result — row counts, join fan-out, edge cases — before declaring it correct? - Do they note query cost / partition pruning? Pass at L3 if safe and verified; L4-L5 if they used a reusable, well-structured prompting approach and validated rigorously.

Test 2 — Pipeline-failure diagnosis with controls (targets L5-L7). Provide a redacted failed-job log (e.g. a nightly ELT failure: upstream schema change plus a null-key explosion). Observe: - Can they use AI to summarize the log and propose a ranked root cause, then confirm it manually? - Do they propose a fix tested in non-prod first, with a rollback plan? - At L6-L7: do they turn this into a reusable triage runbook or a gated automation rather than a one-off fix? Pass at L5 for a sound, controlled manual workflow; L7 if they design an approved automation with rollback.

Recommended target levels

Horizon	Target	Rationale
After 4 months	L4 for individual contributors; L5 for senior/lead data engineers	Everyone safely and reliably produces verified AI-assisted SQL, diagnosis, and DQ rules using only approved tools and masked data. Seniors embed AI into recurring workflows with measured gains.
After 12 months	L5-L6 for ICs; L7+ for leads/architects	Most ICs run multi-step AI data workflows and lift teammates; leads ship governed automations (anomaly, freshness, drift) with approval and rollback, and the strongest move toward validated solution design.

Embedded regulated safety / data controls (non-negotiable at every level)

- **No real PII or production customer/transaction data in any AI tool** — use masked or synthetic data only.
- **Approved enterprise AI tooling only** — no public/consumer chatbots for work data.
- **Verify before trust** — AI output is a draft; validate against the live catalog/schema, never run unreviewed AI SQL against production.
- **Non-prod first** — test all AI-suggested transforms/fixes in a non-production environment.
- **Human approval and rollback** — any automation acting on data requires an approval gate, a change ticket, and a rollback path.
- **Least privilege** — AI-assisted access must respect existing role-based data permissions; AI does not bypass entitlements.
- **Auditability** — keep a trail of AI-assisted changes for model-risk and regulatory review.

(Ladder level definitions are the org's stated L1-L10 framework; capability mappings and test designs above are synthesized recommendations, not a description of any specific company's internal practice.)

12.x Security / Governance

This team is the control function for AI adoption in a regulated financial-services environment. Capability here is judged less by personal productivity and more by the ability to let the rest of the organization use AI safely. A strong engineer who ships fast but cannot evidence controls is a LOW rating for this team.

Scope evaluated: AI risk review, secrets protection, prompt-injection defense, AI-code review, OWASP LLM controls, NIST AI RMF and ISO/IEC 42001 awareness, policy-as-code, audit-evidence generation, AI incident response, and vendor/model risk.

What LOW / MEDIUM / HIGH look like

Band	Ladder range	What you see in practice	Regulated control posture
LOW	L1-L3	Uses GenAI for routine drafting and code lookups. Knows not to paste secrets, PII, or production data into public tools. Cannot yet assess AI risk for others or review AI-generated code for injection or data-leak issues.	Follows controls; does not design or enforce them. Needs supervision on anything customer- or production-facing.
MEDIUM	L4-L6	Runs structured AI risk reviews, catches prompt-injection and secrets-exposure patterns in AI-assisted code, sets safe-use norms for a team, and maps work to OWASP LLM Top 10. Aware of NIST AI RMF and ISO/IEC 42001 intent.	Operates controls and lifts peers. Can sign off on low/ medium-risk AI use; escalates high-risk and model-risk decisions.
HIGH	L7-L10	Builds policy-as-code and automated audit-evidence pipelines, designs AI incident response, leads vendor/model risk assessment, and architects guardrailed agent platforms that pass model-risk validation. Owns the AI governance framework.	Defines and validates controls org-wide. Accountable to model-risk, audit, and regulators.

Examples mapped to ladder levels

Level	Representative capability for this team
L2-L3	Knows the data-classification rules and which AI tools are approved for which data tiers; never sends restricted data to unapproved endpoints.
L4	Writes deliberate prompts to scan a diff for hardcoded secrets, injection sinks, and insecure-output handling; verifies findings before acting.
L5	Embeds AI security checks into a multi-step review workflow (pre-commit secret scan, AI-assisted diff review, evidence capture) and measures false-positive/catch rates.
L6	Team AI-security expert: publishes safe-use norms, runs an OWASP LLM Top 10 self-assessment for a product, coaches engineers on prompt-injection defense.
L7	Builds an approved automation (e.g., policy-as-code check or audit-evidence generator) with human approval and rollback gates before it touches a control.
L8	Designs an end-to-end AI security solution (e.g., AI-assisted vendor/model risk intake) that passes formal model-risk validation and documents residual risk.
L9	Builds a reusable, guardrailed agent or review platform used across teams, with logging, access control, and kill-switch.

Level	Representative capability for this team
L10	Owns enterprise AI governance: maps the program to NIST AI RMF and ISO/IEC 42001, sets the risk appetite, and answers to audit and regulators.

Evidence HR can verify

Claimed level	Verifiable artifact (no self-report alone)
L3-L4	Completed approved AI-use and data-handling training; sample AI-assisted security reviews with verification notes.
L5	A documented AI-in-review workflow with before/after metrics (e.g., secrets caught, review time, false-positive rate).
L6	Published team norms or runbook; an OWASP LLM Top 10 assessment they authored; record of coaching or internal sessions delivered.
L7	A merged automation with approval/rollback gates in change-management records; reviewer sign-offs.
L8	Model-risk validation sign-off on a solution they designed; documented residual-risk acceptance.
L9-L10	Platform ownership records, governance framework mapped to NIST AI RMF / ISO 42001, audit or regulator-facing evidence.

Map all referenced standards to public sources: OWASP Top 10 for LLM Applications, NIST AI RMF (AI 100-1), and ISO/IEC 42001 AI management systems. (Inferred from public material: specific internal control mappings will vary by organization and are not assumed here.)

Practical test examples

- 1. Prompt-injection and data-leak review (targets L4-L6).** Hand the candidate a small AI-assisted feature spec or PR that calls an LLM with user-supplied input and returns output into a downstream action. Ask them to identify the prompt-injection path, the insecure-output-handling sink, and any secrets/PII exposure, then propose mitigations. Strong answers cite specific OWASP LLM categories (e.g., LLM01 Prompt Injection, LLM02 Insecure Output Handling, LLM06 Sensitive Information Disclosure) and add a verification step.
- 2. Audit-evidence under a control (targets L7-L8).** Give a scenario: "We approved an AI tool for tier-2 data only. Demonstrate how you would prove compliance to an auditor." Strong answers describe policy-as-code or automated evidence capture (logs of model, data tier, approver, timestamp), a human approval gate, and a rollback/kill-switch, plus how the control maps to a documented framework.

Recommended target levels

Horizon	Target for this team	Rationale
After 4 months	Minimum L4 ; team leads L5-L6	Everyone must safely run AI-assisted security reviews and apply OWASP LLM controls; leads should be setting norms.
After 12 months	Minimum L5 ; senior/lead L7+ , with at least one L8-L10 owner	The team should operate AI security as a measured workflow, with senior members building validated, gated automations and a clear governance owner accountable to model-risk and audit.

(Recommended target levels are a synthesized recommendation, not a researched standard, and should be calibrated to the organization's risk appetite and regulatory obligations.)

12.x QA / Testing

AI is reshaping QA from manual script-writing toward intelligent test generation, risk-based prioritization, and continuous quality signals. In a regulated banking environment, the central tension is speed versus control: AI can accelerate coverage, but generated tests, synthetic data, and quality-gate decisions must remain auditable, reproducible, and free of real customer data. This guidance helps HR and technical leads place QA staff on the L1-L10 ladder using observable evidence, not self-assessment.

What LOW / MEDIUM / HIGH capability looks like

Capability band	Ladder range	What you observe in QA work
LOW	L1-L3	Uses AI occasionally for isolated tasks: drafting a single test case, explaining one failed assertion, or generating sample data for a low-risk feature. Always pastes AI output verbatim or with minimal edits. Understands not to paste real customer/account data into external tools (L2+). No measurement of impact. Treats AI as a search engine.
MEDIUM	L4-L6	Designs prompts that produce reliable, framework-correct tests (unit/integration/e2e) and reusable prompt patterns for the team. Embeds AI in multi-step QA workflows (generate -> review -> refactor -> run) and tracks gains such as coverage uplift or triage-time reduction. Uses AI for regression-risk analysis and defect clustering, then validates findings against real failure history. Sets team norms for safe synthetic-data generation and acts as the go-to AI reviewer.
HIGH	L7-L10	Builds approved, version-controlled test-generation and triage automations with rollback and human gates. Designs AI-assisted quality gates and synthetic monitoring that feed CI/CD, all passing model-risk and change-management validation. Architects reusable, guarded QA agent platforms (self-healing locators, auto-triage) used across teams. At L10, owns the QA-AI strategy, governance, and regulatory posture for testing.

Examples mapped to ladder levels

Ladder	QA-specific example
L2	Can explain why a real production transaction log must never be pasted into a public LLM; knows the approved internal/enterprise tool.
L3	Uses AI to draft boundary and equivalence-partition test cases for a non-sensitive utility function, then verifies each before committing.
L4	Crafts prompts that generate correct parameterized unit tests in the team's actual framework (e.g., JUnit, pytest, Playwright) with proper fixtures and assertions.
L5	Runs a workflow: AI generates e2e scenarios from acceptance criteria -> reviews for gaps -> AI explains failing CI runs -> logs triage-time and coverage deltas in the QA dashboard.
L6	Publishes a vetted prompt library and synthetic-data guidelines; coaches the team on regression-risk prompting and reviews others' AI-generated suites for safety and quality.
L7	Builds an approved bot that, on each PR, proposes regression tests for changed code paths and posts failed-test explanations to the PR, behind a reviewer approval and rollback gate.
L8	Designs an end-to-end AI quality gate (defect clustering + regression-risk scoring blocking risky merges) that passes model-risk validation and change control.
L9	Builds a reusable, guard-railed test-automation agent platform (self-healing selectors, auto-triage, synthetic monitoring) adopted org-wide with central guardrails.
L10	Owens enterprise testing-AI strategy: tool approval, data controls, audit standards, and regulatory alignment for AI in the SDLC.

Evidence HR can verify

Evidence type	What to look for	Confirms level
Commit/PR history	AI-assisted tests that were reviewed and edited, not pasted raw	L3-L5
Prompt artifacts	Saved, reusable prompts producing framework-correct tests	L4-L6
QA metrics dashboard	Logged coverage uplift, triage-time reduction, escaped-defect trend	L5+
Team enablement records	Prompt library, internal demos, peer reviews, onboarding docs authored	L6
Change/CR tickets	Approved automation with rollback and human-gate documentation	L7-L8
Model-risk / validation sign-off	Quality-gate or scoring model passed validation review	L8

Evidence type	What to look for	Confirms level
Platform adoption records	Other teams using the candidate's QA agent/tooling	L9
Governance ownership	Named owner of testing-AI policy, tool approval, audit standards	L10

HR note: ask for links to PRs, dashboards, prompt repos, and CR/validation tickets. Self-reported "I use AI daily" is not evidence above L3. (Inferred from public material.)

Practical test examples

Test A — Effective prompting and verification (targets L4): Give the candidate a sanitized function spec (e.g., an interest-accrual calculator) and ask them to use the approved AI tool to generate a unit-test suite. Pass criteria: tests compile and run in the real framework; cover boundaries, negatives, and rounding/precision edge cases; the candidate identifies at least one AI-introduced gap or wrong assertion and corrects it; no real data used.

Test B — Workflow, risk analysis, and safe data (targets L5-L6): Provide a small change set (a diff) plus prior failure history. Ask the candidate to use AI to (1) identify the highest regression-risk areas, (2) cluster historical defects to prioritize, and (3) generate synthetic test data without any production records. Pass criteria: risk ranking is justified against real history (not just AI's claim); synthetic data is clearly non-real and policy-compliant; candidate measures and states the expected coverage/triage improvement.

Embedded regulated safety and data controls

- **No real customer/account/PII data** in any prompt; synthetic or masked data only, generated via approved methods.
- **Approved tools only** — enterprise-sanctioned LLM endpoints; no public consumer tools for work artifacts (L2 gate).
- **Human-in-the-loop:** AI-generated tests and triage outputs are reviewed before merge; AI never auto-approves a quality gate above advisory.
- **Auditability:** prompts, generated artifacts, and gate decisions are version-controlled and traceable for regulatory review.
- **Change management:** any AI automation touching CI/CD (L7+) requires CR approval, rollback plan, and where it scores/blocks merges, model-risk validation (L8+).

Recommended target levels

Horizon	Target	Rationale
After 4 months	L4 (team baseline L3)	Most QA staff should reliably generate and verify framework-correct tests with deliberate prompting and full data-handling compliance.

Horizon	Target	Rationale
After 12 months	L5-L6 (leads/seniors toward L7)	Embed AI across QA workflows with measured gains; senior QA engineers and leads begin building approved, gated automations.

Targets are role-weighted: junior QA should solidify L3-L4 with safe habits; senior QA and SDETs should reach L5-L6; QA leads/architects pursue L7+ with full change-management and validation discipline. (Inferred from public material — calibrate to your internal role definitions.)

12.x Release / Change Management

This guidance helps managers and HR assess how well a Release / Change Management professional uses GenAI tools across the change lifecycle, from intake through post-implementation review. In a regulated banking environment, every AI-assisted change artifact (impact analysis, risk score, rollback plan, CAB packet, compliance evidence) is a record that may be examined by auditors and regulators. AI output here is always advisory: a named human change owner remains accountable, and the Change Advisory Board (CAB) approves.

What **LOW** / **MEDIUM** / **HIGH** capability look like

Band	Ladder	What it looks like in Release/Change work	Typical risk posture
LOW	L1-L3	Pastes a change ticket into a chatbot to "tidy up" a description; uses AI only on individual, low-risk tasks; verifies inconsistently; unaware which fields are sensitive (customer data, infra IPs, vendor terms).	Unmanaged. Risk of leaking change content; unverified risk scores reaching CAB.
MEDIUM	L4-L6	Deliberate prompting to draft impact analyses, release notes, and rollback plans; cross-checks AI risk scoring against the org's change-risk matrix and CMDB; builds reusable prompt templates the team adopts; sets norms on what data may and may not be entered.	Managed at task/workflow level. Human always finalizes before CAB.
HIGH	L7-L10	Designs approved automations that pull from CMDB, ticketing (e.g., ServiceNow/Jira), and pipeline data to pre-populate change records with built-in rollback and approval gates; validates change-failure prediction models through model-risk review; defines org-wide change-AI governance and audit-evidence standards.	Governed. Guardrails, logging, and validation are built into the pipeline.

Examples mapped to ladder levels

Ladder	Representative capability in this team
L2	Can explain why a change record with production hostnames or customer identifiers must not go into an unapproved external tool.

Ladder	Representative capability in this team
L3	Uses an approved tool to summarize a change request and shorten release notes, then manually checks every fact against the source ticket.
L4	Writes structured prompts that produce a consistent impact-analysis format (affected services, dependencies, blast radius) and refines them to cut rework.
L5	Embeds AI across the change workflow — summarization, draft risk score, draft rollback plan, release notes — and measures cycle-time and rework reduction.
L6	Sets the team standard for AI-assisted CAB packets, reviews peers' AI-assisted change artifacts, and trains others on safe data handling.
L7	Builds an approved automation that drafts the CAB packet and rollback plan from ticket + CMDB data, with mandatory human approval and rollback gates before deployment.
L8	Designs an end-to-end change-failure-prediction solution that clears model-risk validation and feeds deployment-window recommendations.
L9	Builds a reusable, guardrailed change-management agent/platform used across multiple delivery teams.
L10	Owns enterprise policy for AI in change/release, including auditability, regulatory alignment, and accountability boundaries.

Evidence HR can verify

Capability area	What to ask for as evidence
Change-request summarization	A before/after sample showing the AI summary matched against the source ticket, with the verifier named.
Impact analysis	Impact assessment showing AI-drafted dependencies cross-checked against CMDB, with corrections noted.
Risk scoring	Side-by-side of AI-suggested risk score vs. the org change-risk matrix outcome, plus who confirmed the final score.
Release notes	Published release notes plus the prompt/template and the review sign-off.
CAB decision support	A CAB packet section produced with AI assistance, with a clear note that a human owner finalized it and CAB approved.
Deployment-window recommendation	Recommendation traced to freeze calendars, dependency data, and business-impact rules — not an unsourced AI guess.
Rollback plan generation	Rollback plan validated against the actual deployment steps, with a tested or peer-reviewed checkpoint.
Change-failure prediction	For L7+, evidence the model passed model-risk validation and that outputs are logged and monitored.

Capability area	What to ask for as evidence
Compliance evidence	Audit trail showing AI-assisted artifacts are labeled, logged, and retained per records policy.

For each item, HR should confirm three things: the source data was approved for the tool used, a named human reviewed and signed off, and the artifact is logged/retained for audit.

Practical test examples

Test 1 — Risk-scored change packet (targets L4-L5). Give the candidate a sanitized change request. Ask them to produce: a one-paragraph summary, an impact analysis, a draft risk score, and a rollback plan. Score on whether they (a) used only approved/sanitized data, (b) cross-checked the AI risk score against the change-risk matrix and corrected it, (c) tied the rollback plan to real deployment steps, and (d) flagged what a human/CAB must verify before approval.

Test 2 — Automation design review (targets L7-L8). Present a proposal to auto-generate CAB packets from ticket + CMDB data. Ask the candidate to identify required guardrails. A strong answer names: mandatory human approval gate, rollback gate before deploy, data-scope limits (no unapproved sensitive fields), full logging/audit trail, and a model-validation step for any predictive risk/failure scoring.

Recommended target levels

Horizon	Individual contributor (Change Analyst/Manager)	Technical lead / Change owner
After 4 months	L4 — reliable, verified AI-assisted drafting of change artifacts	L5 — AI embedded across the change workflow with measured gains
After 12 months	L5 — workflow-level use with measured cycle-time/rework improvement	L7 — owns at least one approved change automation with human-approval and rollback gates

(Inferred from public material) — These targets are synthesized from public ITIL/ITSM change-management practice and published vendor patterns (e.g., AI-assisted change summarization and risk prediction in mainstream ITSM platforms), not from any internal company ladder. Calibrate the cadence to your CAB maturity and model-risk governance capacity.

Embedded regulated controls (apply at every level): only approved tools and approved data scopes; no customer data, credentials, or production secrets in prompts to unapproved tools; named human accountability and CAB approval retained for every change; AI outputs labeled as AI-assisted; full logging and records retention for audit; and model-risk validation required before any predictive scoring (change-failure prediction, risk scoring) is used in decisions.

12.x Managers / Technical Leaders

This guidance evaluates managers and technical leaders not on their personal prompting skill, but on how well they **build, govern, and scale AI capability across their teams** inside a regulated financial-services environment. A manager can be a strong individual AI user (L4-L5) yet score LOW as a leader if they have no roadmap, no governance, and no measurement. Evaluate the leadership behaviors below, then map to the ladder.

What LOW / MEDIUM / HIGH leadership capability looks like

Capability area	LOW (gap)	MEDIUM (developing)	HIGH (strong)
AI adoption roadmap	No plan; ad-hoc tool use; "everyone figure it out"	A 1-2 quarter plan exists but is not tracked or funded	Sequenced 12-month roadmap with milestones, owners, budget, and review cadence
Governance model	No rules on data, tools, or approvals; shadow AI tolerated	Reuses enterprise policy but no local enforcement	Local controls layered on enterprise policy; approved-tool list, data-class rules, named accountable owner
Use-case prioritization	Chases hype; no triage	Maintains a backlog but ranks by enthusiasm	Scores use cases by value, risk, and feasibility; rejects high-risk/low-value cases explicitly
ROI measurement	"It feels faster"; no baseline	Tracks usage/activity metrics only	Tracks outcome metrics (cycle time, defect rate, cost) against a pre-AI baseline
Risk management	Unaware of model risk, data leakage, regulatory exposure	Knows risks exist; relies on others to manage	Maintains risk register; ensures human-in-the-loop, rollback, and audit trails on AI-assisted work
Capability planning	No view of team levels	Informal sense of who is "good with AI"	Maps team to ladder levels; plans hiring/training to close gaps
Training strategy	None	One-off lunch-and-learn	Role-based, recurring enablement tied to the ladder with measured progression
AI champion network	None	One informal go-to person	Named champions (L6) with time allocated, norms-setting mandate, and reach across teams
HR ladder adoption	Unaware of ladder	References ladder loosely	Uses ladder in reviews, goals, and promotion conversations consistently
Cross-team alignment	Siloed; duplicates effort	Occasional coordination	Shares reusable patterns, aligns with risk/compliance/platform, avoids duplication

Examples mapped to ladder levels

Observed leadership behavior	Ladder signal
Leader has not used GenAI and cannot state the team's data-handling rules	L1
Leader can explain approved tools and data-class restrictions before enabling the team	L2-L3
Leader embeds AI in team workflows and measures gains against a baseline	L5
Leader acts as the team's AI expert, sets safe norms, and lifts others (a champion)	L6
Leader sponsors production automations with documented approval and rollback gates	L7
Leader oversees end-to-end AI solutions that pass model-risk validation	L8
Leader owns AI strategy, governance, and regulatory risk for the org/domain	L10

Note: A people-manager is not required to build at L7-L9 personally. They are expected to **govern, sponsor, and enable** work at those levels. Evaluate the leader on whether the work under them clears the corresponding control bar, not on whether they wrote the code.

Evidence HR can verify

Evidence	Where to find it
Written AI adoption roadmap with owners, dates, and budget	Team/department planning docs
Use-case backlog scored by value/risk/feasibility	Backlog tool, prioritization sheet
ROI baseline and post-AI metrics	Delivery dashboards, before/after reports
Risk register entries for AI use cases; human-in-the-loop sign-offs	GRC/risk tooling, change-approval records
Approved-tool list and data-classification rules acknowledged by the team	Policy attestations, onboarding records
Named AI champions with allocated time	Org chart, capacity/allocation plans
Ladder levels recorded in performance reviews and development plans	HR review system
Evidence of cross-team reuse (shared prompts, components, standards)	Internal repos, communities of practice

Practical test examples

Test 1 - Roadmap and governance walkthrough (45 min). Ask the leader to present their team's AI adoption roadmap and answer: Which use cases are in flight and why were

they prioritized? What is the approved-tool list and which data classes may each tool touch? Who is the accountable owner if an AI-assisted output causes a customer or regulatory issue? Show one ROI baseline and the post-AI result. - LOW: no roadmap, no tool list, cannot name an accountable owner. - MEDIUM: roadmap and tool list exist, but ROI is activity-based and risk ownership is vague. - HIGH: prioritized roadmap, enforced tool/data rules, named owner, outcome-based ROI versus baseline.

Test 2 - Incident and control tabletop (30 min). Pose a scenario: an engineer used an AI tool that may have exposed customer PII into an unapproved model, and an AI-assisted change reached production without review. - LOW: no detection path, no rollback, unaware of breach-reporting duties. - MEDIUM: can roll back and knows escalation exists, but no preventive control. - HIGH: describes the preventive controls (approved-tool gating, data-loss checks, mandatory human review, rollback and audit trail), the regulatory notification path, and the post-incident control fix.

Recommended target levels

Horizon	Target for the leader's own ladder level	Target for what they enable in the team
After 4 months	L4-L5 (effective, workflow-level user)	Most of team at L3+; roadmap, approved-tool list, and ROI baseline in place; champion(s) named
After 12 months	L6 (team AI expert/champion-grade) or governance-track L7+ for senior leaders	Team median L4-L5; production automations (L7) running under approval/rollback gates; ladder used in all reviews; cross-team patterns shared

Embedded regulated controls (non-negotiable at every level): approved-tool list only; data-classification rules enforced (no restricted/customer PII into unapproved models); human-in-the-loop on any customer-facing or production-bound output; documented approval and rollback gates for automations; audit trail and model-risk validation for L8+ solutions; clear accountable owner and regulatory notification path for AI-related incidents.

(Inferred from public material: ladder-to-leadership mappings and target horizons are synthesized recommendations based on common industry enablement practice and the provided L1-L10 reference, not a published company HR ladder.)

13. HR Scoring Rubric

This section provides a practical, score-based rubric for assessing AI capability across all 16 dimensions. It is built so that any rater (HR partner, manager, or technical lead) can read a description, match it to observed evidence, and assign a defensible score. Scores then roll up into the 10-level AI capability ladder used elsewhere in this report.

13.1 How to use this rubric

- Score each of the 16 dimensions independently on a 0-5 scale using the universal anchors below.

- Base each score on **observed evidence** (work samples, shipped automations, reviewed prompts, incident handling, peer/manager input) — not self-assessment alone.
- Require at least one piece of concrete evidence for any score of 3 or higher.
- Record the score, the evidence, and the date. Re-assess on a fixed cadence (e.g., every 6 months).

Universal score anchors (apply to every dimension)

Score	Label	Universal meaning
0	Not demonstrated	No evidence; has not done this or is unaware it exists.
1	Basic awareness	Knows the concept exists and why it matters; cannot yet apply it.
2	Working knowledge	Can apply it with guidance, templates, or supervision on simple cases.
3	Independent practitioner	Applies it reliably and unsupervised on routine, real work.
4	Advanced practitioner	Handles complex/ambiguous cases, optimizes, and guides others.
5	Expert / leader	Sets standards, builds capability in others, owns outcomes org-wide.

13.2 Per-dimension rubric

Each table below specializes the universal anchors with concrete, observable behavior for that dimension. The same 0–5 scale applies throughout.

D1. AI literacy

Understanding what AI/ML is, what it can and cannot do, and where it fits.

Score	What this looks like
0	Cannot describe what AI does; treats it as magic or ignores it.
1	Knows AI exists and is relevant; can name a few use cases.
2	Explains basic concepts (model, training, prediction) and obvious limits.
3	Independently judges where AI is and isn't a fit for everyday tasks.
4	Explains trade-offs (cost, accuracy, bias, latency) to non-experts; corrects misconceptions.
5	Shapes the org's shared understanding of AI; trusted internal authority.

D2. GenAI literacy

Understanding generative models specifically (LLMs, tokens, context, hallucination, non-determinism).

Score	What this looks like
0	Unaware of generative AI or how it differs from search/automation.
1	Knows GenAI produces text/images and can be wrong.
2	Understands hallucination, context limits, and non-determinism at a basic level.
3	Chooses appropriate models/settings for routine tasks and anticipates failure modes.
4	Reasons about context windows, grounding, and cost/quality trade-offs for complex tasks.
5	Defines model selection and usage standards others follow.

D3. Prompt engineering

Designing inputs that reliably produce correct, useful output.

Score	What this looks like
0	Does not write prompts or expects one-line requests to "just work."
1	Writes simple prompts; accepts whatever comes back.
2	Uses structure (role, context, examples) with templates provided to them.
3	Independently iterates prompts to get reliable results on real tasks.
4	Applies advanced technique (decomposition, few-shot, constraints, evaluation) for hard problems.
5	Builds and shares prompt libraries/patterns; coaches teams on technique.

D4. AI tool usage

Practical operation of approved AI tools and platforms.

Score	What this looks like
0	Has not used any AI tool for work.
1	Has tried an approved tool once or twice.
2	Uses an approved tool for simple tasks with help.
3	Uses approved tools fluently and independently in daily work.
4	Combines multiple tools/features and exploits advanced capabilities.
5	Evaluates, recommends, and onboards tools; sets usage conventions.

D5. Job-specific application

Applying AI to the duties of one's actual role.

Score	What this looks like
0	No connection made between AI and own job.
1	Can name where AI might help in the role.
2	Applies AI to a few simple, role-specific tasks with guidance.
3	Routinely uses AI to do real role work faster/better, unsupervised.
4	Redesigns parts of the role's work around AI; measurable improvement.
5	Reshapes how the function works with AI; model for the discipline.

D6. Critical thinking / validation

Judging whether AI output is correct, relevant, and appropriate.

Score	What this looks like
0	Accepts AI output without question.
1	Knows output can be wrong but rarely checks.
2	Checks output against an obvious source when prompted.
3	Habitually validates output against sources/logic before use.
4	Designs validation approaches for ambiguous or high-stakes output.
5	Sets validation standards and teaches sound AI skepticism.

D7. Human review / verification

Ensuring a human is appropriately in the loop before output is used or shipped.

Score	What this looks like
0	Ships AI output directly with no review.
1	Aware review is needed but inconsistent.
2	Reviews own AI output before low-risk use.
3	Applies appropriate review depth based on task risk, consistently.
4	Designs review/sign-off workflows and approval gates for teams.
5	Owns human-in-the-loop policy; ensures accountability across the org.

D8. Automation ability

Building repeatable AI-driven automations.

Score	What this looks like
0	Has not automated anything with AI.
1	Understands automation is possible; no builds.
2	Builds a simple, single-step automation with help.
3	Builds reliable multi-step automations for own/team work independently.
4	Builds production automations with error handling, approval, and rollback.
5	Designs automation patterns/platforms reused across teams.

D9. Data & RAG understanding

Grounding AI in trusted data (retrieval, embeddings, sources, freshness).

Score	What this looks like
0	Unaware AI can be grounded in specific data.
1	Knows AI can use "your documents" at a high level.
2	Understands retrieval/grounding concept and why it reduces errors.
3	Uses RAG-style tools correctly and judges source quality/freshness.
4	Designs retrieval pipelines, chunking, and data-quality controls.
5	Sets data-grounding architecture and standards org-wide.

D10. Agentic AI understanding

Understanding autonomous, multi-step AI agents that take actions.

Score	What this looks like
0	Unaware of AI agents.
1	Knows agents can act/use tools at a high level.
2	Understands agent loops, tools, and the added risk of autonomy.
3	Uses agentic tools safely within set boundaries.
4	Designs agents with scoped permissions, guardrails, and monitoring.
5	Architects reusable agent platforms with org-wide guardrails.

D11. AI safety & security

Protecting against misuse, data leakage, prompt injection, and unsafe output.

Score	What this looks like
0	Unaware of AI safety/security risks.
1	Knows risks like data leakage and "don't paste secrets" exist.
2	Follows basic safe-use rules consistently.
3	Independently avoids and flags common risks (injection, leakage, oversharing).
4	Designs safeguards and threat-aware AI workflows.
5	Owens AI security posture; defines controls and response.

D12. Governance & compliance

Operating within policy, approvals, audit, and documentation requirements.

Score	What this looks like
0	Unaware of any AI policy or approval requirement.
1	Knows policies exist; unsure of specifics.
2	Follows approval/usage policy with guidance.
3	Works within policy independently and documents AI use appropriately.
4	Builds compliant workflows; prepares evidence for audit/model-risk review.
5	Shapes AI governance, controls, and policy for the org.

D13. Banking / regulated-industry risk awareness

Understanding the specific obligations of a regulated financial-services context.

Score	What this looks like
0	No awareness of regulatory/customer-data obligations around AI.
1	Knows banking has strict data/regulatory rules relevant to AI.
2	Identifies obvious regulated-data risks (PII, customer data) before acting.
3	Independently applies regulated-industry caution to routine AI use.
4	Anticipates regulatory exposure (fairness, explainability, records) in AI design.
5	Owens regulatory risk strategy for AI; interfaces with risk/compliance/regulators.

D14. Collaboration / knowledge-sharing

Spreading safe, effective AI practice to others.

Score	What this looks like
0	Works in isolation; shares nothing.
1	Occasionally mentions AI tips informally.
2	Shares a useful prompt/technique when asked.
3	Regularly shares working practices and helps peers.
4	Runs enablement (docs, sessions, norms) that lifts a team.
5	Builds AI community of practice across the org.

D15. Business impact

Tying AI use to measurable value (time, cost, quality, revenue, risk reduction).

Score	What this looks like
0	No link between AI use and outcomes.
1	Claims benefit anecdotally; no measurement.
2	Notes time/quality gains informally.
3	Measures and reports concrete gains from own AI use.
4	Drives measurable team-level impact with clear metrics.
5	Delivers and owns enterprise-level AI value; ties to strategy.

D16. Leadership & strategy

Setting direction, prioritization, and accountability for AI.

Score	What this looks like
0	No role in AI direction.
1	Voices opinions on AI direction informally.
2	Contributes to AI decisions when included.
3	Leads AI adoption within own team/scope.
4	Sets AI priorities and standards across multiple teams.
5	Owens enterprise AI strategy, governance, and accountability.

13.3 Master matrix (quick reference)

#	Dimension	1 Basic awareness	3 Independent practitioner	5 Expert / leader
D1	AI literacy	Knows AI is relevant	Judges AI fit independently	Org authority on AI
D2	GenAI literacy	Knows GenAI can be wrong	Picks models/settings, anticipates failure	Sets model-use standards
D3	Prompt engineering	Writes simple prompts	Iterates to reliable results	Builds prompt libraries, coaches
D4	AI tool usage	Tried a tool	Uses tools fluently daily	Evaluates/onboards tools
D5	Job-specific application	Names where AI helps	Uses AI for real role work	Reshapes the function
D6	Critical thinking / validation	Knows output can be wrong	Habitually validates	Sets validation standards
D7	Human review / verification	Aware review needed	Risk-based review consistently	Owns human-in-loop policy
D8	Automation ability	Knows automation possible	Builds multi-step automations	Designs automation platforms
D9	Data & RAG understanding	Knows AI can use documents	Uses RAG, judges sources	Sets grounding architecture
D10	Agentic AI understanding	Knows agents can act	Uses agents within bounds	Architects agent platforms
D11	AI safety & security	Knows leakage risk	Avoids/flags common risks	Owns security posture
D12	Governance & compliance	Knows policy exists	Works within policy, documents	Shapes governance/ policy
D13	Banking / regulated risk	Knows banking is strict	Applies regulated caution	Owns regulatory AI strategy
D14	Collaboration / sharing	Mentions tips informally	Shares practices, helps peers	Builds community of practice
D15	Business impact	Anecdotal benefit	Measures/reports gains	Owns enterprise value
D16	Leadership & strategy	Informal opinions	Leads team adoption	Owns enterprise strategy

13.4 How dimension scores roll up to the 10-level ladder

The 16 dimensions describe capabilities; the ladder (L0–L10) describes a person's overall level. Use this two-rule method to convert scores into a ladder level.

Rule 1 — Gate dimensions (must-pass safety floor). Because this is a regulated financial-services context, four dimensions act as gates. A person cannot be placed above the ladder level their gate scores allow, regardless of how strong their other scores are. The gate dimensions are:

- D6 Critical thinking / validation
- D7 Human review / verification
- D11 AI safety & security
- D12 Governance & compliance
- D13 Banking / regulated-industry risk awareness

Rule 2 — Driver dimensions (what pulls the level up). Within the ceiling set by the gates, the level is set by the highest-order capability the person consistently demonstrates with evidence (prompting → workflows → enablement → automation → solution design → platform building → strategy).

Mapping table

Ladder level	Name	Typical dimension profile (with evidence)	Gate requirement
L0 / L1	No Exposure	All dimensions at 0; unaware of tools and data risks.	None.
L2	AI Awareness	D1, D2, D12, D13 at 1; understands data-handling rules before using a tool.	Gates $\geq$ 1.
L3	Basic AI User	D4, D5 at 2–3; D6, D7 at 3 (verifies on low-risk tasks).	Gates $\geq$ 2; D6, D7, D11 $\geq$ 2.
L4	Effective Prompt User	D3 at 4; D2, D5 at 3; reliable results via deliberate technique.	Gates $\geq$ 2; D6, D7 $\geq$ 3.
L5	Workflow AI User	D5 at 4; D8 at 3; D15 at 3 (embeds AI across multi-step work and measures gains).	Gates $\geq$ 3; D6, D7 $\geq$ 3.
L6	AI Power User	D14 at 4; D3, D6 at 4; sets safe norms and lifts others.	Gates $\geq$ 3; D11, D12, D13 $\geq$ 3.
L7	AI Automation Contributor	D8 at 4 (production automations with approval and rollback); D11 at 4.	Gates $\geq$ 3; D7, D11, D12 $\geq$ 4.
L8	AI Solution Designer	D9 at 4; D8 at 4; D12 at 4 (end-to-end solutions that pass model-risk validation).	Gates $\geq$ 4; D12, D13 $\geq$ 4.
L9	AI Agent / Platform Builder	D10 at 5; D8, D9 at 5; D11 at 4–5 (reusable agent platforms with guardrails org-wide).	Gates $\geq$ 4; D11, D12 $\geq$ 4.

Ladder level	Name	Typical dimension profile (with evidence)	Gate requirement
L10	AI Strategy / Governance Leader	D16 at 5; D12, D13 at 5; D15 at 5 (owns enterprise strategy, governance, regulatory risk).	Gates ≥ 4 ; D12, D13 = 5.

Worked examples

- **Strong builder, weak compliance:** D3=4, D8=4, D10=4 but D12=2 and D13=1. Driver capability suggests L7–L8, but the governance/regulated-risk gates cap placement at **L3**. Action: close the gate gap before advancing.
- **Balanced workflow user:** D3=4, D5=4, D8=3, D15=3, gates all ≥ 3 . Lands cleanly at **L5**.
- **Enablement leader:** D14=5, D6=4, D11=4, D12=4, gates ≥ 4 , but no production automations (D8=3). Caps at **L6** until automation evidence (D8 ≥ 4) supports L7.

Notes on the mapping

- (Inferred from public material) The gate-and-driver model synthesizes widely published competency-framework practice (proficiency scales, must-pass safety criteria) with the regulated-industry control emphasis described elsewhere in this report. It is a recommended method, not a vendor-published standard.
- The dimension thresholds in the mapping table are **recommended starting points**. Calibrate them against real assessments in your org and adjust before formal use in promotion or pay decisions.
- Keep the gate list short and non-negotiable. In a banking-style context, the cost of advancing someone who ships unverified or non-compliant AI output is far higher than the cost of holding them one level back.

14. Evidence-Based Assessment Process

A capability claim is only as good as the evidence behind it. In a regulated financial-services environment, "I'm good with AI" is not a rating — it is a starting hypothesis that must be tested against observable behaviour, artefacts, and outcomes. This section defines seven assessment types, what each is for, how to score it, what evidence to require, and how to keep bias out of the result.

Each assessment type maps to the AI capability ladder (L0/L1 through L10). No single method is sufficient on its own: self-assessment is cheap but unreliable, practical tasks are reliable but narrow, and calibration panels are fair but expensive. The recommended design uses cheaper methods for screening lower levels (L0/L1–L3) and reserves the heavier methods (practical task, portfolio, panel) for higher-stakes levels (L5+), where the cost of a wrong rating — an unqualified person shipping a production automation or designing a model-risk-relevant solution — is highest.

Assessment design principle (Inferred from public material)

The general principle that no single rating source is reliable, that ratings should be calibrated across raters, and that self-assessment tends to be inflated, is drawn from widely published research and practice on performance appraisal and competency assessment (e.g. Kruger & Dunning on self-assessment inflation; structured-interview and work-sample validity literature; calibration-session practice common in HR). The specific mapping to the AI ladder below is a synthesized recommendation, not an established company practice.

A. Self-Assessment

Field	Detail
Purpose	Fast, low-cost screening; surface the person's own view of their level and identify gaps to probe later. Useful for L0/L1–L3 triage and for prompting reflection before a manager conversation.
Scoring method	Person rates themselves against ladder descriptors (L0–L10) per competency. Treated as a claim, not a score. Gap = (self-rating – verified rating); large positive gaps flag over-confidence to probe. Never used alone above L3.
Evidence required	Completed ladder rubric with a concrete example for each claimed level (what they did, which tool, what data, what verification step). Claims without examples are scored as unevidenced.
Bias risks	Over-confidence (Dunning-Kruger); under-confidence in cautious/junior staff; social-desirability bias (claiming "safe use" because it is expected); gaming toward promotion.
Mitigation	Require a concrete example per claim; cross-check against manager assessment and at least one objective method; calibrate the self-vs-verified gap across the team rather than reading any one score in isolation.

Example questions - "Give one task in the last month where you used a GenAI tool. What data did you put in, and how did you check the output before using it?" - "Which level on the ladder best describes your typical use, and why not the level above?" - "Describe a time you decided not to use AI for a task. What was the risk?"

B. Manager Assessment

Field	Detail
Purpose	Provide a supervisor's view grounded in day-to-day observation; primary verification source for L3–L5; input (not the deciding vote) for L6+.

Field	Detail
Scoring method	Manager rates the person against the same ladder rubric, citing specific observed instances. Rating must reference dated examples, not general impressions. Disagreements with self-assessment are recorded, not averaged away.
Evidence required	At least two dated, specific observations per claimed level (e.g. "verified a model output against source before sending to client, 12 May"); for L4+, evidence of repeatable technique, not a one-off.
Bias risks	Halo/horns effect; recency bias; favouritism; leniency or central-tendency bias; managers rating AI skill they themselves cannot judge.
Mitigation	Require dated examples; train managers on the ladder before rating; route any level the manager cannot personally judge (typically L7+) to technical review; surface manager rating distributions in calibration to catch leniency/severity.

Example questions (for the manager) - "What is the most complex AI-assisted task you have personally seen this person complete correctly?" - "Have you seen them verify outputs and handle data safely under time pressure, or only in ideal conditions?" - "Where have they lifted others' capability versus only delivering their own work?"

C. Practical Task (Work Sample)

Field	Detail
Purpose	Directly observe capability on a representative, controlled task. Highest validity for L3–L5 (safe use, prompting, workflow); the core method for confirming hands-on skill rather than talk.
Scoring method	Scored against a pre-written rubric with pass/partial/fail criteria per behaviour (e.g. data-handling, verification, prompt iteration, result quality). Same task and rubric for all candidates at a level. Blind scoring where feasible.
Evidence required	The task artefact itself (prompts used, outputs, the verification trail) plus the completed rubric. For workflow levels, a worked multi-step example with a measured before/after.
Bias risks	Task not representative of real work; difficulty drift between candidates; scorer leniency; advantage to candidates familiar with the specific tool used in the test.
Mitigation	Use realistic, role-relevant scenarios with synthetic (never live customer) data; fix one rubric per level; use two independent scorers and reconcile; allow tool choice where the level is about capability, not a specific product.

Example tasks - L3: "Summarise this internal policy using a GenAI tool. Show what you pasted in and how you confirmed the summary is accurate. Flag anything you would not paste in." (Tests safe routine use + verification.) - L4: "Get a usable first draft of a customer email for this scenario. Show your prompt iterations and why the final prompt works." (Tests deliberate prompting technique.) - L5: "Design an AI-assisted workflow for this recurring

reporting task, and estimate the time saved versus today." (Tests multi-step embedding + measurement.)

D. Portfolio Evidence

Field	Detail
Purpose	Assess sustained, real-world capability over time using actual work products. Primary method for L5–L9, where capability shows up in shipped workflows, automations, platforms, and adoption by others.
Scoring method	Review submitted artefacts against ladder descriptors, checking authorship, approval/rollback gates, and measured impact. Each item scored for what it actually demonstrates, not for ambition. Authorship and the candidate's specific contribution are verified.
Evidence required	Links/exports of real artefacts: prompt libraries, documented workflows with metrics, production automations with approval and rollback controls (L7), solution designs that passed model-risk validation (L8), reusable agent platforms with guardrails (L9), plus evidence others used them.
Bias risks	Attribution error (taking credit for team work); cherry-picking best work; polished presentation masking weak substance; survivorship (failures hidden).
Mitigation	Verify contribution with named collaborators and version history; require a representative sample, not just highlights; ask for at least one thing that failed and what was learned; check governance artefacts (approvals, rollback, validation sign-off) exist, not just the build.

E. Interview / Discussion (Structured)

Field	Detail
Purpose	Probe reasoning, judgement, and risk awareness behind the work — the "why," not just the "what." Critical for L2 (data-handling understanding), L6 (norm-setting), and L8–L10 (design, governance, regulatory judgement).
Scoring method	Structured interview: same core questions per level, anchored rating scale per question (behaviourally-defined 1–5), scored against pre-agreed answer indicators. Not a free-form chat.
Evidence required	Recorded ratings per question with notes on what the candidate actually said; specific scenarios they were asked to reason through.
Bias risks	Similarity/affinity bias; articulate-talker effect (rewarding fluency over substance); leading questions; first-impression anchoring.
Mitigation	Use a fixed question set and anchored scoring; two interviewers scoring independently before discussing; focus questions on real past behaviour and scenario reasoning, not hypotheticals about ideal practice; separate "explains well" from "did well."

Example questions - L2: "What types of data must never go into an external GenAI tool here, and why? What do you do if you are unsure?" - L6: "How would you set safe AI norms for a team where some members are at L3 and some at L1?" - L8: "Walk me through how you would design an AI solution so it passes model-risk validation. What controls would you build in from the start?" - L10: "How would you balance enterprise AI adoption against regulatory and reputational risk?"

F. Peer / Technical Review

Field	Detail
Purpose	Bring expert and peer judgement to bear where managers cannot assess depth. Essential for the technical levels (L7–L9: automation, solution design, platform building) and for verifying claimed influence on peers (L6).
Scoring method	Qualified reviewer(s) assess technical artefacts and design choices against ladder descriptors and engineering/governance standards; peers attest to norm-setting and uplift. Scored against defined technical criteria, with reviewer qualification recorded.
Evidence required	Reviewer sign-off referencing specific artefacts (code, automation gates, architecture, guardrails); peer attestations of being trained, unblocked, or having adopted the person's norms/tools.
Bias risks	Reciprocity/log-rolling ("rate me up, I'll rate you up"); in-group bias; reviewer not actually qualified for the level reviewed; conflict of interest within the same team.
Mitigation	Require reviewers qualified at or above the level assessed; use at least one reviewer outside the candidate's immediate team; record reviewer rationale; weight peer attestation as supporting, not sole, evidence.

Example questions (for the reviewer) - "Do the automation's approval and rollback gates meet our production standard? Cite where." - "Is this agent platform genuinely reusable with guardrails, or a one-off bound to its author?" - "Independently of what the candidate claims, what does this artefact prove they can do?"

G. Calibration Panel

Field	Detail
Purpose	Final fairness and consistency check. Reconcile multi-source evidence into a single defensible rating and ensure a given level means the same thing across teams. Required for all L6+ ratings and for resolving any self-vs-manager disagreement.
Scoring method	Cross-functional panel reviews the assembled evidence pack (self, manager, task, portfolio, interview, technical review) and agrees a final level. Decisions and dissents are documented. Panel checks that ratings hold to a consistent standard, not relative ranking within one team.

Field	Detail
Evidence required	Complete evidence pack per candidate; written rationale for the agreed level; record of any adjustment from the manager's proposed rating and why.
Bias risks	Groupthink/dominant-voice effect; rating-distribution pressure (forced curves distorting genuine levels); horse-trading; status bias toward senior candidates.
Mitigation	Independent pre-reads before discussion; rotate/limit who speaks first; chair enforces evidence-based challenge; assess against absolute ladder descriptors, not a quota; document dissent; audit decisions for adverse-impact patterns across demographic groups.

Common Evidence Types

Evidence type	What it shows	Strongest for
Concrete worked example (prompt + output + verification trail)	Actual hands-on behaviour and safety habits	L3–L5
Dated manager/peer observation	Real-world performance under normal conditions	L3–L6
Work-sample artefact + rubric score	Controlled, comparable capability	L3–L5
Documented workflow with before/after metrics	Measured productivity impact	L5
Production automation with approval/rollback gates	Safe build capability under governance	L7
Solution design with model-risk validation sign-off	End-to-end design that meets regulatory bar	L8
Reusable agent platform with guardrails + adoption evidence	Org-wide engineering capability	L9
Enterprise strategy/governance artefacts (policy, risk framework)	Strategic and regulatory ownership	L10
Peer attestation of training/uplift	Influence on others' capability	L6
Reviewer sign-off referencing specific artefacts	Independently verified technical depth	L7–L9

Assessment Methods at a Glance

Method	Cost	Reliability alone	Best ladder fit	Use as
A. Self-assessment	Low	Low	L0/L1–L3 triage	Screening / claim only

Method	Cost	Reliability alone	Best ladder fit	Use as
B. Manager assessment	Low	Medium	L3-L5	Primary verification (lower levels)
C. Practical task	Medium	High	L3-L5	Confirming hands-on skill
D. Portfolio	Medium-High	High	L5-L9	Confirming sustained real capability
E. Structured interview	Medium	Medium-High	L2, L6, L8-L10	Probing judgement and reasoning
F. Peer/technical review	Medium	High (technical)	L6-L9	Verifying depth and influence
G. Calibration panel	High	High (fairness)	L6+ and all disputes	Final reconciliation

Recommended evidence-by-level summary (Inferred / synthesized recommendation)

Ladder level	Minimum evidence to confirm
L0/L1 No Exposure	Self-assessment + manager confirmation
L2 AI Awareness	Self-assessment + short structured interview on data-handling rules
L3 Basic AI User	Practical task (safe routine use + verification) + manager observation
L4 Effective Prompt User	Practical task showing deliberate prompting + worked example
L5 Workflow AI User	Portfolio workflow with measured before/after + manager sign-off
L6 AI Power User	Peer attestations of uplift + manager input + calibration panel
L7 AI Automation Contributor	Portfolio automation with approval/rollback gates + technical review
L8 AI Solution Designer	Solution design with model-risk validation sign-off + technical review + panel
L9 AI Agent/Platform Builder	Reusable platform with guardrails + adoption evidence + technical review + panel
L10 AI Strategy/Governance Leader	Enterprise strategy/governance artefacts + executive/panel review

15. Practical Tests by Role

15.x Service Desk Analyst

Ladder anchor: This test targets L3-L4 (Basic AI User to Effective Prompt User), with stretch indicators for L5 (Workflow AI User). It assumes the candidate has cleared L2 (knows GenAI basics and data-handling rules). Service Desk Analysts in a regulated bank handle live incident tickets containing customer and employee data, so safe data-handling judgment is weighted as heavily as technical accuracy.

Scenario

You are a Service Desk Analyst on the IT service desk of a retail bank. A P2 incident ticket has been escalated to you. A branch employee reports that the internal "Account Servicing" desktop application repeatedly fails to load the customer search screen, showing a generic "Connection timed out" error since this morning. Roughly 40 branch users across three locations are affected, so tellers are falling back to a slower manual process.

The ticket thread you have been handed contains:

- The end-user's description and screenshots.
- A copied application error log snippet.
- The reporting employee's full name, employee ID, branch code, and direct phone number.
- One screenshot that shows a real customer's name, full account number, and partial address visible in the application window.
- A connection string fragment from the log that includes an internal database hostname and a service-account username.

You have access to an approved, enterprise-hosted GenAI assistant (your bank's sanctioned tool, covered by the corporate data-processing agreement). You do NOT have access to any consumer/public AI tool. Your job is to use AI to accelerate triage, while keeping sensitive data out of any prompt that is not strictly necessary and within policy.

Task

1. Decide what content from the ticket can and cannot be placed into the approved AI assistant, and redact or substitute anything that should not be sent.
2. Use AI to summarize the failure, propose the most likely root cause(s), and suggest a safe first-response remediation and a clear escalation path to the application support team.
3. Produce a customer-safe and an internal-facing update for the ticket.
4. Explicitly state which AI outputs you verified or must hand off to a human/specialist team before acting.

AI usage allowed

Allowed	Not allowed
Use the approved enterprise GenAI assistant for summarization, drafting updates, and brainstorming likely causes.	Pasting raw customer PII (name, full account number, address) into any prompt.
Paste sanitized/redacted log text and a generic problem description.	Pasting service-account credentials, full internal hostnames, or connection strings.
Ask AI to suggest diagnostic questions and a triage checklist.	Using any consumer/unsanctioned AI tool, even for "quick" checks.
Use AI to draft the customer-facing and internal updates for human review.	Letting AI auto-execute remediation, close the ticket, or take any system action.

Expected output

A short triage package containing:

1. **Data-handling decision** — a list of items removed, masked, or substituted before any AI use, with one line of reasoning each (e.g., account number masked to last 4, hostname replaced with `<DB_HOST>`, service-account user replaced with `<SVC_USER>`, employee personal phone excluded).
2. **AI-assisted failure summary** — 3-5 sentences in plain language.
3. **Likely root cause(s)** — ranked, with a confidence note (e.g., "network/connectivity vs. DB service availability vs. credential/expiry") and what evidence would confirm each.
4. **Safe first-response remediation** — only low-risk, reversible steps the service desk is authorized to take (e.g., confirm scope, basic connectivity checks, restart of the client app on one machine), plus the correct escalation/handoff to application or database support for anything privileged.
5. **Two ticket updates** — one customer/branch-friendly, one internal technical note.
6. **Human-verify list** — items that must NOT be acted on from AI output alone (e.g., any change touching the database, service account, or firewall).

Evaluation criteria

#	Criterion	What good looks like
1	Correct data triage	Identifies all sensitive elements and redacts/substitutes before any AI use; nothing prohibited is sent.
2	Tool choice	Uses only the approved enterprise tool; never reaches for a consumer tool "just to test."
3	Quality of summary	Accurate, plain-language, no invented log details or fabricated error codes.
4	Root-cause reasoning	Offers ranked hypotheses with confidence and the evidence needed to confirm — not a single guess stated as fact.

#	Criterion	What good looks like
5	Safe remediation scope	Suggests only authorized, reversible service-desk actions; escalates privileged actions correctly.
6	Human verification	Clearly separates AI suggestions from actions requiring human/specialist sign-off.
7	Communication	Customer update is reassuring and jargon-free; internal note is precise and actionable.
8	Prompt technique (stretch, L4)	Uses structured prompting (role, context, constraints, output format) and iterates rather than accepting first output.

Scoring rubric (0-5)

Score	Level	Description
0	Unsafe / no exposure	Pastes raw PII or credentials into AI, uses an unsanctioned tool, or cannot use the tool at all. Maps to L0/L1.
1	Aware only	Knows data rules in theory but applies them inconsistently; output is mostly unusable without rework. Maps to L2.
2	Basic, partial	Redacts most sensitive data and produces a usable summary, but misses one sensitive element or accepts AI output without verification. Approaching L3.
3	Safe routine user	Fully correct data triage, accurate summary, sensible remediation, and a clear human-verify list. Solid L3.
4	Effective prompt user	All of the above plus deliberate prompting (structured, iterated), ranked root causes with confidence, and well-targeted escalation. Solid L4.
5	Workflow-oriented	All of L4 plus reusable artifacts (a reusable redaction checklist or triage prompt template) and a measure of time/quality gain, signaling readiness toward L5.

Red flags

- Any customer PII, account number, address, credential, or internal hostname pasted into an AI prompt — automatic cap at score 0 regardless of other quality.
- Use of a consumer/unsanctioned AI tool for any part of the task.
- Treating an AI-suggested remediation (especially DB, service-account, or firewall changes) as approved and acting on it without human verification.
- Presenting AI-invented error codes, log lines, or root causes as confirmed fact (hallucination passed through to the ticket or customer).
- Closing the ticket or marking it resolved based on AI output alone.
- Putting the reporting employee's personal phone number or full identifiers into a prompt when not needed.

Safety/compliance checks

Check	Pass condition
Data minimization	Only the minimum sanitized text needed for triage is sent to AI; PII and secrets are masked or substituted.
Approved tooling	Only the bank's sanctioned, contractually covered GenAI assistant is used.
Secrets handling	No credentials, connection strings, or internal hostnames are exposed to AI; any suspected credential exposure in the ticket is flagged for rotation per policy.
Human-in-the-loop	No privileged or system-changing action is taken on AI advice without specialist verification and approval.
Auditability	The prompt(s) and AI outputs used can be reviewed (kept within the approved tool's logged session); no shadow tooling.
Customer confidentiality	Customer-facing update reveals no internal system names, account data, or root-cause speculation that could mislead.
Incident integrity	Ticket status changes and resolutions remain a human decision; AI is decision-support only.

Note (Inferred from public material): The ladder levels and the redaction/escalation expectations here are synthesized from widely published service-desk and regulated-industry GenAI-usage best practices (data minimization, approved-tool-only usage, human-in-the-loop for privileged actions). They do not reflect any specific internal HR ladder or proprietary company policy.

15.x DevOps Engineer

Scenario

A nightly CI/CD pipeline for the bank's **Payments Authorization Service** has failed during the deploy stage to the pre-production environment. The release window closes in two hours, and a regulatory-mandated change freeze begins tomorrow. You are handed a 1,200-line Jenkins console log. The log contains a mix of build errors, a failed database migration, and a connection timeout to a downstream service.

Critically, the raw log includes embedded sensitive material: a database connection string with credentials, an internal hostname/IP scheme, a customer PAN (card number) that appeared in a debug-level SQL statement, an OAuth client secret printed by a misconfigured plugin, and internal service topology. You may use an approved enterprise GenAI assistant to accelerate triage, but the bank's data-handling policy prohibits sending production secrets, customer data (PII/PAN/PCI scope), or internal infrastructure detail to external or non-approved AI tools.

Task

1. Identify and redact all sensitive data in the log **before** any AI interaction.

2. Use the approved AI assistant to summarize the failure, propose a ranked root-cause hypothesis, and suggest safe remediation steps.
3. Explicitly separate AI-generated suggestions from facts you have verified yourself.
4. State what must be human-verified before any change is applied to pre-production.
5. Produce a go/no-go recommendation given the impending change freeze.

AI usage allowed

Allowed	Not allowed
Summarizing a pre-redacted log	Pasting raw logs containing secrets, PAN/PII, or internal topology
Generating candidate root-cause hypotheses	Letting AI auto-apply fixes to any environment
Drafting remediation steps for human review	Treating AI output as verified root cause
Drafting redaction/regex patterns	Using a non-approved/consumer AI tool for bank data
Explaining unfamiliar error signatures	Sending credentials or connection strings to obtain a "quick fix"

Expected output

- A **redaction list**: each sensitive item found, its category (credential / PAN-PCI / PII / internal topology), and how it was masked.
- A concise **failure summary** (what failed, where in the pipeline, observed symptoms).
- A **ranked root-cause hypothesis** (most-to-least likely) with the evidence behind each.
- **Remediation steps** clearly tagged as AI-suggested vs. self-verified.
- A **human-verification checklist** (e.g., confirm migration is idempotent/reversible, validate downstream service health, check rollback path).
- A **go/no-go** decision with reasoning that accounts for the change freeze.

Evaluation criteria

Area	What good looks like
Data handling	Finds and redacts every sensitive item before AI use; correctly categorizes PAN/PII/secrets/topology
Tool choice	Uses only the approved enterprise AI tool; states this explicitly
Triage quality	Failure summary is accurate and maps to the correct pipeline stage
Reasoning	Root-cause hypotheses are ranked and evidence-backed, not guessed
Verification discipline	Clearly separates AI output from verified fact; lists concrete human checks
Safe remediation	Proposes reversible, gated changes with a rollback path; no direct prod edits

Area	What good looks like
Judgment	Go/no-go reasoning weighs risk vs. the freeze and release window honestly

Scoring rubric (0-5)

Score	Description
0	Pastes raw log (incl. secrets/PAN) into AI, or uses a non-approved tool; treats AI output as fact.
1	Some AI use but misses most sensitive data; no redaction; root cause is a guess.
2	Redacts some items but leaks at least one secret/PII; summary partly correct; no rollback consideration.
3	Redacts all obvious secrets; reasonable failure summary; AI suggestions used but verification is thin.
4	Full redaction with correct categorization; ranked evidence-based hypotheses; clear human-verification checklist; rollback path noted.
5	All of L4 plus: distinguishes AI-suggested vs. verified throughout; sound go/no-go tied to freeze/risk; proposes a reusable redaction step for the team pipeline (raises the bar for others).

Red flags

- Any secret, credential, PAN, PII, or internal hostname/IP sent to AI unredacted.
- Use of a personal or consumer AI account for bank data.
- Accepting AI's root cause without independent verification.
- Allowing AI to generate-and-apply changes directly to pre-prod or prod.
- Disabling the migration or downstream check "to make the pipeline pass."
- Ignoring the change freeze or misrepresenting risk to force a release.
- Hardcoding or echoing the recovered secret back into config instead of rotating it.

Safety/compliance checks

- [] All sensitive data redacted and categorized before any AI interaction.
- [] Only the bank-approved enterprise AI tool used; logged per policy.
- [] Exposed credential/OAuth secret flagged for **rotation**, not reuse.
- [] PAN exposure in logs raised as a potential **PCI-DSS logging violation** to the appropriate owner.
- [] No change applied to pre-prod/prod without human review and an approved rollback path.
- [] Change-freeze policy respected; any exception follows the documented emergency-change process.
- [] AI-assisted decisions recorded for auditability (what was asked, what was verified).

(Inferred from public material: maps to ladder L4-L5 — Effective Prompt User to Workflow AI User — with L6 behavior signaled when the candidate hardens the team pipeline with a reusable redaction step.)

15.x SRE Engineer

Ladder placement (target band): L3 (Basic AI User) through L5 (Workflow AI User). Most production-facing SRE work caps at L5 for this exercise; L7+ behaviors (auto-remediation, agent platforms) are noted as stretch indicators but are **not** required to pass.

Scenario

You are the on-call SRE for the bank's **Payments Gateway** platform. At 02:14, PagerDuty fires: the nightly `payments-settlement` Jenkins pipeline failed on the `deploy-to-prod` stage, and downstream batch settlement is now blocked. SLA for settlement completion is 06:00. You have:

- A 4,000-line Jenkins console log (build #1183).
- Access to the deployment runbook and a non-production GenAI assistant approved by the bank (enterprise tenant, "no-training" contractual flag, internal network only).
- A **public** consumer-grade GenAI chatbot on your personal phone (not approved for bank data).

The log contains, among normal output: a stack trace, a Kubernetes rollout error, a database connection string with embedded credentials, three customer PANs (primary account numbers) printed by a misconfigured debug logger, an internal hostname/IP scheme, and an employee's email in a commit author field.

You decide to use AI to accelerate triage. You must decide **what** to paste, **where**, and **what you cannot trust AI to confirm**.

Task

1. Prepare the log excerpt for AI assistance: identify and redact sensitive data **before** it leaves your terminal.
 2. Use the **approved** AI assistant to: summarize the failure, propose a ranked root-cause hypothesis, and suggest safe remediation steps.
 3. Explicitly separate **AI-suggested** steps from **human-must-verify** steps.
 4. State the rollback/abort plan and the human approval gate before any production change.
 5. Decide whether the public chatbot may be used at all, and justify it.
-

AI usage allowed

Action	Allowed?	Condition
Use approved enterprise assistant for summarization/root-cause	Yes	Only after redaction; verify output against runbook
Paste raw log into public consumer chatbot	No	Contains regulated and internal data; not an approved processor

Action	Allowed?	Condition
Paste redacted log into approved assistant	Yes	Redaction confirmed by human first
Ask AI to draft remediation commands	Yes	Treated as draft; never executed unreviewed against prod
Let AI execute remediation directly	No (for this exercise)	Requires change-control + human approval gate

Expected output

The candidate should produce:

1. **Redaction list** — each sensitive element found and how it was handled (remove / mask / tokenize).
2. **AI prompt(s)** used, showing only sanitized content.
3. **Failure summary** (2-4 sentences, plain language).
4. **Ranked root-cause hypotheses** (most to least likely, with the log evidence for each).
5. **Remediation plan** split into two columns: AI-suggested vs Human-must-verify.
6. **Rollback/abort plan** and the named **human approval gate** (who signs off before prod change).
7. **Tooling decision** — which AI tool was used and why the public chatbot was rejected.

Evaluation criteria

#	Criterion	What "good" looks like
1	Sensitive-data handling	All seven sensitive items found; PANs and credentials removed (not just masked), tool choice justified
2	Correct tool choice	Uses approved tenant; explicitly rejects public chatbot with a data-handling reason
3	Root-cause quality	Hypotheses ranked and tied to specific log evidence, not generic guesses
4	Human-verify discipline	Clearly marks what AI cannot be trusted to confirm (e.g., prod state, actual root cause)
5	Safe remediation	No direct prod execution; commands treated as drafts behind a change/ approval gate
6	Rollback readiness	Concrete abort/rollback path stated before any change
7	Communication	Output is incident-ready: concise, skimmable, hands off cleanly to the next responder

Scoring rubric (0-5)

Score	Level	Description
0	Unsafe	Pastes raw log (PANs/credentials) into any AI, or executes AI commands directly against prod. Auto-fail.
1	Below L3	Uses AI but misses most sensitive data; treats AI output as ground truth; no rollback plan.
2	Approaching L3	Redacts some items, uses approved tool, but redaction incomplete (e.g., misses PANs or creds) or no human-verify split.
3	L3 — Basic AI User	Full redaction, approved tool, sound summary, basic root cause, states rollback exists. Safe but not deeply analytical.
4	L4 — Effective Prompt User	Deliberate prompting (structured, role-set, asks for ranked hypotheses + evidence); clean AI-vs-human split; concrete rollback and approval gate.
5	L5 — Workflow AI User	All of L4, plus embeds AI into the incident workflow (e.g., reusable sanitization step, prompt template, measures triage-time saved) and proposes a guardrail to stop debug-logging of PANs recurring.

Red flags

- Pastes the log (or any fragment containing PANs, credentials, or internal IPs) into the **public** chatbot, or into any AI **before** redaction.
- Masks a PAN partially (e.g., leaves last 4 plus BIN) and calls it safe without confirming it meets the bank's tokenization standard.
- Treats AI's root-cause guess as confirmed and proceeds to remediate without checking prod/runbook.
- Lets AI generate **and** run commands against production without a human approval gate.
- No rollback or abort plan; "we'll fix forward" with no fallback.
- Misses that customer PANs were logged at all — focuses only on the stack trace.
- Over-trusts AI on a regulatory point (e.g., asks AI "is this PCI-compliant?" and treats the answer as authoritative).

Safety/compliance checks

Check	Requirement
Regulated-data redaction	PANs and credentials removed before any AI use; no exceptions. PAN handling must align with PCI-DSS principles — candidate should defer the compliance ruling to a human/control owner, not to AI. (Inferred from public material: PCI-DSS restricts storage/transmission of PANs.)
Approved processor only	Sensitive-adjacent (redacted) content goes only to the bank-approved enterprise tenant with no-training terms; never the public chatbot.

Check	Requirement
Change control	Any production change passes the existing change-management / approval gate; AI output is advisory only.
Human accountability	A named human approves the prod action and owns the outcome; AI is not an approver.
Auditability	The prompt, the sanitized input, and the AI output are logged with the incident ticket for later review.
Incident hygiene	The PAN-logging defect is raised as a separate follow-up (logging hygiene / data-leak remediation), not silently dropped.

Note (separating best practice from recommendation): The redaction-before-AI workflow and human-approval gate are established incident-management and data-handling best practices. The specific tool tiers (approved tenant vs. public chatbot) and the named approval gate are **synthesized recommendations** for this exercise; map them to your organization's actual change-management and approved-tooling registry before use.

15.x Platform Engineer

Scenario

You are a Platform Engineer on the Shared Services team at a regulated retail bank. The nightly CI/CD pipeline for the core payments authorization service (`pay-auth-svc`) failed at the deploy stage. Your team relies on AI assistants (an approved enterprise LLM) to accelerate triage, but the Jenkins console log is large and contains a mix of build output, infrastructure detail, and operational data. The failure is blocking the morning release window, and an SRE is asking for a root-cause summary in the next 30 minutes.

You have been given the raw Jenkins build log. It contains, among normal build output: - A Kubernetes secret value echoed by a misconfigured `kubect1` debug step (a base64-encoded database password). - A production database connection string including host, port, and service account username. - Internal hostnames and private IP ranges for the payments VPC. - A customer PAN (primary account number) that leaked into a stack trace from a failed integration test using non-tokenized test data. - Standard stack traces, Helm chart version mismatch errors, and a failed readiness probe.

Task

1. Use the approved enterprise AI assistant to help triage the failure.
2. Before sending any log content to the AI, identify and redact all sensitive data, and document what you removed and why.
3. Produce a root-cause summary, a ranked list of probable causes, and a safe remediation plan.
4. Explicitly separate AI-suggested conclusions from what a human must verify before acting.
5. State which remediation steps require change approval and rollback gates.

AI usage allowed

Allowed	Not allowed
Use the approved enterprise LLM to summarize sanitized log excerpts, hypothesize root causes, and draft remediation steps.	Pasting raw, unredacted logs into any AI tool.
Use AI to generate redaction patterns/regex and a sanitization checklist.	Sending secrets, PANs, connection strings, or internal network detail to AI.
Use AI to draft (not execute) <code>kubectl</code> /Helm commands for human review.	Using a non-approved/consumer AI tool for any bank data.
Use AI to draft the change ticket and rollback plan.	Letting AI auto-apply changes to production without approval and rollback gates.

Expected output

1. A sanitization record: a table of each sensitive item found, its category, and the redaction action.
2. A one-paragraph root-cause summary written in plain language.
3. A ranked list of probable causes (most to least likely) with supporting evidence from the sanitized log.
4. A remediation plan split into: (a) safe-to-do steps, (b) steps needing change approval, (c) rollback plan.
5. A clearly labeled "Must be human-verified" section.
6. A note on which AI tool was used and confirmation that only sanitized content was shared.

Evaluation criteria

Criterion	What good looks like
Sensitive-data detection	Finds all five categories (secret, connection string, PAN, internal IPs/hostnames, service account) before any AI use.
Redaction discipline	Replaces secrets with placeholders; never pastes raw values; documents each removal.
Root-cause quality	Correctly prioritizes the Helm version mismatch / readiness probe failure over noise.
Human-in-the-loop	Clearly separates AI hypotheses from verified facts; flags what needs human confirmation.
Change control	Identifies which steps need approval and defines a concrete rollback.
Tool governance	Confirms only the approved enterprise LLM was used, on sanitized data only.

Scoring rubric (0-5)

Score	Description
0	Pastes raw log (or any secret/PAN) into AI, or uses a non-approved tool. Automatic fail on safety.
1	Some triage done, but misses sensitive data or sends partial unredacted content to AI.
2	Redacts most sensitive items but misses one category (e.g., the PAN or service account); root cause weak or AI output taken as fact.
3	Redacts all sensitive data; produces a usable root-cause summary; some separation of AI vs. human-verified, but change control or rollback is vague.
4	All sensitive data redacted and documented; correct root cause; clear AI-vs-human separation; identifies approval and rollback gates with minor gaps.
5	All of the above, plus: proposes a durable fix (e.g., stop echoing secrets in CI, enforce tokenized test data, add log-scrubbing in the pipeline); measurable triage-time improvement; ready-to-file change ticket with rollback.

Red flags

- Any raw secret, PAN, connection string, or internal hostname/IP sent to an AI tool.
- Use of a personal or consumer AI account for bank data.
- Treating AI-generated root cause or commands as ground truth without verification.
- Drafting commands that would alter production without an approval or rollback gate.
- No documentation of what was redacted or which tool was used.
- Over-redacting to the point the AI cannot help, then guessing instead of escalating.

Safety/compliance checks

Check	Requirement
Data handling	No PAN, secret, credential, or connection string leaves the bank boundary; PAN handling aligns with PCI-DSS expectations.
Tool approval	Only the bank-approved enterprise LLM is used; consumer tools are prohibited for any internal data.
Least exposure	Only the minimum sanitized excerpt needed for triage is shared with AI.
Change management	Production-affecting steps go through change approval with a documented rollback.
Auditability	Sanitization record and AI-tool usage are logged for later review.
Incident hygiene	The leaked secret is treated as compromised and rotated; the PAN leak is reported per the bank's data-incident process. (Inferred from public material: PCI-DSS and standard incident-response practice.)

Suggested ladder placement (Inferred from public material): Strong performance here maps to **L4-L5** (deliberate prompting embedded in a real triage workflow with measured time

savings). A candidate who also proposes durable pipeline guardrails (log scrubbing, tokenized test data, secret-rotation automation) and codifies them for the team trends toward **L6-L7**.

15.x Observability Engineer

Ladder fit: This test targets **L3-L5** (Basic AI User to Workflow AI User), with stretch indicators for **L6/L7** (Power User / Automation Contributor). It is built for an Observability Engineer who owns metrics, logs, traces, dashboards, and alerting for production banking systems.

Scenario

It is 02:40 on a weekday. The bank's **real-time payments service** has triggered a latency SLO burn-rate alert. The on-call Observability Engineer is pulled in to triage. The signals available are:

- A **Prometheus/Grafana** dashboard showing p99 latency on the `payments-api` rising from 80ms to 1.9s over 20 minutes, correlated with a rising 5xx rate.
- A **distributed trace** (OpenTelemetry/Jaeger) for a slow request showing time concentrated in a downstream `customer-profile` service call.
- An **application log excerpt** (~600 lines) containing stack traces, connection-pool warnings, and request/response payloads.

The log excerpt contains live customer data: full PANs (card numbers), national ID numbers, customer names, account balances, an internal service auth bearer token, and a database connection string with an embedded password.

The engineer is asked to use an approved enterprise GenAI assistant to **accelerate triage**: summarize the failure, propose a root cause, and suggest a safe remediation — without leaking sensitive data and without taking any unverified production action.

Task

1. Decide **what data may and may not be sent** to the AI assistant. Redact or synthesize before any paste.
2. Use AI to **summarize the failure** (symptom, blast radius, timeline) from the sanitized signals.
3. Use AI to **propose a ranked root-cause hypothesis** linking the latency spike, the trace hotspot, and the log warnings.
4. Use AI to **suggest safe remediation options**, each labeled with risk level and rollback path.
5. Explicitly state **what must be human-verified** before any change reaches production.
6. Recommend a **follow-up observability improvement** (e.g., a new alert, SLI, dashboard panel, or trace attribute) to detect this class of failure earlier.

AI usage allowed

Activity	Allowed?	Condition
Summarizing sanitized logs/traces/metrics	Yes	Only the approved enterprise AI tool; sensitive data removed first
Drafting PromQL / log queries / alert rules	Yes	Output reviewed and tested in non-prod before use
Proposing root-cause hypotheses	Yes	Treated as hypotheses, not facts; verified against real signals
Drafting incident summary / comms	Yes	Reviewed by human before posting to stakeholders
Pasting raw logs with PANs/IDs/tokens/secrets	No	Hard violation — see Red flags
Letting AI execute commands against production	No	No auto-remediation without approval and rollback gates
Using a public/consumer AI tool	No	Only sanctioned, data-governed tooling

Expected output

A short triage artifact (roughly one page) containing:

1. **Sanitization note** — list of sensitive fields identified and how each was handled (removed, masked, or replaced with a placeholder), plus an explicit statement of what was not sent to the AI.
2. **Failure summary** — symptom, affected service(s), user-facing impact, and a 3-5 point timeline.
3. **Ranked root-cause hypotheses** — at least two, each with the evidence supporting it and the signal needed to confirm or rule it out.
4. **Remediation options table** — each option with action, risk level, expected effect, and rollback path.
5. **Human-verification checklist** — the specific facts/actions that must be confirmed by a person before any production change.
6. **Follow-up observability improvement** — one concrete, measurable detection or signal change.

Evaluation criteria

#	Criterion	What good looks like
1	Data handling first	Identifies all sensitive fields (PAN, national ID, name, balance, bearer token, DB password/connection string) and sanitizes before any AI use

#	Criterion	What good looks like
2	Correct sanitization method	Masks or replaces with placeholders while preserving diagnostic value (e.g., keeps error types, timing, status codes, host roles)
3	Accurate summary	Symptom, blast radius, and timeline match the signals; no invented detail
4	Sound root cause	Hypotheses logically link metrics + trace + logs (e.g., customer-profile connection-pool exhaustion causing upstream latency/5xx)
5	Safe remediation	Options are reversible, scoped, and ranked by risk; no blind restarts of prod or schema changes without gates
6	Human-in-the-loop	Clearly separates AI suggestions from verified fact; names what a human must confirm
7	AI output skepticism	Treats AI root cause as a hypothesis; cross-checks against actual dashboards/traces
8	Detection improvement	Proposes a measurable early-warning signal (e.g., pool-saturation alert, downstream-dependency SLI)

Scoring rubric (0-5)

Score	Level	Description
0	No exposure (L0/L1)	Cannot or would not use AI for triage; or pastes raw sensitive logs with no awareness of risk
1	Aware (L2)	Knows sensitive data must not be shared but cannot perform a usable triage; sanitization is vague or incomplete
2	Basic user (L3)	Sanitizes the obvious fields and gets a generic AI summary, but misses some sensitive data or doesn't verify the root cause against real signals
3	Effective prompt user (L4)	Cleanly sanitizes all sensitive fields, prompts deliberately, gets an accurate summary and a plausible ranked root cause, and states human-verification steps
4	Workflow user (L5)	All of the above plus reversible remediation options with rollback paths, AI-output skepticism, and a measurable follow-up detection improvement; integrates metrics + traces + logs coherently
5	Power user / automation contributor (L6/L7)	Produces a reusable, safe pattern: a sanitization/redaction step others can reuse, a tested query/alert, and a proposal for gated (approval + rollback) automation — while keeping production actions human-approved

Pass threshold for the role: 3 or higher. Any unmitigated sensitive-data leak caps the score at **0** regardless of triage quality.

Red flags

- Pastes raw logs containing **PANs, national IDs, customer names, account balances, bearer tokens, or DB credentials** into any AI tool.
- Uses a **public/consumer AI tool** instead of the sanctioned enterprise assistant.
- Treats the AI's root cause as **confirmed fact** and acts on it without checking real signals.
- Proposes **production changes without a rollback path** (e.g., "just restart the prod DB").
- Suggests the AI **auto-execute** remediation against production with no approval gate.
- Masks the symptom (e.g., raising the alert threshold to silence it) instead of addressing cause.
- Invents log lines, metric values, or trace spans not present in the source ("hallucination accepted as evidence").
- Strips so much context during sanitization that the diagnosis becomes meaningless (over-redaction), or leaves partial identifiers (e.g., last 4 of PAN plus name plus balance) that re-identify a customer.

Safety/compliance checks

Check	Requirement
Sensitive data minimization	No PAN, PII (national ID, name), account balance, secret, or token leaves the bank's controlled boundary into AI. Confirm via a pre-send checklist.
Approved tooling only	AI assistant must be the enterprise, data-governed instance — not a personal/consumer account.
PCI-DSS alignment (Inferred from public material)	Cardholder data (PAN) must not be exposed to unapproved systems; masking/truncation must follow the bank's PCI controls.
Secret rotation	If a bearer token or DB password was present in logs, flag it for rotation and report the leakage path — logging secrets is itself an incident.
Change management	Any remediation reaching production goes through approval and rollback gates; no direct AI-driven prod actions.
Audit trail	Record what was sent to the AI, what was returned, and how it informed the decision, for incident review.
Human accountability	A named engineer owns the final remediation decision; AI output is advisory only.

Note: PCI-DSS and secure-logging practices referenced here are public, widely adopted industry standards. This test does not assume any specific internal bank ladder or control beyond those public standards; map the checks above to your organization's actual control catalog before use.

15.x DataOps Engineer

Scenario

A nightly batch ETL pipeline that loads transactional data from the core banking system into the regulatory-reporting data warehouse has failed. The on-call DataOps Engineer is paged at 02:10. The pipeline orchestrator (e.g., Airflow/Jenkins) shows a failed run for the job `core_txn_to_regulatory_dwh`. The failure blocks the morning AML (Anti-Money Laundering) and liquidity-reporting refresh, which has a regulatory delivery deadline of 09:00.

The engineer wants to use an internal/approved GenAI assistant to triage the failure faster. The raw failure log contains stack traces, SQL fragments, connection strings, and sampled rows of failed records, some of which include customer PII (names, national ID numbers, account numbers, IBANs) and transaction details.

The engineer must produce a triage summary, propose a safe remediation, and decide what may and may not be shared with the AI tool.

Task

1. Use the approved AI assistant to summarize the failure and identify the most likely root cause from the (sanitized) log.
2. Propose a remediation plan with explicit safety gates (what runs in non-prod first, what needs approval, rollback steps).
3. State clearly what must be human-verified before any production change.
4. Identify and redact all sensitive data before any content is sent to the AI tool, and document what was removed and why.
5. Write a short incident note suitable for the change-management ticket and the data-governance log.

This task targets ladder levels **L4-L7**: deliberate prompting (L4), embedding AI in an operational workflow with measured time savings (L5), setting safe norms for the team (L6), and proposing approval/rollback-gated automation (L7).

AI Usage Allowed

Allowed	Not allowed
Pasting sanitized log excerpts (PII/secrets removed or tokenized) into the approved internal AI tool	Pasting raw logs containing PII, account numbers, IBANs, national IDs, or live credentials
Asking the AI to explain stack traces, summarize errors, and suggest candidate root causes	Letting AI directly execute commands against production without human approval
Asking the AI to draft remediation steps, rollback scripts, and the incident note	Treating AI output as authoritative without verifying against schema, runbook, and data lineage
Using AI to generate redaction/regex patterns to help sanitize logs	Sending connection strings, tokens, or keys to any AI tool

Expected Output

The candidate should produce all five artifacts:

1. **Failure summary** (3-6 lines): what failed, where in the DAG/job, and the surfaced error class.
2. **Root-cause hypothesis** with at least one alternative, each with a confidence level and how to confirm it.
3. **Remediation plan** with non-prod-first sequencing, explicit approval gate, and rollback steps.
4. **Human-verification list**: items that must be checked by a person before production execution (e.g., schema change impact, row counts, downstream reconciliation, regulatory deadline impact).
5. **Data-handling record**: a table of sensitive fields found, the action taken (redact/tokenize/drop), and the rationale, plus a one-line statement confirming no PII/secrets were sent to the AI.

Evaluation Criteria

Dimension	What good looks like
Data handling	Identifies all sensitive fields, sanitizes before AI use, documents it
Diagnostic quality	Plausible root cause tied to actual log evidence, not generic guessing
Safety gating	Non-prod-first, approval gate, and tested rollback are explicit
Human-in-the-loop	Clearly separates AI suggestions from what a human must verify
Operational fit	Output usable in a real change ticket and governance log
Compliance awareness	Acknowledges regulatory deadline, audit trail, and data-residency rules

Scoring Rubric (0-5)

Score	Description
0	Pastes raw log (with PII/secrets) into AI, or relies on AI output with no verification. Unaware of data risk. (L0-L1 behavior)
1	Knows PII should not be shared but cannot reliably identify or redact it; no real remediation. (L2)
2	Sanitizes the obvious fields and gets a generic AI summary; remediation lacks safety gates or rollback. (L3)
3	Thorough redaction with documentation; deliberate prompting yields a credible root cause; remediation has a rollback but weak approval/non-prod gating. (L4)
4	All five artifacts present and coherent; AI embedded in workflow with a human-verification list and approval + rollback gates; notes time saved vs. manual triage. (L5-L6)

Score	Description
5	As above, plus proposes a reusable, guardrailed sanitize-and-triage automation (e.g., a pre-AI redaction step in the runbook) with approval and rollback controls, and shares the norm with the team. (L7)

Red Flags

- Pastes the raw log, a connection string, or any credential into the AI tool.
- Customer PII (national IDs, IBANs, account numbers) appears in any AI prompt.
- Proposes running an AI-suggested fix directly in production with no approval or rollback.
- Accepts the AI root cause without checking it against the actual log, schema, or lineage.
- Ignores the 09:00 regulatory deadline or fails to escalate when at risk.
- Uses an unapproved/public AI tool ("shadow AI") for bank data.
- No audit trail: cannot show what was redacted or what AI was asked.

Safety / Compliance Checks

Check	Pass condition
Sensitive-data sanitization	No PII, account numbers, IBANs, national IDs, or secrets in any AI prompt; redaction documented
Approved tooling only	Uses the bank's sanctioned internal AI tool, not a public/consumer service
Data residency	Confirms data and AI processing stay within permitted jurisdiction/ environment
Human approval gate	No production change without documented human approval (change-management record)
Rollback readiness	Tested rollback path exists before any remediation runs
Audit trail	Prompt inputs, AI outputs, and redaction actions are logged for review
Deadline / escalation	Regulatory 09:00 deadline tracked; escalation path triggered if at risk
Least exposure	Only the minimum sanitized excerpt needed for triage is shared, not the full log

15.x QA Automation Engineer

Target ladder level for "pass": L4 (Effective Prompt User) with stretch indicators toward L5 (Workflow AI User). The test is designed so that an L2-L3 candidate can demonstrate baseline safety, while L5+ candidates reveal workflow and measurement maturity.

Scenario

You support automated regression testing for a retail banking web application. Overnight, the **Jenkins pipeline** `core-banking-regression` failed at the `integration-tests` stage. Twelve of

340 Selenium/REST API tests failed. The QA lead has asked you to triage quickly so the release train is not blocked.

The raw pipeline log is large and contains:

- Stack traces and assertion failures
- A test fixture that logs a **real customer's PAN (card number), full name, national ID, account number, and a session bearer token** captured during a failed payment-flow test
- Internal hostnames, database connection strings (with embedded credentials), and an internal Jira ticket reference

You are permitted to use the bank's **approved internal GenAI assistant** (enterprise tenant, no training on inputs, data stays in the bank's environment). Public/consumer GenAI tools are **not** approved for any work data.

Task

Using the approved AI assistant, produce a triage summary that:

1. Summarizes the 12 failures and groups them by likely failure type (product defect vs. test/environment flakiness vs. data setup).
2. Identifies the most probable root cause(s) with the supporting log evidence.
3. Proposes safe remediation steps, clearly separating "safe to action now" from "must be human-verified before action."
4. States explicitly what a human must verify (e.g., whether a failure reflects a real defect before reopening a release).
5. **Before** any log content is sent to the AI assistant, identifies every piece of sensitive data in the log and how it must be handled (removed, masked, or tokenized).

AI usage allowed

Allowed	Not allowed
Approved enterprise GenAI assistant for summarizing sanitized logs, drafting root-cause hypotheses, and drafting remediation steps	Pasting raw, unsanitized logs into any tool
Using AI to generate masking/redaction regex or scripts (then human-reviewed)	Any consumer/public AI tool (ChatGPT free, etc.) for work data
Using AI to draft the triage summary structure and Jira comment text	Letting AI auto-merge, auto-close tickets, or trigger a re-run without human approval
Using AI to suggest which tests are likely flaky based on patterns	Sending PAN, national ID, tokens, or credentials to AI even on the approved tenant

Expected output

A candidate at the pass bar should deliver:

1. **A pre-submission sensitive-data register** listing each sensitive element found and the chosen action:

Sensitive element	Example in log	Handling action	Rationale
PAN (card number)	4111 11** **** 1111	Remove entirely	PCI-DSS; never send to AI even on approved tenant
National ID	national_id=...	Remove entirely	PII / regulatory
Full customer name	name=...	Remove or replace with CUSTOMER_A	PII
Account number	acct=...	Mask (last 4 only) or tokenize	PII / traceability
Session bearer token	Authorization: Bearer ...	Remove and rotate/revoke	Live credential; security incident
DB connection string + creds	jdbc:...user=...password=...	Remove and rotate	Credential exposure
Internal hostnames	host-int-...	Replace with generic placeholder	Reduce internal attack surface
Jira ticket ref	BANK-1234	May keep (low sensitivity)	Operational context

1. **A sanitized log excerpt** (or description of how it was sanitized) confirming nothing above the agreed threshold was sent to the AI.
2. **A grouped failure summary** (defect / flaky / data-setup) with counts.
3. **Root-cause hypotheses** tied to specific (sanitized) log evidence.
4. **A remediation plan** split into "safe now" vs. "human-verify-first."
5. **An explicit human-verification list** and a note that the AI output was reviewed, not trusted blindly.
6. A note that the live bearer token must be reported as a **potential credential-exposure incident** (rotation/revocation), not just redacted.

Evaluation criteria

Dimension	What good looks like
Data handling (weighted highest)	Catches all sensitive elements, especially the live token and credentials; chooses correct action per element; sanitizes before sending; uses only the approved tool

Dimension	What good looks like
Incident recognition	Recognizes the exposed bearer token and DB credentials as a security incident requiring rotation, not just redaction
Triage quality	Correctly separates defects from flakiness; root causes are evidence-based, not guesses
Prompt technique	Gives the AI clear role, context, and constraints; iterates rather than accepting first output
Human-in-the-loop	Clearly marks what AI suggested vs. what a human must verify before any release decision
Tool choice & rationale	Uses approved enterprise tenant; can explain why public tools are prohibited
Communication	Output is clear enough for the QA lead to act on

Scoring rubric (0-5)

Score	Description
0	Pastes raw log (including PAN/token/creds) into any AI tool, or uses an unapproved/public tool. Automatic fail regardless of triage quality.
1	Uses approved tool but misses one or more high-risk elements (PAN, token, or credentials) in sanitization. Triage may be present but data handling is unsafe.
2	Sanitizes the obvious PII but treats the bearer token/DB creds only as "redact," missing the credential-exposure incident angle. Triage is shallow or mostly AI-verbatim with little verification.
3	Sanitizes all sensitive elements correctly and uses the approved tool. Produces a usable grouped triage and root-cause hypotheses. Marks some human-verification needs. Meets the L3-L4 pass bar.
4	All of the above, plus: flags the token/creds as an incident requiring rotation; clearly separates "safe now" vs. "human-verify"; demonstrates deliberate prompting (role/context/constraints) and at least one iteration to improve output. Solid L4.
5	All of the above, plus: builds a reusable, reviewable sanitization step (e.g., a masking script/regex others can run), measures or estimates time saved, and proposes embedding sanitization into the CI log-handling workflow so this is repeatable and auditable. Shows L5 workflow thinking.

Pass threshold: 3. Scores of 0-1 are disqualifying on safety grounds, independent of triage skill.

Red flags

- Pastes any unsanitized log content into an AI tool, or uses a consumer/public AI tool for bank data.
- Treats the live bearer token or DB credentials as "just redact" and does not raise a credential-exposure/rotation concern.
- Accepts the AI's root-cause claim as fact and recommends reopening or blocking the release without independent human verification.
- Lets AI trigger a pipeline re-run, close tickets, or merge changes without human approval.
- Cannot explain why the approved enterprise tenant is safer than a public tool (data residency, no training on inputs).
- "Over-trusts" AI: copies remediation steps verbatim into production scripts without review.
- Masks PAN but leaves national ID, account number, or internal connection strings intact.
- Sends "just a small snippet" containing a secret because it seemed low-risk.

Safety/compliance checks

Check	Requirement
Tool approval	Only the bank's approved enterprise GenAI tenant is used; public tools confirmed unused
Data minimization	Only sanitized, minimum-necessary log content is sent to AI
PCI-DSS	No PAN/cardholder data sent to AI under any circumstance, even on approved tenant
PII handling	National ID, name, account number removed/masked/tokenized per policy before submission
Credential exposure	Live bearer token and DB credentials reported through the security incident process for rotation/revocation, not silently redacted
Human approval gates	No release, ticket, merge, or pipeline action taken on AI output alone; a named human signs off
Auditability	Sanitization step and what was sent to AI are recorded so the triage is reproducible and reviewable
Output verification	AI-generated root causes and remediation are human-verified before influencing any release decision

15.x Security Engineer

Ladder placement: This test targets **L3-L5** (Basic AI User → Workflow AI User), with stretch indicators for **L6**. It assumes the engineer already meets L2 (AI awareness and data-handling rules). Roles above L6 are evaluated separately via solution-design and governance exercises.

Scenario

You are an on-call Security Engineer at a regulated retail bank. At 09:14 the SIEM raises a medium-severity alert: a public-facing web application firewall (WAF) logged a burst of suspicious requests against the customer onboarding API. You are handed a 600-line bundle to triage quickly:

- Raw WAF and reverse-proxy access logs (full request lines, headers, source IPs)
- An application stack trace from the onboarding service
- A snippet of a `terraform plan` diff for the API's security group
- An extract from a customer record that appears in one log line (name, national ID, masked PAN, email)

Leadership wants a triage summary within 30 minutes. You may use the bank's **approved internal GenAI assistant** (data classified up to "Internal"; **not** approved for "Confidential/Restricted" or customer PII). Public/consumer AI tools are prohibited for any work data.

Task

1. Use AI to **summarize** the incident from the log bundle and produce a plain-language triage narrative.
 2. **Identify the likely root cause** (attack pattern vs. misconfiguration vs. false positive) and the affected component.
 3. Propose **safe remediation** steps, separated into "contain now" and "fix properly," each tagged with required approvals (change ticket, peer review, security lead sign-off).
 4. State explicitly **what a human must verify** before any action is taken.
 5. **Before prompting AI**, identify and redact all sensitive data that must not be sent to the assistant, and document what you removed and why.
-

AI usage allowed

Activity	Allowed?	Condition
Summarize sanitized logs	Yes	PII and secrets removed; data ≤ "Internal"
Classify attack pattern / suggest detections	Yes	On sanitized excerpts only
Draft remediation and rollback steps	Yes	Output treated as draft, human-verified
Paste raw customer record (name, national ID, PAN)	No	Restricted PII — never sent to AI
Paste real source IPs, internal hostnames, secrets, tokens	No	Redact or tokenize first

Activity	Allowed?	Condition
Auto-apply remediation (firewall/SG change) from AI output	No	Requires change ticket + human approval + rollback
Use a public/consumer AI tool	No	Policy violation regardless of content

Expected output

The candidate should produce:

1. **Redaction log** — a short table listing each sensitive item found, its classification, and the action taken (remove / tokenize / mask) before any AI use.
2. **Sanitized prompt** — the actual text/excerpt submitted to the approved assistant, demonstrating that PII, secrets, and internal identifiers are gone.
3. **Triage summary** — 5–10 lines: what happened, affected component, severity assessment, confidence level.
4. **Root-cause hypothesis** — stated as a hypothesis with supporting evidence, not a certainty.
5. **Remediation plan** — split into Contain Now vs. Fix Properly, each with owner, approval gate, and rollback note.
6. **Human-verify checklist** — explicit list of claims/actions that must be confirmed by a person before execution.

Evaluation criteria

#	Criterion	What "good" looks like
1	Data handling first	Redacts PII/secrets before the first prompt; documents it
2	Correct tool choice	Uses approved internal assistant only; rejects public tools
3	Prompt quality	Clear, scoped prompts that yield useful, structured output (L4 signal)
4	Technical accuracy	Root cause and remediation are plausible and correct for the evidence
5	Hypothesis framing	States confidence; distinguishes attack vs. misconfig vs. false positive
6	Approval & rollback discipline	No change applied without ticket, review, and rollback path
7	Human verification	Clearly separates AI draft from what must be human-confirmed
8	Workflow thinking (stretch)	Suggests a repeatable sanitize→summarize→triage flow or detection rule (L5/L6)

Scoring rubric (0-5)

Score	Level	Description
0	No exposure / unsafe	Pastes raw PII or secrets into AI, or uses a prohibited tool. Automatic fail regardless of technical quality.
1	Aware but unsafe	Knows AI could help but redacts inconsistently, or sends internal hostnames/IPs without thinking.
2	Basic user	Redacts the obvious PII, gets a usable summary, but accepts AI output with little verification; remediation vague.
3	Safe routine user (meets L3)	Clean redaction with a documented log, sound triage summary, plausible root cause, verifies key claims. Solid baseline.
4	Effective prompt user (meets L4)	All of L3 plus deliberate, well-structured prompting; remediation split into contain/fix with approval gates and rollback; clear human-verify list.
5	Workflow user (meets L5/L6)	All of L4 plus a reusable sanitization/triage workflow or proposed detection rule, measurable time savings, and norms others can follow. Lifts the team.

Pass threshold: 3 of 5. Any score of 0 is an automatic fail for the exercise.

Red flags

- Pastes the raw customer record, national ID, or PAN into any AI tool. (Automatic fail.)
- Sends real source IPs, internal hostnames, secrets, API tokens, or the raw `terraform` diff without redaction.
- Uses a public/consumer AI assistant for bank work data.
- Treats AI output as ground truth — applies a firewall or security-group change directly from the AI's suggestion.
- No rollback plan, no change ticket, or no human sign-off before proposing to act.
- Cannot tell the difference between a confident AI answer and a verified fact.
- Over-shares the incident externally or in unapproved channels.
- Lets the 30-minute clock justify skipping redaction ("no time to sanitize").

Safety / compliance checks

Check	Requirement	Pass condition
Data classification	No data above "Internal" sent to AI	Redaction log shows all Confidential/Restricted items removed
PII protection	Customer name, national ID, PAN, email never reach AI	Verified in the sanitized prompt

Check	Requirement	Pass condition
Secrets hygiene	No tokens, keys, internal hostnames/IPs sent	Tokenized or removed before prompting
Approved tooling	Only the bank's sanctioned assistant used	No public/consumer tool in evidence
Change control	Remediation gated by ticket + peer review + security sign-off	Approval gates named in the plan
Reversibility	Every proposed change has a rollback path	Rollback noted per action
Human accountability	A named person verifies before any action	Human-verify checklist present and owned
Auditability	AI use and decisions are documented	Redaction log and prompt retained for the incident record

(Inferred from public material): Specific classification tiers ("Internal/Confidential/Restricted"), approval gates, and the "approved internal assistant" model reflect common regulated-banking control patterns (e.g., data classification policies, change-management and model-risk practices). They are illustrative defaults, not any one institution's published HR ladder or internal policy. Adapt names and thresholds to your organization's actual standards.

15.x Release Manager

Scenario

You are the Release Manager coordinating a Saturday-night production deployment for the bank's retail mobile-banking platform. The release covers a payment-services microservice and a customer-onboarding (KYC) module. The Jenkins CI/CD pipeline fails at the integration-test stage, and the deployment window closes in 90 minutes. The pipeline log is 4,000 lines and includes stack traces, environment variables, database connection strings, a test fixture containing sample customer PII (names, national IDs, account numbers), and an internal API token printed by a misconfigured debug flag. You want to use the bank's approved internal GenAI assistant to accelerate triage, but you must decide what can and cannot be shared, and you must produce a go/no-go recommendation that a human approver can act on.

Task

1. Prepare the Jenkins log for AI assistance by removing or masking sensitive data before any content leaves a controlled environment.
2. Use the approved GenAI tool to summarize the failure, identify the probable root cause, and propose safe remediation options.
3. Clearly separate AI-generated suggestions from facts that must be human-verified.
4. Produce a go/no-go release recommendation with a rollback plan and a record of what was shared with the AI tool.

AI usage allowed

Allowed	Not allowed
Approved internal/enterprise GenAI tool only	Public/consumer AI tools (free ChatGPT, etc.)
Sanitized log excerpts, error messages, stack traces with identifiers masked	Raw logs containing PII, secrets, tokens, or connection strings
Drafting remediation steps, summarizing failures, generating rollback checklists	Pasting customer national IDs, account numbers, or credentials
Generating communication drafts for stakeholders	Letting AI auto-approve or auto-execute the deployment

Expected output

A short release-decision package containing:

- A 5-10 line plain-language failure summary.
- A stated probable root cause, labeled as a hypothesis until confirmed.
- 2-3 remediation options with trade-offs (fix-forward vs. rollback vs. defer).
- An explicit "Must be human-verified" list (e.g., DB migration reversibility, payment reconciliation, KYC data integrity).
- A go/no-go recommendation with reasoning tied to the closing window.
- A rollback plan with trigger conditions and owner.
- A data-handling note listing exactly what was masked and what was shared with the AI tool.

Evaluation criteria

Area	What good looks like
Data handling	Identifies and removes/masks all PII, secrets, tokens, and connection strings before using AI; uses approved tool only
Diagnostic quality	Failure summary is accurate; root cause is plausible and clearly marked as a hypothesis
Human-in-the-loop	Separates AI suggestions from human-verified facts; no auto-approval or auto-deploy
Decision quality	Go/no-go is justified, time-boxed, and risk-aware; rollback plan is concrete with owners and triggers
Traceability	Records what was shared with AI and what was masked, suitable for audit

Scoring rubric (0-5)

Score	Description
0	Pastes raw log (PII/secrets included) into AI, or uses an unapproved tool; no human verification
1	Uses AI but misses key sensitive data; accepts AI output as fact; no rollback plan

Score	Description
2	Masks some sensitive data; basic summary; weak go/no-go reasoning; minimal verification
3	Masks all obvious PII/secrets; sound summary and root-cause hypothesis; states a go/no-go with a rollback plan
4	Thorough masking with rationale; clear AI-vs-human separation; time-boxed decision; concrete rollback with owners/triggers
5	All of L4 plus a documented, auditable data-handling record; verification checklist tied to payment/KYC risk; proposes a reusable sanitization step for future releases

Red flags

- Pastes the full raw log, connection strings, API token, or customer PII into any AI tool.
- Uses a public/consumer AI tool for bank data.
- Treats the AI's root cause as confirmed fact and deploys without human sign-off.
- Lets AI trigger or approve the deployment.
- No rollback plan, or a rollback plan with no owner or trigger conditions.
- Proceeds past the window with no decision recorded.
- Ignores payment-reconciliation or KYC-data-integrity implications.

Safety/compliance checks

Check	Requirement
Approved tooling	Only the bank's sanctioned GenAI tool is used; no data leaves controlled environments
Data minimization	Only the minimum sanitized content needed for triage is shared
Secret hygiene	Exposed API token is treated as compromised and rotated; debug flag misconfiguration logged as a defect
PII protection	Customer national IDs, names, and account numbers are masked or removed before AI use
Audit trail	A record of prompts, shared content, and the final decision is retained for review
Human authority	A named human approver makes the final go/no-go; AI is advisory only
Change control	Decision aligns with the bank's change-management and segregation-of-duties policy

15.x DevOps/Technical Manager

Target ladder level for this test: L4-L5 (Effective Prompt User to Workflow AI User), with stretch indicators for L6-L7 (setting safe norms, proposing approval/rollback gates). This test measures whether a DevOps/Technical Manager can use GenAI to accelerate incident triage without leaking sensitive data and without deferring engineering judgment to the model.

Scenario

You manage the CI/CD and release engineering function for the core banking platform. At 09:14 on a release day, the **Jenkins production-deploy pipeline** for the payments service fails at the database-migration stage. The on-call engineer pastes you the full console log and asks for help. The pipeline must be unblocked safely, and a change record must be updated before the next deploy window closes at 11:00.

The raw Jenkins log contains, among normal build output:

- A **database connection string** with embedded username and password
(jdbc:postgresql://prod-pay-db-01.internal:5432/payments?user=svc_deploy&password=...)
- An **internal hostname/IP scheme** for production payment servers
- A **customer PAN fragment** that leaked into a debug log line from a test fixture (...card ending 4921, acct 7781)
- An **API token** for the artifact registry
- A **stack trace** pointing to a failed Flyway migration (V47__add_settlement_index.sql) timing out due to a lock on a large table

You have access to an approved, enterprise-tier GenAI assistant (data not used for training, contractual confidentiality in place) for log analysis and remediation drafting.

Task

Using the approved GenAI assistant, produce an incident-triage package:

1. **Sanitize** the log before sending any portion to the AI: identify and redact every piece of sensitive data, and state what you removed and why.
 2. **Summarize** the failure in plain language for a non-technical change-approval board.
 3. **Identify the probable root cause** and rank alternative causes.
 4. **Propose a safe remediation** including a rollback path and the deploy/no-deploy recommendation for the 11:00 window.
 5. **Explicitly separate** what the AI suggested from what a human must verify before any production action.
 6. Note any **norm or guardrail** you would add so the team handles the next incident more safely (stretch indicator).
-

AI usage allowed

Allowed	Not allowed
Pasting sanitized log excerpts into the approved enterprise assistant	Pasting raw logs containing credentials, tokens, PAN/ account data, or internal host schemes
Asking the AI to summarize, hypothesize root cause, and draft remediation steps	Using a personal/consumer AI account or any tool not on the approved list

Allowed	Not allowed
Asking the AI to draft the change-board summary and rollback plan	Letting the AI text be applied to production without human review
Using AI to suggest what to verify	Treating AI output as authoritative on production state or as the change-record approver

Expected output

A triage package containing:

Section	What good looks like
Sanitization note	Lists each sensitive item found (connection string, password, API token, PAN/account fragment, internal hostnames/IPs) and the redaction applied; confirms PAN handling escalated per data-incident policy
Plain-language summary	3-5 sentences a non-technical approver understands; states impact, blast radius, and that no customer data was exposed externally
Root cause + alternatives	Primary: Flyway migration V47 timed out on a lock against a large table. Ranked alternatives (lock contention from concurrent job, undersized statement timeout, index build on hot table) with how to confirm each
Remediation + rollback	Safe options (run migration in low-traffic window with CONCURRENTLY /online index, raise lock timeout cautiously, split migration); explicit rollback path; clear deploy/no-deploy call for 11:00
Human-verify list	Concrete items only a human can confirm (current DB lock state, replication lag, change-record approval, blast radius sign-off)
Guardrail proposal	E.g., pre-send log scrubber, secrets out of build logs, PAN never in test fixtures

Evaluation criteria

Criterion	What the evaluator checks
Data protection first	Candidate sanitizes before any AI interaction, not after; catches all five sensitive item types
PAN/account handling	Recognizes the leaked card/account fragment is a data-incident trigger , not just a redaction task, and says so
Correct root-cause reasoning	Connects the timeout/lock evidence to a credible migration cause; does not just parrot AI
Safe remediation	Proposes reversible steps with a rollback path; does not recommend blind retry or disabling safety checks

Criterion	What the evaluator checks
Human-in-the-loop clarity	Cleanly separates AI suggestions from human-verified facts about live production
Sound deploy decision	Makes a defensible deploy/no-deploy call tied to the 11:00 constraint and risk
Prompt quality	Gives the AI structured, scoped prompts; does not over-share context

Scoring rubric (0-5)

Score	Level	Description
0	No exposure / unsafe	Pastes raw log (or would) into AI; misses credentials and PAN; treats AI output as the fix. Maps to L0-L1.
1	Aware but weak	Knows AI shouldn't get secrets but redacts incompletely (e.g., catches password, misses PAN or internal hosts); no rollback thinking. Maps to L2.
2	Basic safe use	Sanitizes most items and verifies AI output on low-risk points, but misses PAN-as-incident and gives a vague remediation. Maps to L3.
3	Effective	Full sanitization, correct root cause, coherent remediation with rollback, clear human-verify list, defensible deploy call. Solid prompting. Maps to L4 (target) .
4	Workflow-grade	All of the above plus measures the triage as a repeatable workflow, escalates PAN per policy, and ties remediation to change-management gates. Maps to L5 (target stretch) .
5	Norm-setting	Adds durable guardrails (automated pre-send scrubber, secrets removed from build logs at source, PAN-in-fixtures eliminated), defines team norms, and proposes approval/rollback automation. Maps to L6-L7.

Red flags

Red flag	Why it matters
Pastes the raw log (with connection string, token, or PAN) into any AI	Direct data-leak / potential cardholder-data exposure
Treats the leaked PAN/account fragment as "just redact it" and moves on	Misses a reportable data-handling incident
Recommends "just retry the deploy" or disabling the lock/statement timeout	Unsafe production action with no root-cause confidence
Presents AI root-cause as fact without human verification of live DB state	Over-trust in model; production decision on unverified data

Red flag	Why it matters
Uses a personal or non-approved AI tool "to move faster"	Shadow-AI / contractual and confidentiality breach
Recommends deploying at 11:00 with no rollback path	Change-management and operational-risk failure
Over-shares full system context the AI doesn't need	Unnecessary exposure of internal architecture

Safety / compliance checks

Check	Requirement
Approved tooling only	GenAI assistant must be on the enterprise-approved list with no-training / confidentiality terms; no consumer accounts
Data minimization	Only sanitized, scoped log excerpts leave the environment; no credentials, tokens, internal host schemes, PAN, or account data
Cardholder-data incident path	Any PAN/account leakage into logs is treated as a potential data-handling incident and escalated per policy (PCI-DSS-aligned), not silently redacted
Human authority on production	No production change, retry, or rollback executed solely on AI output; change-record approval and live-state verification remain human-owned
Auditability	The triage package, sanitization actions, and deploy/no-deploy decision are recorded in the change record for audit
Secrets management	Credentials and tokens appearing in build logs are flagged for removal at source (secrets manager / masked logging)

Note: (Inferred from public material) The PAN-handling and audit requirements above reflect widely published standards such as PCI-DSS and common change-management practice; they are not drawn from any specific institution's internal HR ladder or private procedures.

16. Promotion and Career Path Guidance

This section explains how to put the AI capability ladder (L0-L10) to work in day-to-day people decisions. It is written so an HR partner, an engineering manager, or a technical lead can apply it consistently, defensibly, and in line with the controls expected in a regulated financial-services environment.

16.1 How to use the framework across HR processes

Process	How to use the ladder	What "good" looks like
Annual review	Assess current level with evidence; compare against the expected minimum for the person's role and seniority.	A level rating backed by 2–3 concrete artifacts, not a self-claim.
Promotion readiness	Require sustained performance at the target level for at least one review cycle before promoting.	Evidence of operating one level up, not a single lucky example.
Hiring requirements	State a minimum and target level in the job description per role family.	Interview tasks that probe real capability (see 16.6), not tool familiarity.
Training plan	Map each person's gap (current vs. target level) to specific enablement.	Named next level, named skills, a date to re-assess.
Career path	Use the ladder as a transparent map of what the next step requires.	Each person can name their current level and the next two.
Team capability planning	Aggregate levels to a heat map; find single points of failure.	No critical workflow depends on one L6+ individual.
Succession planning	Identify who can cover L6+ roles; build a bench.	At least two credible successors per critical AI role.
AI champion selection	Select from sustained L6 performers with peer-lifting evidence.	Champions chosen for enablement impact, not output volume.
Manager evaluation	Evaluate managers on team capability growth and safe adoption, not personal usage.	Team level distribution improves and incidents stay near zero.

16.2 Minimum level by seniority (recommendation)

These are synthesized recommendations for a regulated environment, not a published industry standard. Calibrate to your own risk appetite.

Role / seniority	Minimum acceptable	Healthy target	Stretch
All staff (any function)	L2 Awareness	L3 Basic User	L4
Junior / associate engineer	L3	L4 Effective Prompt User	L5
Mid-level engineer	L4	L5 Workflow User	L6
Senior engineer	L5	L6 Power User	L7
Tech lead	L5	L6–L7	L8
Architect	L6	L7–L8 Solution Designer	L9

Role / seniority	Minimum acceptable	Healthy target	Stretch
AI champion	L6	L7	L8+
Engineering manager	L3 personal + team-growth track record	L4 personal + demonstrable team uplift	—
Security / governance specialist	L4 + L10 governance literacy	L5 + governance ownership	L10
Platform / MLOps specialist	L6	L8	L9 Agent/ Platform Builder

16.3 Evidence accepted for promotion

Promotion should rest on demonstrated, verifiable impact, not on volume of AI usage.

Level moving into	Acceptable evidence	Not acceptable as sole proof
L3	Safe routine use with verification logs on low-risk tasks.	"I use it every day."
L4	Before/after examples showing prompting technique improved a result.	Saved prompts with no outcome.
L5	A multi-step workflow with measured time/quality gain and a control point.	A one-off impressive output.
L6	Documented norms adopted by peers; measurable uplift of teammates.	High personal throughput alone.
L7	A production automation with approval and rollback gates, signed off.	A demo or notebook prototype.
L8	An end-to-end solution that passed model-risk validation.	A working POC without validation.
L9	A reusable agent/platform used by multiple teams with guardrails.	A single-team internal tool.
L10	Ownership of enterprise AI strategy, governance, and regulatory risk artifacts.	Title or tenure.

16.4 What NOT to do

- Do not promote on AI usage frequency, prompt counts, or tokens consumed.
- Do not treat a single impressive demo as proof of a sustained level.
- Do not rate people on tools they have not been granted access to.
- Do not let self-reported levels stand without artifacts.
- Do not equate fast output with safe, validated output, especially in regulated workflows.
- Do not skip levels on the strength of one project; require sustained performance.
- Do not make the ladder a surveillance tool; it is a development map.

16.5 Avoiding common distortions

Risk	Why it happens	Guardrail
Overvaluing AI usage without business impact	Activity is easy to measure; impact is not.	Tie every level claim to a business or quality outcome, not activity counts.
Penalizing staff without tool access	Access is unevenly rolled out.	Assess only on tools formally provisioned; record access gaps as an org issue, not a personal score. Provide a path to assessment once access is granted.
Confusing AI usage with AI capability	Heavy users may still produce unverified, unsafe work.	Require evidence of judgment: verification, control points, and rejection of bad output.
Champion chosen for loudness	Visibility is mistaken for capability.	Select on peer-uplift evidence and safe-norm setting (L6 criteria).

16.6 Distinguishing AI usage from true AI capability

True capability is shown by judgment, not activity. Probe for:

- **Verification behavior** — does the person check outputs against authoritative sources before acting?
- **Failure handling** — can they recognize and reject a wrong or hallucinated answer?
- **Control awareness** — do they know what data may and may not enter a tool?
- **Outcome ownership** — can they tie their AI use to a measured result?
- **Transfer** — can they teach the technique to someone else and have it stick?

A practical test: ask the person to walk through a real task end to end and explain why they trusted or rejected each AI output. Usage produces a story about speed; capability produces a story about judgment.

16.7 Evaluating safe AI usage in a regulated environment

In a banking-style setting, "safe" is part of the competency, not an add-on. Assess these alongside capability at every level from L2 upward.

Dimension	What to check	Reference
Data handling	No confidential, PII, or regulated data placed into unapproved tools.	(Inferred from public material) Aligns with data-minimization and confidentiality principles common to GDPR and financial data rules.
Approved tooling	Only sanctioned tools used for work tasks.	Internal tool-approval policy (use your own; do not assume one exists).
Human-in-the-loop	A person reviews and owns every AI-influenced decision that affects customers or risk.	(Inferred from public material) Consistent with regulator expectations on accountability and explainability.

Dimension	What to check	Reference
Model-risk validation	Solutions (L8+) pass independent validation before production.	(Inferred from public material) Mirrors the intent of model-risk-management practice such as the U.S. Federal Reserve / OCC SR 11-7 guidance.
Auditability	Decisions, approvals, and rollbacks are logged.	(Inferred from public material) Supports audit and supervisory review.
Approval & rollback gates	Automations (L7+) cannot deploy without sign-off and a rollback path.	Synthesized recommendation.

Note: The regulatory references above are publicly known frameworks cited as illustrative best practice. They are **not** a claim about any specific internal policy. Replace each reference with your organization's own controls before publishing.

17. 4-Month and 12-Month Target Levels

These tables set realistic capability targets at two horizons: a 4-month horizon (one onboarding/enablement cycle) and a 12-month horizon (one full performance year). Targets are **synthesized recommendations** for a regulated financial-services technology org, not a published benchmark. Adjust to your risk appetite, tool-access rollout, and starting baseline.

Assumptions behind these targets: - Tools are formally provisioned and a safe-use policy exists before assessment begins. - "All staff" includes non-engineering functions; engineering roles carry higher targets. - Movement of one level per cycle is realistic for most people; two levels in a year is achievable only for high performers with support. - Higher levels (L7+) require organizational scaffolding (governance, validation, platforms), so targets there reflect role scope, not just individual ambition.

17.1 Target levels by role and seniority

Role / seniority	Typical start (Inferred)	4-month target	12-month target	Rationale
All staff (non-eng)	L0-L1	L2 Awareness	L3 Basic User	Everyone must understand data rules before use, then reach safe routine use.
Junior / associate engineer	L1-L2	L3 Basic User	L4 Effective Prompt User	Build safe daily habits first, then deliberate prompting skill.
Mid-level engineer	L2-L3	L4	L5 Workflow User	Move from single tasks to measured multi-step workflows.

Role / seniority	Typical start (Inferred)	4-month target	12-month target	Rationale
Senior engineer	L3-L4	L5	L6 Power User	Become a workflow owner, then a team-lifting expert.
Tech lead	L4	L5-L6	L6-L7	Lead by setting safe norms; begin sponsoring approved automations.
Architect	L5	L6	L7-L8 Solution Designer	Design solutions that can clear model-risk validation.
AI champion	L5-L6	L6 Power User	L7 Automation Contributor	Consolidate peer-lifting, then deliver a governed automation.
Engineering manager	L2-L3 personal	L3 personal + team plan	L4 personal + measurable team uplift	Managers are judged on team growth and safe adoption, not personal output.
Security / governance specialist	L3-L4	L4 + governance literacy	L5 + governance ownership (L10 track)	Capable enough to assess use; owns the safe-use guardrails.
Platform / MLOps specialist	L5-L6	L6-L7	L8 Solution Designer / toward L9	Builds the validated automations and platforms others depend on.

17.2 Organization-level targets (distribution)

Individual targets roll up into a healthier capability distribution. The figures below are illustrative planning goals, not a measured benchmark.

Capability band	4-month goal	12-month goal	Why it matters
L0-L1 (no exposure)	Below 20% of staff	Near 0% of staff	Unaware users are the main data-risk exposure.
L2-L3 (aware / basic)	Majority of all staff	Majority of non-eng staff	Safe routine use becomes the baseline.
L4-L5 (effective / workflow)	Majority of engineers	Majority of engineers	Productivity gains come from this band.
L6 (power users)	At least 1 per team	2+ per critical team	Local experts set safe norms and lift others.
L7-L8 (automation / solution)	A small, governed group	Enough to cover all critical workflows	Production impact with validation and rollback.
L9-L10 (platform / strategy)	Named owners exist	Bench of 2+ per critical role	Avoids single points of failure in AI leadership.

17.3 What makes these targets realistic (and what breaks them)

Enabler	Effect	If missing
Provisioned tools + safe-use policy	Assessment and growth can start	Targets stall; staff cannot be fairly assessed
One enablement cycle per level	One-level moves become routine	Progress slips; expect half the movement
Governance, validation, platforms in place	L7+ targets are reachable	High levels become aspirational only
Manager incentives tied to team uplift	Distribution improves broadly	Growth concentrates in a few individuals
Honest baseline assessment	Targets are credible	Inflated levels erode trust in the framework

Reminder: All numeric distribution goals and per-role targets in Section 17 are **synthesized planning recommendations**. They are not derived from any internal company ladder or external published benchmark. Calibrate against your own baseline before committing them in a report.

18. Training Plan by Level

This plan maps every ladder level (L0/L1 through L10) to a concrete learning path. Each level builds on the one below it, so no learner should skip a tier. Training references are real, publicly available programs; where a program name is exact it is hyperlinked. Time estimates assume a working professional learning part-time alongside their day job.

How to read the tables - "Time investment" is total effort to reach competence at that level, not calendar time. - "Assessment method" is how a manager or L&D confirms the level was actually reached, not just attended. - Security/governance and banking/regulatory rows are mandatory gates: a learner cannot be signed off at a level until those are passed, regardless of skill.

A consolidated reference list of all cited public training sits at the end of this section.

L0/L1 — No Exposure

Item	Detail
Learning objectives	Understand what generative AI is and is not; recognize where AI is already embedded in daily tools; understand why uncontrolled use creates data, privacy, and conduct risk.

Item	Detail
Required courses / topics	Microsoft Learn "AI fundamentals" path; AWS "Introduction to Generative AI - Art of the Possible"; internal AI Acceptable Use Policy briefing.
Hands-on labs	None required. Optional sandbox walkthrough of an approved tool led by a trainer (read-only observation).
Role-specific exercises	Spot-the-AI exercise: identify which tools in the person's own workflow already contain AI features.
Security / governance training	Mandatory: data classification basics (public / internal / confidential / restricted); "never paste customer or restricted data into an unapproved tool."
Banking / regulatory awareness	Overview of why financial-services firms are regulated; confidentiality, customer data protection, and conduct expectations.
Assessment method	Short multiple-choice quiz (pass = correct on all data-handling questions); signed acknowledgement of AI Acceptable Use Policy.
Estimated time investment	2–4 hours.
Recommended next-level path	Complete data-handling rules module in full, then enroll in L2 awareness training before touching any tool.

L2 — AI Awareness

Item	Detail
Learning objectives	Explain how large language models work at a conceptual level; understand hallucination, data leakage, and prompt-injection risk; know which tools are approved and the data rules before first use.
Required courses / topics	Google Cloud "Introduction to Generative AI" (Skills Boost); Microsoft Learn "Fundamentals of Generative AI"; internal approved-tool register and data-handling SOP.
Hands-on labs	Guided first session in an approved enterprise tool on synthetic/non-sensitive data only.
Role-specific exercises	Classify five sample prompts as safe / unsafe to submit, with reasoning.
Security / governance training	OWASP Top 10 for LLM Applications awareness overview (focus on prompt injection and sensitive-information disclosure); shadow-AI reporting path.
Banking / regulatory awareness	Customer data confidentiality, record-keeping obligations, and why AI output may need human review before any external or customer-facing use.
Assessment method	Scenario quiz on data handling; trainer sign-off that the learner can state the approved-tool list and the "do not submit" data categories from memory.

Item	Detail
Estimated time investment	4–6 hours.
Recommended next-level path	Begin supervised low-risk daily use; progress to L3 once data rules are second nature.

L3 — Basic AI User

Item	Detail
Learning objectives	Use an approved tool safely for routine low-risk tasks; always verify output before use; recognize when a task is too sensitive for AI.
Required courses / topics	AWS "Generative AI Learning Plan" (foundational modules); vendor academy onboarding for the firm's primary tool (e.g., Microsoft Copilot adoption training).
Hands-on labs	Complete 8–10 real low-risk tasks (drafting internal notes, summarizing public docs) with a verification checklist.
Role-specific exercises	Maintain a one-week "verify log": every AI output used at work, plus the check performed before relying on it.
Security / governance training	Output verification discipline; citation and source-checking; recognizing confabulation (per NIST AI 600-1 GenAI risk categories).
Banking / regulatory awareness	"Human-in-the-loop" expectation for anything touching customers, financials, or decisions; non-reliance on unverified AI output.
Assessment method	Review of the verify log by a manager or L4+ peer; demonstrate catching at least one AI error during the assessment.
Estimated time investment	8–12 hours over 2–3 weeks.
Recommended next-level path	Move to deliberate prompting technique; enroll in L4 prompting course.

L4 — Effective Prompt User

Item	Detail
Learning objectives	Get reliable, repeatable results through deliberate prompting (role, context, constraints, examples, output format); iterate and refine systematically.
Required courses / topics	Google Cloud "Prompt Design in Vertex AI" / "Introduction to Prompt Engineering"; vendor prompt-engineering academy modules; Anthropic prompt engineering documentation.

Item	Detail
Hands-on labs	Build and test 3–5 reusable prompt templates for the learner's own recurring tasks; measure quality before/after templating.
Role-specific exercises	Take a poor prompt and a good prompt for the same task; document why the good one produces better, safer output.
Security / governance training	Prompt-injection awareness in practice; avoiding embedding sensitive data in saved/shared prompts.
Banking / regulatory awareness	Ensuring prompted outputs remain auditable and explainable; not encoding policy decisions into prompts without review.
Assessment method	Submit a small prompt library with before/after quality evidence; peer review by an L5+ user confirms repeatability.
Estimated time investment	12–16 hours over 3–4 weeks.
Recommended next-level path	Start chaining prompts into multi-step workflows; enroll in L5 workflow training.

L5 — Workflow AI User

Item	Detail
Learning objectives	Embed AI across multi-step, multi-tool workflows; measure time saved and quality impact; standardize a workflow others can reuse.
Required courses / topics	Microsoft Learn Copilot / Power Platform AI workflow modules; AWS "Generative AI Learning Plan" intermediate modules; internal tooling integration guides.
Hands-on labs	Build one end-to-end workflow (e.g., intake → draft → review → finalize) with measured baseline vs. AI-assisted metrics.
Role-specific exercises	Document a real workflow with hand-off points, verification checkpoints, and a measured productivity delta.
Security / governance training	Data flow mapping for the workflow; confirming no restricted data crosses an unapproved boundary; logging and traceability.
Banking / regulatory awareness	Maintaining audit trails across steps; ensuring control checkpoints are not removed for speed; segregation-of-duties awareness.
Assessment method	Present one workflow with documented metrics and data-flow review; sign-off requires evidence of measured gain and an intact control point.
Estimated time investment	20–30 hours over 4–6 weeks.

Item	Detail
Recommended next-level path	Begin coaching peers and setting team norms; enroll in L6 leadership and standards track.

L6 — AI Power User

Item	Detail
Learning objectives	Act as the team's AI expert; set safe, practical usage norms; lift the capability of others; evaluate new tools responsibly.
Required courses / topics	AWS Skills Builder advanced generative AI plan; vendor "champion"/trainer-track programs (e.g., Microsoft Copilot champion enablement); facilitation and coaching skills.
Hands-on labs	Run an internal enablement session; pilot-evaluate one new approved-tool feature and write a short go/no-go recommendation.
Role-specific exercises	Author the team's AI usage playbook (approved tools, prompt patterns, verification rules) and onboard two colleagues from L2/L3 upward.
Security / governance training	OWASP Top 10 for LLM Applications (full, not just awareness); NIST AI RMF four core functions (Govern, Map, Measure, Manage) overview.
Banking / regulatory awareness	How team practices map to firm policy and regulator expectations; escalation paths for risky use; conduct accountability as a norm-setter.
Assessment method	Evidence of two coached colleagues advancing a level; review of the team playbook by governance/L8+; delivery of one enablement session.
Estimated time investment	30–40 hours over 6–8 weeks plus ongoing coaching.
Recommended next-level path	Move from usage to building approved automations; enroll in L7 automation and approval-gates track.

L7 — AI Automation Contributor

Item	Detail
Learning objectives	Build production AI automations that run with explicit approval, monitoring, and rollback gates; understand the SDLC and change-control implications.
Required courses / topics	AWS "Generative AI Learning Plan for Developers (includes labs)"; Microsoft Learn Azure AI / Copilot Studio developer paths; internal change-management and CI/CD training.
Hands-on labs	Build a small automation in a sandbox with a tested rollback and a kill switch; pass a peer code/security review before any production path.

Item	Detail
Role-specific exercises	Produce a runbook covering failure modes, rollback steps, monitoring alerts, and approver sign-off for one automation.
Security / governance training	OWASP Top 10 for LLM Applications applied to built systems (insecure output handling, excessive agency, supply chain); secrets management; least-privilege access.
Banking / regulatory awareness	Change-approval and segregation-of-duties controls; auditability and logging requirements; awareness that production AI may fall under model-risk and operational-risk policy.
Assessment method	Production-readiness review: rollback tested, gates demonstrated, security review passed, runbook approved by change board.
Estimated time investment	40–60 hours over 8–10 weeks.
Recommended next-level path	Move from single automations to designed solutions; enroll in L8 solution-design and model-risk track.

L8 — AI Solution Designer

Item	Detail
Learning objectives	Architect end-to-end AI solutions (data, model, integration, controls, monitoring) that pass formal model-risk validation.
Required courses / topics	AWS "Generative AI Developer Advanced Learning Plan"; cloud architect AI specializations (AWS / Google Cloud / Azure AI engineer paths); model-risk management fundamentals.
Hands-on labs	Produce a full solution design with threat model, evaluation/test plan, monitoring design, and human-oversight design for one real use case.
Role-specific exercises	Write the validation package: intended use, limitations, data lineage, evaluation results, bias/fairness checks, and ongoing monitoring plan.
Security / governance training	NIST AI RMF and NIST AI 600-1 GenAI Profile applied to a designed solution (mapping the 12+ GenAI risk categories to mitigations); OWASP LLM threat modeling.
Banking / regulatory awareness	Model-risk management expectations (validation, documentation, independent review, ongoing monitoring); explainability and challenge requirements; data residency and privacy law alignment.
Assessment method	Solution design passes a mock or real model-risk validation review by an independent reviewer; documentation deemed audit-ready.
Estimated time investment	60–90 hours over 10–14 weeks.

Item	Detail
Recommended next-level path	Move from solutions to reusable platforms; enroll in L9 agent/platform track.

L9 — AI Agent/Platform Builder

Item	Detail
Learning objectives	Build reusable agent platforms and shared guardrails that many teams safely build on; standardize controls, evaluation, and observability org-wide.
Required courses / topics	Advanced agent/orchestration training (vendor agent academies, AWS Bedrock Agents, Azure AI agent services); platform engineering and SRE for AI; agentic risk profiles.
Hands-on labs	Stand up a guardrailed agent platform component (policy enforcement, logging, evaluation harness, rate/scope limits) used by at least one downstream team.
Role-specific exercises	Define platform-wide guardrail standards and a self-service governance gate that other builders must pass before deploying.
Security / governance training	Cloud Security Alliance / NIST AI RMF agentic profile concepts (excessive agency, tool-use risk, autonomy limits); platform-level OWASP LLM controls; supply-chain and dependency security.
Banking / regulatory awareness	Enterprise control frameworks, operational resilience, third-party/model supply-chain risk, and consistent audit evidence across all tenants of the platform.
Assessment method	Independent architecture and security review of the platform; evidence that downstream teams inherit guardrails by default; documented governance gate in use.
Estimated time investment	90-120+ hours over 3-4 months, with ongoing platform ownership.
Recommended next-level path	Move from building to owning strategy and governance; enroll in L10 strategy/governance track.

L10 — AI Strategy/Governance Leader

Item	Detail
Learning objectives	Own enterprise AI strategy, governance operating model, and regulatory risk posture; set policy, risk appetite, and investment priorities.
Required courses / topics	Executive AI governance and risk programs; NIST AI RMF (full framework, Govern function in depth); regulatory horizon scanning (e.g., EU AI Act, sector model-risk guidance); board-level AI risk briefings.

Item	Detail
Hands-on labs	Not lab-based. Lead the design or refresh of the enterprise AI governance framework and risk-appetite statement.
Role-specific exercises	Produce the enterprise AI policy, governance committee charter, and a regulator-facing AI risk narrative.
Security / governance training	Enterprise alignment of NIST AI RMF, OWASP LLM, and model-risk management into a single control framework; third-line/audit assurance design.
Banking / regulatory awareness	Direct accountability for regulatory compliance, supervisory engagement, conduct and fairness obligations, and operational resilience for AI across the firm.
Assessment method	Board/regulator-ready governance framework adopted; independent audit or supervisory review confirms control adequacy; measurable adoption of policy across the ladder.
Estimated time investment	Ongoing executive responsibility; structured learning roughly 40–60 hours/year plus continuous regulatory monitoring.
Recommended next-level path	Terminal level. Focus shifts to continuous external regulatory tracking, board reporting, and maturing the program.

Public training reference list

Program	Best fit levels	Notes
Microsoft Learn — AI fundamentals & Copilot paths	L0–L7	Free; spans awareness to developer and Copilot Studio automation.
Google Cloud Skills Boost — Generative AI / Prompt Design	L2–L8	Conceptual through Vertex AI prompt and architect paths.
AWS Skill Builder — Generative AI learning plans	L3–L9	Includes "Generative AI Learning Plan for Developers (includes labs)" and "Generative AI Developer Advanced Learning Plan." 1,000+ free resources.
AWS AI & ML Scholars 2026	L2–L5	Structured program toward AWS Certified AI Practitioner; Challenge phase Mar–Jun 2026.
OWASP Top 10 for LLM Applications	L2 (awareness) → L9 (applied)	Core security curriculum; depth increases with level.
NIST AI Risk Management Framework	L6–L10	Govern/Map/Measure/Manage functions; foundation for governance.
NIST AI 600-1 — Generative AI Profile	L8–L10	12+ GenAI-specific risk categories and 400+ suggested actions.

Program	Best fit levels	Notes
Vendor AI academies (Microsoft Copilot champion, AWS Bedrock, Azure AI, Google Cloud)	L4-L9	Tool-specific enablement, champion, and agent-building tracks.

(Inferred from public material): the mapping of specific public courses to internal ladder levels is a recommendation synthesized from publicly available program content, not a published vendor-to-ladder mapping. Internal SOPs, the approved-tool register, and the firm's model-risk policy referenced in the tables are organization-specific and must be supplied by the firm; they are not fabricated here.

Sources: - [AWS Skill Builder — Generative AI](#) - [AWS AI & ML Scholars 2026](#) - [NIST AI Risk Management Framework](#)

19. Governance and Risk Considerations

A capability ladder for AI-assisted engineers is also a **control surface**. The same rubric that defines "what good looks like" at each level can encode the guardrails a regulated financial-services org needs. This section maps the most material AI risks to ladder behaviors and to four external frameworks engineering and risk leaders already recognize:

- **OWASP LLM Top 10 (2025)** — application-layer threats for LLM systems.
- **NIST AI Risk Management Framework (AI RMF 1.0)** — the four functions Govern, Map, Measure, Manage.
- **ISO/IEC 42001:2023** — the AI Management System (AIMS) standard, audited like ISO 27001.
- **SR 11-7** — U.S. interagency Guidance on Model Risk Management (Federal Reserve / OCC), the baseline supervisors apply to models in banking.

Scope note: SR 11-7 governs models used for business decisions. An AI coding assistant is generally a development tool, not a decision model. But when AI-generated logic enters a model, a control, or a customer-facing decision path, SR 11-7 expectations (validation, documentation, ongoing monitoring) attach to that output. Treat the assistant as in-scope tooling, and treat what it produces as potentially in-scope model code. (Inferred from public material.)

19.1 How the ladder encodes governance

The ladder should make safe behavior a **promotion requirement**, not a side policy. Three principles:

1. **Verification scales with level.** Lower levels are allowed to use AI only with full human review; higher levels are trusted to design controls, set review standards, and be accountable for AI output across a team.

2. **Tool and data access scales with level and is least-privilege.** Access to production data, secrets, and autonomous automation is granted by demonstrated judgment, not by curiosity.
3. **Accountability never transfers to the model.** At every level, a named human owns the merged result. "The AI wrote it" is never an acceptable defense.

19.2 Risk register

Risk	Why it matters	How the ladder mitigates	How HR / managers evaluate it
Hallucination (fabricated APIs, facts, citations)	Wrong code or wrong reasoning ships with confident tone; costly in regulated logic. Maps to OWASP LLM09 Misinformation; NIST Measure; SR 11-7 output validation.	Lower levels: every AI output is verified against authoritative source before use. Higher levels: build automated checks (tests, type checks, doc cross-refs) and teach juniors verification habits.	Look for evidence the engineer caught/ corrected AI errors. Review whether claims in PRs and docs are sourced. Sample merged AI-assisted code for fabricated dependencies.
Data leakage (sensitive data pasted into prompts)	Customer PII, account data, or confidential code sent to external models can breach privacy law and contracts. OWASP LLM02 Sensitive Information Disclosure; NIST Govern/Manage; ISO 42001 data controls; SR 11-7 data governance.	Ladder ties data-class awareness to level; only approved, sanctioned tools/ endpoints permitted. Higher levels define what may/may not enter a prompt and enforce it in review.	Confirm engineers use only sanctioned tools and know data classifications. Check for any PII/secret in prompt logs (where logging is sanctioned). Evaluate whether they redact before prompting.
Prompt injection (malicious instructions in fetched content, tickets, repos)	Untrusted input can hijack an agent into exfiltration or unsafe actions. OWASP LLM01 Prompt Injection (the top risk); NIST Map/Manage.	Higher levels treat all external content as untrusted, constrain agent tool scope, and review agent action logs. Lower levels are not granted autonomous, internet-fed agents.	Ask candidates to identify injection vectors in a scenario. Check that agentic workflows use least-privilege tool scopes. Review incident handling of any injection attempt.
Overtrust / automation bias	Engineers accept AI output without scrutiny; skills atrophy; errors compound. OWASP LLM09; NIST Measure (human factors); SR 11-7 "effective challenge."	Ladder rewards effective challenge of AI output and explicitly does not reward raw acceptance speed. Higher levels model healthy skepticism.	Probe in 1:1s: "When did AI steer you wrong recently, and how did you catch it?" Inability to answer is a red flag. Watch for declining fundamentals masked by tool use.

Risk	Why it matters	How the ladder mitigates	How HR / managers evaluate it
Biased evaluation (judging people by AI volume, not judgment)	Rewarding output velocity over correctness drives bad behavior and can create disparate impact in promotion. NIST Govern (fairness); ISO 42001 (responsible AI objectives).	Rubric measures judgment, verification, and outcomes — not lines of AI code generated. Calibration sessions standardize how AI use is scored.	Audit promotion decisions for consistency. Ensure reviewers are calibrated. Track whether AI-fluent and AI-cautious engineers are assessed on the same outcome criteria.
Unequal tool access	If only some engineers get capable tools, the ladder measures access, not ability — unfair and noisy. NIST Govern; ISO 42001 (fairness/inclusion).	Define a baseline sanctioned toolset available to all at each level; advanced tools gated by training, not favoritism.	Verify everyone at a level has equal access to the tools the rubric assumes. Flag assessments confounded by tooling gaps.
Secrets exposure (keys, tokens in prompts or AI-generated code)	Leaked credentials cause direct breaches; AI can also hardcode secrets. OWASP LLM02; NIST Manage; SR 11-7 controls.	Higher levels enforce secret scanning, vaulting, and never-in-prompt rules; teach this downward. Lower levels operate inside guardrails (pre-commit secret scanning, masked envs).	Check secret-scanning is enabled and respected. Review whether the engineer ever pasted credentials. Test knowledge of the org's secrets-management workflow.
Compliance risk (output violates regulatory/legal requirements)	AI doesn't know your jurisdiction's rules; non-compliant code creates legal/regulatory exposure. NIST Govern/Map; ISO 42001; SR 11-7 documentation & validation.	Higher levels own that AI output meets applicable controls (e.g., audit logging, retention, consent) before merge; embed compliance checks in review.	Assess whether the engineer maps requirements to controls independently. Confirm regulated changes go through required approvals regardless of AI involvement.
Unsafe automation (agents acting on prod, irreversible ops)	Autonomous actions on production or customer systems can cause outages or data loss. OWASP LLM06 Excessive Agency; NIST Manage; SR 11-7 change control.	Autonomy is a high-level privilege with blast-radius limits, dry-runs, approvals, and rollback. Lower levels run agents only in sandboxes.	Verify agent permissions are scoped and reversible. Review change-control adherence for AI-driven changes. Confirm prod actions retain human approval gates.

Risk	Why it matters	How the ladder mitigates	How HR / managers evaluate it
Lack of auditability (no record of what AI did / why)	Regulators expect traceability; "we can't reconstruct it" is a finding. OWASP LLM Top 10 (logging); NIST Measure; ISO 42001 (records); SR 11-7 documentation.	Higher levels ensure AI-assisted changes are documented (what was generated, what was verified) and agent actions are logged.	Check PRs/commits note AI involvement per policy. Confirm agent logs exist and are retained. Test whether a past change can be reconstructed.
Inaccurate AI-generated code (subtle bugs, wrong edge cases)	Plausible-looking code with logic/security flaws reaches prod. OWASP LLM05 Improper Output Handling; NIST Measure; SR 11-7 validation.	Test coverage, security review, and verification rigor are level requirements; higher levels set the bar and review AI-heavy PRs more closely.	Sample AI-assisted merges for defects and test adequacy. Track defect/escape rates by AI usage. Evaluate the engineer's test-writing discipline.
Vendor / model lock-in	Over-reliance on one model/provider raises cost, continuity, and concentration risk. NIST Govern; ISO 42001 (supplier controls); SR 11-7 (vendor models).	Higher levels keep prompts/workflows portable, document model assumptions, and avoid hard dependencies on a single provider where avoidable.	Ask how the engineer would migrate off the current model. Check that critical workflows aren't single-vendor-dependent without a fallback.
Shadow AI (unsanctioned tools/accounts)	Untracked tools bypass data, security, and audit controls — the highest-leverage governance gap. OWASP LLM02/LLM05; NIST Govern/Map; ISO 42001 (asset inventory).	Ladder normalizes using only sanctioned tools and reporting gaps in the toolset rather than working around them; higher levels steward the approved-tool list.	Survey actual tool usage vs. the sanctioned list. Make it safe to disclose unmet needs. Treat discovered shadow AI as a process failure to fix, not just an individual fault.
AI cost control	Token/compute spend can balloon silently; unmanaged agents are expensive. NIST Manage (resource); ISO 42001 (operational controls).	Higher levels use AI cost-effectively, right-size models to tasks, and monitor spend; this is an explicit efficiency expectation, not "use the biggest model always."	Review cost-per-outcome trends. Check engineers choose appropriately sized models. Reward measurable efficiency, not raw consumption.
Human accountability (ownership of AI output)	Diffused ownership erodes safety and regulatory answerability. NIST Govern; ISO 42001 (roles/responsibilities); SR 11-7 (named ownership).	Every level: a named human owns merged output; "the AI did it" is never a defense. Higher levels own outcomes across their team's AI use.	Confirm clear ownership on every change. In retros/incident reviews, verify a human owner is named for AI-assisted work.

19.3 Framework crosswalk (quick reference)

Risk	OWASP LLM Top 10 (2025)	NIST AI RMF function	ISO/IEC 42001	SR 11-7
Hallucination	LLM09 Misinformation	Measure	Performance monitoring	Output validation
Data leakage	LLM02 Sensitive Info Disclosure	Govern / Manage	Data management	Data governance
Prompt injection	LLM01 Prompt Injection	Map / Manage	Operational controls	Change control
Overtrust	LLM09	Measure	Human oversight	Effective challenge
Biased evaluation	— (governance)	Govern	Responsible-AI objectives	Sound development
Unequal tool access	— (governance)	Govern	Fairness / resources	—
Secrets exposure	LLM02	Manage	Information security	Controls environment
Compliance risk	— (governance)	Govern / Map	Legal & regulatory	Documentation / validation
Unsafe automation	LLM06 Excessive Agency	Manage	Operational controls	Change control
Lack of auditability	LLM Top 10 (logging)	Measure	Records & traceability	Documentation
Inaccurate AI code	LLM05 Improper Output Handling	Measure	Verification & validation	Model validation
Vendor / model lock-in	— (governance)	Govern	Supplier management	Vendor model risk
Shadow AI	LLM02 / LLM05	Govern / Map	Asset inventory	Inventory & scope
AI cost control	— (operational)	Manage	Operational controls	Ongoing monitoring
Human accountability	— (governance)	Govern	Roles & responsibilities	Named ownership

19.4 Practical guidance for HR and managers

- **Make safety promotable.** If verification, auditability, and accountability are not in the rubric, they will lose to velocity. Bake them into level expectations and calibration.
- **Evaluate judgment, not volume.** The strongest signal of an AI-mature engineer is the quality of their skepticism: what they rejected, what they verified, what they escalated.

- **Treat shadow AI as a system failure first.** Punishing disclosure drives it underground. Reward people who surface unmet tooling needs.
- **Keep a human name on every change.** Ownership is the single control that ties all the others together and satisfies SR 11-7's expectation of clear accountability.
- **Don't over-claim.** This framework organizes recognized standards against ladder behaviors; it is not a certification. Validation against ISO 42001 or SR 11-7 must be done with your risk, legal, and compliance functions. (Inferred from public material.)

20. HR Implementation Plan

This plan rolls out the AI Capability Ladder (L0-L10) across the organization in four phases. It is designed for a regulated, banking-style technology environment where data-handling controls, model-risk validation, and auditable change management are mandatory. Timelines are indicative and should be adjusted to your headcount and regulatory calendar.

Phasing Overview

Phase	Name	Typical Duration	Primary Owner	Exit Criteria
1	Design & Alignment	4-6 weeks	HR + AI Governance Lead	Ladder definitions signed off; assessment method agreed; governance guardrails published
2	Pilot	6-10 weeks	Senior DevOps Manager + HR Business Partner	One team assessed L0-L10; baseline measured; playbook refined
3	Rollout	1-2 quarters	HR + Engineering Directors	All in-scope staff assessed and assigned development paths
4	Continuous Improvement	Ongoing	AI Governance Board	Quarterly re-assessment cycle running; metrics reviewed each quarter

Phase 1 — Design & Alignment (4-6 weeks)

Goal: Agree what each ladder level means in your context, how you assess it, and what guardrails apply before anyone uses a tool.

Activity	Description	Output
Confirm ladder definitions	Map L0-L10 to your roles (e.g., who is expected to reach L3 vs L6 vs L9)	Role-to-level expectation matrix

Activity	Description	Output
Define assessment evidence	Decide what counts as proof of each level (e.g., L4 = demonstrated prompt patterns; L7 = a merged automation with rollback)	Evidence rubric per level
Set the data-handling gate	Publish what data may/may not enter GenAI tools; tie it to the L2 "AI Awareness" gate	Approved tool list + data-classification rules
Align with model-risk & compliance	Confirm L8+ work routes through model-risk validation; define approval/rollback gates for L7	Governance sign-off
Communications plan	Explain why the ladder exists, that it is developmental not punitive	Internal launch message + FAQ

Key alignment decisions to lock: - No work use of GenAI above L1 until the L2 awareness gate is passed (training + acknowledgement). - L7 production automations require approval and rollback gates. - L8+ solutions must pass model-risk validation.

Phase 2 — Pilot (6-10 weeks)

Goal: Run the full ladder on one representative team (DevOps/platform is ideal) to test the rubric, surface friction, and produce a baseline.

Activity	Description	Output
Select pilot team	Choose one team with varied skill levels; secure manager buy-in	Named pilot cohort
Baseline assessment	Place each member on L0-L10 using the evidence rubric	Baseline level distribution
Targeted enablement	Run L2 awareness for anyone below it; coach L3→L4→L5 with real tasks	Training completion log
Test the guardrails	Have the pilot attempt an L7 automation through the approval/rollback path	Working example + lessons
Measure	Track cycle-time, rework, and verification-failure rates against baseline	Pilot metrics report
Refine	Update rubric, evidence definitions, and training based on friction	v2 playbook

Pilot success criteria: - Every pilot member placed on a level with documented evidence. - At least one L7 automation shipped through the approval and rollback gates. - A measurable, attributable gain (e.g., cycle-time or rework reduction) on at least one workflow.

Phase 3 — Rollout (1-2 quarters)

Goal: Extend the assessed ladder and development paths across all in-scope teams without overwhelming managers or compliance.

Activity	Description	Output
Wave planning	Roll out team-by-team (not all at once); sequence by readiness	Rollout schedule
Manager enablement	Train managers to assess, coach, and validate evidence consistently	Calibrated assessors
Mass L2 gate	Ensure everyone passes the awareness gate before tool access	Access tied to gate completion
Assign development paths	Each person gets a target level and next-step actions	Individual development plans
Identify L6 multipliers	Name AI Power Users per team to set norms and lift others	Named L6 leads per team
Tooling & access governance	Provision approved tools by level; log access	Access matrix

Calibration note: Run cross-team calibration sessions so an "L4" means the same thing everywhere. Inconsistent leveling is the fastest way to lose trust in the ladder.

Phase 4 — Continuous Improvement (Ongoing)

Goal: Keep the ladder current as tools, threats, and regulations change, and prove value over time.

Activity	Cadence	Output
Re-assessment cycle	Quarterly	Updated level distribution + movement trends
Metrics review	Quarterly	Productivity, quality, and risk-incident trend report
Guardrail refresh	Quarterly or on regulatory change	Updated data rules, approved-tool list, approval gates
Ladder version control	As needed	Changelog of level/rubric changes
Recognition & progression	Per review cycle	Promotions/recognition tied to demonstrated levels
Incident feedback loop	On event	Lessons fed back into L2 awareness and L7 gates

Metrics to track (illustrative):

Metric	Why it matters
Level distribution over time	Shows capability lift across the org
% staff past the L2 gate	Confirms baseline data-handling safety
Number of L7 automations live (with rollback tested)	Measures safe automation adoption
Verification-failure / rework rate	Detects over-trust of AI output
AI-related risk incidents	Confirms guardrails are working
Cycle-time on AI-supported workflows	Quantifies productivity gains

21. Templates

The following four templates are designed to be copied directly into your performance and promotion processes. All fields are blank and ready to fill. Replace bracketed placeholders such as [] and with real data.

22. Recommended First 10 Actions

A concrete checklist a Senior DevOps Manager can start **this quarter**. Each action is small, measurable, and ordered so that safety (the L2 gate) comes before scaling.

#	Action	Done when...	Suggested owner
1	Publish the approved-tool and data-handling rules (what data may/may not enter GenAI). Tie it explicitly to the L2 awareness gate.	A one-page rule sheet is published and acknowledged by the team.	DevOps Manager + Compliance
2	Run the L2 "AI Awareness" gate for the whole team (short training + acknowledgement) before any further tool use.	100% of team members have completed and signed off.	DevOps Manager + HR
3	Baseline every team member on L0-L10 using the evidence rubric.	Each person has a documented level with evidence.	DevOps Manager
4	Pick one real workflow to improve (e.g., incident runbooks, PR review, log triage) and measure its current cycle-time/rework.	A baseline number is recorded for that workflow.	DevOps Manager
5	Coach 2-3 people from L3 to L4 with deliberate prompting on low-risk tasks.	At least 2 people demonstrate reliable, repeatable prompt patterns.	L6 lead / DevOps Manager

#	Action	Done when...	Suggested owner
6	Name an L6 "AI Power User" on the team to set safe norms and mentor others.	One person is formally designated and given time to coach.	DevOps Manager
7	Define the L7 approval + rollback gate for any production automation.	A written checklist exists: who approves, how to roll back, how it's logged.	DevOps Manager + Change Mgmt
8	Ship one small L7 automation through that gate (low blast radius, fully reversible).	One automation is live, approved, and its rollback has been tested.	DevOps engineer + L6 lead
9	Stand up a simple metrics dashboard (level distribution, % past L2 gate, automations live, rework rate).	The dashboard shows current numbers for the team.	DevOps Manager
10	Schedule the quarterly re-assessment and review so the ladder stays live, not a one-off exercise.	A recurring calendar invite and review template exist.	DevOps Manager + HR

Sequencing logic (Inferred from public material on staged change management and AI-governance best practice): Lock data-handling and the L2 gate first (Actions 1–2), establish a baseline and a measurable target workflow (Actions 3–4), build human capability and a local champion (Actions 5–6), only then introduce reversible automation behind explicit gates (Actions 7–8), and finally make the whole effort measurable and repeatable (Actions 9–10).

Note: The L0–L10 ladder levels referenced here are taken from the assignment brief. This implementation plan synthesizes general, publicly understood change-management and AI-governance practice; it does not reproduce any specific company's internal HR ladder.

17.1 Self-Assessment Form

Field	Entry
Employee name	_____
Employee ID	_____
Current title / level	_____
Team / department	_____
Manager name	_____
Review period (from – to)	<u> </u> to <u> </u>

Field	Entry
Date submitted	_____

Key Achievements This Period

#	Achievement	Business / customer impact	Evidence link or reference
1			
2			
3			

Self-Rating by Competency (scale: 1 = Developing, 2 = Meets, 3 = Strong, 4 = Exceeds)

Competency	Self-rating (1-4)	Supporting comment
Technical / craft skills	[]	
Delivery & execution	[]	
Code / work quality	[]	
Collaboration & teamwork	[]	
Communication	[]	
Ownership & reliability	[]	
Compliance & risk awareness	[]	
Mentoring / leadership (if applicable)	[]	

Reflection Questions

Question	Response
What am I most proud of this period?	
Where did I fall short, and why?	
What skills do I want to build next?	
What support do I need from my manager / team?	
Do I believe I am ready for promotion? Why?	

Employee signature	_____	Date	_____

17.2 Manager Assessment Form

Field	Entry
Employee name	_____
Current title / level	_____
Manager name	_____
Review period (from – to)	<u> </u> to <u> </u>
Date completed	_____

Competency Assessment (scale: 1 = Developing, 2 = Meets, 3 = Strong, 4 = Exceeds)

Competency	Rating (1-4)	Evidence / specific example
Technical / craft skills	[]	
Delivery & execution	[]	
Code / work quality	[]	
Collaboration & teamwork	[]	
Communication	[]	
Ownership & reliability	[]	
Compliance & risk awareness	[]	
Mentoring / leadership (if applicable)	[]	

Overall Summary

Field	Entry
Overall rating	[] Below expectations [] Meets [] Exceeds
Top 2 strengths	
Top 2 development areas	
Agreement with employee self-assessment?	[] Yes [] Partial [] No — explain below
Notes on any gaps vs. self-assessment	

Development & Next Steps

Goal for next period	Success measure	Target date

Promotion Recommendation

Field	Entry
Recommend for promotion this cycle?	☐ Yes ☐ Not yet ☐ No
Target level	_____
Justification (evidence-based)	

Manager signature	_____	Date	_____

17.3 Practical Test Scoring Sheet

Field	Entry
Candidate name	_____
Role / level assessed	_____
Test / exercise name	_____
Date of test	_____
Evaluator name	_____

Scoring (scale: 0 = Not demonstrated, 1 = Partial, 2 = Adequate, 3 = Strong, 4 = Excellent)

Criterion	Weight (%)	Raw score (0-4)	Weighted score	Notes
Problem understanding & approach		[]		
Correctness of solution		[]		
Code quality / structure		[]		
Handling of edge cases & errors		[]		
Security & data-handling awareness		[]		
Performance / efficiency		[]		
Testing & verification		[]		
Communication of decisions		[]		
Total	100	—		

Outcome

Field	Entry
Total weighted score	___ / 100
Pass threshold	___
Result	☐ Pass ☐ Borderline ☐ Fail
Key strengths observed	
Key concerns	
Recommendation	

Evaluator signature	_____	Date	_____

17.4 Promotion Evidence Checklist

Field	Entry
Employee name	_____
Current level	_____
Target level	_____
Sponsoring manager	_____
Review cycle	_____

Evidence Requirements (mark each as complete and link the proof)

Requirement	Met?	Evidence link / reference	Reviewer note
Consistently performs at target level (min. sustained period)	☐ Yes ☐ No		
Delivery track record (shipped work, outcomes)	☐ Yes ☐ No		
Demonstrated scope / complexity for target level	☐ Yes ☐ No		
Impact beyond own immediate tasks	☐ Yes ☐ No		
Collaboration & cross-team contribution	☐ Yes ☐ No		

Requirement	Met?	Evidence link / reference	Reviewer note
Mentoring / knowledge sharing (if required at level)	[] Yes [] No		
Compliance & risk record clean for period	[] Yes [] No		
Practical test / assessment passed (if required)	[] Yes [] No		
Self-assessment submitted	[] Yes [] No		
Manager assessment submitted	[] Yes [] No		
Peer / stakeholder feedback collected	[] Yes [] No		

Sign-Off

Role	Name	Decision	Signature	Date
Sponsoring manager		[] Approve [] Hold		
Skip-level / department head		[] Approve [] Hold		
HR / People partner		[] Approve [] Hold		
Final decision		[] Approved [] Deferred [] Declined		

Final notes / conditions	

23. References and Sources

Sources are public frameworks, vendor documentation, engineering blogs, and reports (knowledge as of ~Jan 2026). Items marked (Inferred) in the body are reasoned from public material, not internal HR documents.

- **The Impact of AI on Developer Productivity: Evidence from GitHub Copilot (arXiv 2302.06590)** — <https://arxiv.org/abs/2302.06590> — RCT showing ~55.8% faster task completion with Copilot
- **GitHub Blog: Quantifying GitHub Copilot's impact in the enterprise with Accenture** — <https://github.blog/news-insights/research/research-quantifying-github-copilots-impact-in-the-enterprise-with-accenture/> — Enterprise-scale randomized trial

- **AWS Certified AI Practitioner (AIF-C01) exam guide** — <https://docs.aws.amazon.com/aws-certification/latest/ai-practitioner-01/ai-practitioner-01.html> — Foundational AI certification domains
- **AWS Certified Generative AI Developer - Professional** — <https://aws.amazon.com/certification/certified-generative-ai-developer-professional/> — Builder-track GenAI certification
- **Microsoft 365 Copilot Skilling Center** — <https://adoption.microsoft.com/en-us/copilot/skilling-center/> — Role-based skilling resources
- **Microsoft Learn: Agentic AI maturity model (governance & security)** — <https://learn.microsoft.com/en-us/microsoft-copilot-studio/guidance/maturity-model-security-governance> — Governance maturity ladder
- **C5 Insight: 5 Levels of Microsoft Copilot Adoption Maturity** — <https://c5insight.com/5-levels-of-microsoft-copilot-adoption-maturity/> — Partner-published maturity model (Inferred)
- **DORA 2024 State of DevOps Report highlights (getdx summary)** — <https://getdx.com/blog/2024-dora-report/> — AI adoption vs delivery stability findings
- **DORA Insights** — <https://dora.dev/insights/> — Google's DevOps research program
- **IBM Certified watsonx Governance Lifecycle Advisor v1 - Associate** — <https://www.ibm.com/training/certification/ibm-certified-watsonx-governance-lifecycle-advisor-v1-associate-C9008000> — Governance-specific certification
- **IBM watsonx.governance product page** — <https://www.ibm.com/products/watsonx-governance> — Lifecycle governance, risk monitoring, factsheets
- **IBM OpenPages Model Risk Governance docs** — https://www.ibm.com/docs/en/SSFUEU_9.0.0/op_grc_admin/c_adm_mrg.html — Model-risk governance relevant to banking
- **A Practical Guide to Enterprise AI Adoption (OpenAI/Anthropic playbooks)** — <https://www.linkedin.com/pulse/openai-anthropic-playbooks-practical-guide-enterprise-gleb-markevich-evjse> — Summary of vendor enterprise adoption guidance
- **Stanford Digital Economy Lab: The Enterprise AI Playbook (51 deployments)** — https://digitaleconomy.stanford.edu/app/uploads/2026/03/EnterpriseAIPlaybook_PereiraGraylinBrynjolfsson.pdf — Cross-enterprise adoption evidence
- **PYMNTS: Anthropic 30-Day Data Policy and enterprise governance gaps** — <https://www.pymnts.com/news/artificial-intelligence/2026/anthropic-30-day-data-policy-exposes-enterprise-ai-governance-gaps/> — Data custody / vendor-risk governance
- **Gartner AI Maturity Model (BMC summary)** — <https://www.bmc.com/blogs/ai-maturity-models/> — Five stages: Awareness, Active, Operational, Systemic, Transformational
- **Deloitte: State of AI in the Enterprise 2026** — <https://www.deloitte.com/us/en/what-we-do/capabilities/applied-artificial-intelligence/content/state-of-ai-in-the-enterprise.html> — Workforce AI fluency, upskilling/reskilling, job redesign findings

- **Deloitte AI Academy** — <https://www.deloitte.com/us/en/what-we-do/capabilities/applied-artificial-intelligence/about/deloitte-ai-academy.html> — Internal role-based upskilling and certification program
- **Deloitte: Generative AI shaping the future workforce** — <https://www.deloitte.com/cbc/en/what-we-do/genai/the-future-workforce.html> — Future-of-work and new AI roles framing
- **McKinsey QuantumBlack** — AI/analytics arm; defines technical role archetypes (data scientist, ML engineer, data engineer, translator, designer). Well-established public knowledge.
- **BCG X / 10-20-70 principle** — Tech build/design unit; 10% algorithms, 20% tech & data, 70% people & process. Well-established public knowledge.
- **PwC Responsible AI** — Responsible AI toolkit and 'New world. New skills.' reskilling. Well-established public knowledge.
- **KPMG Trusted AI / AI governance** — AI governance and digital-workforce framework. Well-established public knowledge.
- **Forrester AI maturity / adoption** — Adoption-tier maturity research; exact tier labels vary by report (Inferred from public material).
- **Accenture LearnVantage** — Large-scale AI talent transformation and reskilling. Well-established public knowledge.
- **ServiceNow Now Assist platform** — <https://www.servicenow.com/platform/now-assist.html> — Now Assist, Skill Kit, Data Kit, Analytics, Guardian
- **ServiceNow touts AI governance for its Autonomous Workforce (TechTarget)** — <https://www.techtarget.com/searchitoperations/news/366639250/ServiceNow-touts-AI-governance-for-its-Autonomous-Workforce> — Guardian / governance three-part model
- **Now Assist Governance Tools and Guardrails (ServiceNow Community)** — <https://www.servicenow.com/community/now-assist-blog/now-assist-governance-tools-and-guardrails/ba-p/3517694> — HITL escalation, sensitive-topic routing
- **PagerDuty H2 2025 Release: AI Agents** — <https://www.pagerduty.com/blog/product/product-launch-2025-h2/> — SRE Agent, suggest/act-on-approval, smart playbooks
- **PagerDuty Runbook Automation** — <https://www.pagerduty.com/platform/automation/runbook/> — AI-generated runbooks, HITL responder-invoked automation
- **GitLab Duo Agent Platform HITL guardrails (Epic 22381)** — https://gitlab.com/groups/gitlab-org/-/work_items/22381 — Tool approval gates beta
- **GitLab Duo agentic security threats (docs)** — https://docs.gitlab.com/user/duo_agent_platform/security_threats/ — Prompt injection, composite identity, agentic threats
- **GitLab Duo CLI agentic AI** — <https://about.gitlab.com/blog/gitlab-duo-cli/> — HITL-by-default interactive mode
- **Atlassian Rovo agents practical guide (Devoteam)** — <https://www.devoteam.com/expert-view/atlassians-rovo-agents/> — 3-level autonomy and governance-in-the-loop
- **Atlassian Rovo agents in Jira Service Management** — <https://www.atlassian.com/blog/jira-service-management/rovo-agents-service-desk-instant-resolution> — JSM agentic automation, knowledge-grounded resolution

- **SFIA 9 - a framework for AI skills** — <https://sfia-online.org/en/sfia-9/sfia-9-release-notes/ai-skills-framework> — 7 Levels of Responsibility; AI/data skills added in SFIA 9 (2024)
- **SFIA Levels of Responsibility for human/AI task allocation** — <https://sfia-online.org/en/sfia-9/sfia-9-release-notes/ai-skills-framework/using-sfia-levels-of-responsibility-to-analyse-what-tasks-responsibilities-to-assign-to-ai> — Guidance on splitting work between humans and AI using the 7 levels
- **CNCF Platform Engineering Maturity Model** — <https://tag-app-delivery.cncf.io/whitepapers/platform-eng-maturity-model/> — Maturity levels across Investment, Adoption, Interfaces, Operations, Measurement
- **OWASP Top 10 for LLM Applications 2025** — <https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/> — Official 2025 ranked LLM risk list (LLM01-LLM10)
- **OWASP LLM10:2025 Unbounded Consumption** — <https://genai.owasp.org/llmrisk/llm102025-unbounded-consumption/> — Confirms LLM10 broadened from Model DoS to denial-of-wallet/model extraction
- **ISO 42001 Annex A Controls Explained (ISMS.online)** — <https://www.isms.online/iso-42001/annex-a-controls/> — 38 AI-specific controls across 9 objectives; ISO 27001-style pattern
- **JPMorgan Chase AI assistant (LLM Suite) - CNBC** — <https://www.cnbc.com/2024/08/09/jpmorgan-chase-ai-artificial-intelligence-assistant-chatgpt-openai.html> — OpenAI-powered internal assistant rolled out to employees
- **JPMorgan Chase to equip 140K workers with GenAI - CIO Dive** — <https://www.ciodive.com/news/JPMorgan-Chase-LLM-Suite-generative-ai-employee-tool/726772/> — Scale of LLM Suite rollout
- **LLM Suite named American Banker Innovation of the Year - JPMorganChase** — <https://www.jpmorganchase.com/about/technology/blog/llmsuite-ab-award> — Firm blog; multi-model gateway, upgrades, use cases
- **Morgan Stanley Research announces AskResearchGPT - Morgan Stanley press release** — <https://www.morganstanley.com/press-releases/morgan-stanley-research-announces-askresearchgpt> — GPT-4o assistant over 70K+ research reports
- **Morgan Stanley expands OpenAI chatbot to Wall Street division - CNBC** — <https://www.cnbc.com/2024/10/23/morgan-stanley-rolls-out-openai-powered-chatbot-for-wall-street-division.html> — AI @ Morgan Stanley Assistant/Debrief and institutional rollout
- **Goldman Sachs launches AI assistant for employees - CNBC** — <https://www.cnbc.com/2025/01/21/goldman-sachs-launches-ai-assistant.html> — Firmwide GS AI Assistant after ~10K pilot
- **Goldman Sachs internal AI assistant - Fortune** — <https://fortune.com/2025/06/24/goldman-sachs-internal-ai-assistant> — Developer-tailored version and approved internal-hosted models
- **Capital One Machine Learning Engineering Training Program (MLETP)** — <https://www.capitalone.com/tech/machine-learning/accelerating-machine-learning-engineering-with-a-new-capital-one-skills-program/> — 160-hour program; Responsible/Explainable AI emphasis

- **Capital One Tech College / tech career development** — <https://www.capitalone.com/tech/culture/tech-future-of-everything/> — Internal academy with Machine Learning & AI track
- **HSBC and AI** — <https://www.hsbc.com/who-we-are/hsbc-and-digital/hsbc-and-ai> — AI Review Councils, governance, human judgement at core
- **DBS Responsible AI in banking** — <https://www.dbs.com/artificial-intelligence-machine-learning/artificial-intelligence/responsible-ai-in-banking-gaining-a-competitive-edge.html> — PURE framework; co-pilot human-in-the-loop stance
- **OCC / Fed revised model risk guidance (SR 11-7 lineage)** — [https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html](https://www OCC.gov/news-issuances/bulletins/2026/bulletin-2026-13.html) — Three-lines-of-defense model risk management applied to AI/GenAI